



**Cyber Security (CYBER);
CRA;
Cybersecurity requirements for operating systems**

Reference

DEN/CYBER-EUS-0012

Keywords

CRA, cybersecurity, operating system

ETSI

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B
Association à but non lucratif enregistrée à la
Sous-Préfecture de Grasse (06) N° w061004871

Important notice

The present document can be downloaded from the
[ETSI Search & Browse Standards](#) application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on [ETSI deliver](#) repository.

Users should be aware that the present document may be revised or have its status changed,
this information is available in the [Milestones listing](#).

If you find errors in the present document, please send your comments to
the relevant service listed under [Committee Support Staff](#).

If you find a security vulnerability in the present document, please report it through our
[Coordinated Vulnerability Disclosure \(CVD\)](#) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.
In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

No part of this document may be reproduced in any form, by any means and in any media, without the prior written authorization of ETSI and except as expressly permitted below.

By way of exception and when the document is a normative deliverable (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)), ETSI authorizes to reproduce and incorporate into products, services and technical documentation only those extracts (e.g. templates) that are strictly necessary for the technical implementation of the normative deliverable, to ensure compliance with the latter. Nothing in this notice shall be construed as limiting any mandatory exceptions to copyright provided by applicable law.

© ETSI 2026.
All rights reserved.

Contents

Intellectual Property Rights	9
Foreword.....	9
Modal verbs terminology	10
Introduction	10
1 Scope	11
1.1 General.....	11
1.2 Products in scope	11
1.2.1 General	11
1.2.2 Components of operating systems that are in scope	12
1.3 Products covered by other CRA harmonised standards	12
2 References	13
2.1 Normative references	13
2.2 Informative references	14
3 Definition of terms, symbols and abbreviations	15
3.1 Terms	15
3.2 Symbols	17
3.3 Abbreviations.....	17
4 Product context.....	18
4.1 Intended purpose and reasonably foreseeable use	18
4.2 Product functions	18
4.3 Product architecture	19
4.3.1 Overview	19
4.3.2 Operating system security functions	19
4.3.3 Privileges.....	19
4.3.4 Access control mechanisms	19
4.3.5 Resource management.....	20
4.3.6 Scheduling.....	20
4.4 Operational Environment.....	20
4.5 Distribution of security functions	21
4.5.1 General	21
4.5.2 Security functions provided by some other part of its context	21
4.5.3 Security functions provided to other components	21
4.6 Users	21
4.7 Use cases.....	21
4.7.1 General	21
4.7.2 Basic use cases	22
4.7.2.1 UC-REST: Restricted operating system	22
4.7.2.2 UC-GEN: General-purpose operating system	22
4.7.3 Conditions	22
4.7.4 Characterising a product.....	23
4.7.5 Risk-factor levels of the basic use cases.....	23
4.8 Remote data-processing dependencies.....	24
4.8.1 General	24
4.8.2 Remote data-processing solutions	24
4.8.3 RDPS interfaces	24
4.8.4 RDPS-dependent product functions	25
5 Technical requirements for products	25
5.1 Notes on the structure of the Requirements	25
5.1.0 General	25
5.1.1 Necessity of Requirements	25
5.1.2 Types of Technical Requirements	25
5.1.3 Assumptions Regarding Requirements	26

5.1.3.1	Testability	26
5.1.3.2	Mitigations	26
5.1.3.3	Residual risk	26
5.2	Technical security requirements specifications	26
5.2.1	General	26
5.2.2	TR-NKEV: No known exploitable vulnerabilities	26
5.2.2.1	MI-KEVM: Documentation of mitigation of known exploitable vulnerabilities	26
5.2.2.2	MI-KEVT: Testing for known exploitable vulnerabilities	27
5.2.3	TR-MINI: Minimise impact on other devices and services	27
5.2.3.1	MI-RRIS: Document residual risk to other devices and services	27
5.2.3.2	MI-MNET: Minimise negative impact of network transmission	27
5.2.4	TR-SDEF: Secure by default configuration	27
5.2.4.1	MI-ADEF: Authorisation required by default to access security-relevant assets	27
5.2.4.2	MI-PDDI-1: Document how to control access to debug and management interfaces	28
5.2.4.3	MI-PDDI-2: Control local software access to debug and management interfaces	28
5.2.4.4	MI-PDDI-3: Control network access to debug or management interfaces	28
5.2.5	TR-SCUD: Secure updates	28
5.2.5.1	MI-KEVD: Documentation for secure update before or during first use	28
5.2.5.2	MI-KEVA: Secure update before or during first use	28
5.2.5.3	MI-SCUE: Security updates provided by the operational environment	29
5.2.5.4	MI-SUVI: Update authenticity and integrity verification	29
5.2.5.5	MI-SUDP: Anti-rollback protection	29
5.2.5.6	MI-SUAR: Authorised rollback	29
5.2.6	TR-AUTH: Authentication and access control	30
5.2.6.1	MI-RAUT: Authenticate the remote data processing solution and validate its interactions at the RDPS boundary	30
5.2.6.2	MI-AUTH-1: Require user authentication on interfaces providing access to the operating system	30
5.2.6.3	MI-AUTH-2: Require privilege or authorisation on interfaces providing access to the operating system	30
5.2.6.4	MI-LCKT: Authentication failure protection	30
5.2.6.5	MI-CRED: Protect stored critical security parameters and enforce credential strength	30
5.2.6.6	MI-ACCS: Access control enforcement on operating system resources and functions	31
5.2.6.7	MI-PRIV: Privilege separation and restriction	31
5.2.6.8	MI-SESS: Interactive session lifecycle controls	31
5.2.6.9	MI-ACSD: Access control for stored data	31
5.2.7	TR-CDST: Confidentiality of data stored on the product	31
5.2.7.1	MI-ENST: Cryptographic encryption of stored data	31
5.2.8	TR-CDTX: Confidentiality of data transmitted by the product	31
5.2.8.1	MI-CDTX: Protect confidentiality of user data transmitted by the product	31
5.2.8.2	MI-RRDC: Document residual risk to confidentiality of data transmitted	32
5.2.8.3	MI-ENTX: Cryptographic encryption of transmitted data	32
5.2.9	TR-CRYP: Encryption	32
5.2.9.1	MI-CRYP: Conformance to Annex K	32
5.2.10	TR-IDST: Integrity of data stored on the product	32
5.2.10.1	MI-DCST: Detect corruption of stored data	32
5.2.10.2	MI-INTS: Cryptographic integrity protection of stored data	32
5.2.11	TR-IDTX: Integrity of data transmitted by the product	33
5.2.11.1	MI-INTT: Cryptographic integrity protection of transmitted data	33
5.2.12	TR-DMIN: Data Minimisation	33
5.2.12.1	MI-DJST: Document and justify processed data	33
5.2.13	TR-AVAI: Availability	33
5.2.13.1	MI-AVNT: Availability of network functions	33
5.2.13.2	MI-CSFR: Detection and recovery from critical service failures	33
5.2.13.3	MI-RLIM: Resource usage limits and exhaustion fallback	34
5.2.13.4	MI-PRIO: Workload prioritisation	34
5.2.13.5	MI-RRDS: Document residual risk of denial of service	34
5.2.13.6	MI-RTDL: Real-time deadline preservation	34
5.2.13.7	MI-RTRY: Retry and degraded behaviour on unavailability of the remote data processing solution	34
5.2.14	TR-ISOL: Isolation	35
5.2.14.1	MI-ISO-1: Access control across security boundaries	35
5.2.14.2	MI-ISO-2: Process isolation	35

5.2.14.3	MI-ISO-3: Isolation between the processes of different users.....	35
5.2.14.4	MI-ISO-4: Isolation between the data of different users	35
5.2.14.5	MI-ISO-5: Privilege model.....	35
5.2.14.6	MI-ISO-6: Side-channel isolation.....	36
5.2.14.7	MI-ISO-7: Binary hardening	36
5.2.15	TR-LOGG: Logging and monitoring	36
5.2.15.1	MI-LOGG: Logging	36
5.2.16	TR-SCDL: Secure deletion	37
5.2.16.1	MI-SDEL: Secure deletion	37
5.2.16.2	MI-RRSD: Document residual risk to secure deletion	37
5.2.17	TR-SDTR: Secure data read and transfer.....	37
5.2.17.1	MI-SDRF: Secure data read from product.....	37
5.2.17.2	MI-SDTR: Document secure data transfer to another product or system.....	37
5.3	Security profiles.....	37
5.3.1	General.....	37
5.3.2	SP-REST baseline mitigations	38
5.3.3	SP-GEN baseline mitigations.....	38
5.3.4	Conditioned mitigations	39
5.3.4.0	General	39
5.3.4.1	C-NET: Public network access	39
5.3.4.2	C-NETR: Restricted network access	40
5.3.4.3	C-MOD: User-modifiable software, firmware, or hardware	40
5.3.4.4	C-APPS: Third-party application installation.....	40
5.3.4.5	C-LOSS: Loss or theft of a portable device.....	40
5.3.4.6	C-MULTI: Multiple user accounts	40
5.3.4.7	C-UNTR: Untrusted concurrent users	41
5.3.4.8	C-DATA: Sensitive or personal data	41
5.3.4.9	C-FUNC: Sensitive functions.....	41
5.3.4.10	C-RDPS: Remote data-processing dependency.....	42
5.3.4.11	C-PHYS: Physical exposure to untrusted persons.....	42
5.3.4.12	C-SELFADM: Self-administration.....	42
6	Assessment criteria for compliance with technical requirements	42
6.1	Introduction to the assessment and compliance criteria.....	42
6.2	TR-NKEV: No known exploitable vulnerabilities.....	44
6.2.1	[AC-KEVM] Assessment criteria: Documentation of mitigation of known exploitable vulnerabilities	44
6.2.2	[AC-KEVT] Assessment criteria: Testing for known exploitable vulnerabilities	45
6.3	TR-MINI: Minimise impact on other devices and services	45
6.3.1	[AC-RRIS] Assessment criteria: Document residual risk to other devices and services.....	45
6.3.2	[AC-MNET] Assessment criteria: Minimise negative impact of network transmission	46
6.4	TR-SDEF: Secure by default configuration.....	47
6.4.1	[AC-ADEF] Assessment criteria: Authorisation required by default to access security-relevant assets....	47
6.4.2	[AC-PDDI-1] Assessment criteria: Document how to control access to debug and management interfaces	48
6.4.3	[AC-PDDI-2] Assessment criteria: Control local software access to debug and management interfaces	48
6.4.4	[AC-PDDI-3] Assessment criteria: Control network access to debug or management interfaces.....	49
6.5	TR-SCUD: Secure updates	50
6.5.1	[AC-KEVD] Assessment criteria: Documentation for secure update before or during first use	50
6.5.2	[AC-KEVA] Assessment criteria: Secure update before or during first use	50
6.5.3	[AC-SCUE] Assessment criteria: Security updates provided by the operational environment.....	51
6.5.4	[AC-SUVI] Assessment criteria: Update authenticity and integrity verification	52
6.5.5	[AC-SUDP] Assessment criteria: Anti-rollback protection	53
6.5.6	[AC-SUAR] Assessment criteria: Authorised rollback.....	53
6.6	TR-AUTH: Authentication and access control	54
6.6.1	[AC-RAUT] Assessment criteria: Authenticate the remote data processing solution and validate its interactions at the RDPS boundary	54
6.6.2	[AC-AUTH-1] Assessment criteria: Require user authentication on interfaces providing access to the operating system.....	55
6.6.3	[AC-AUTH-2] Assessment criteria: Require privilege or authorisation on interfaces providing access to the operating system.....	56
6.6.4	[AC-LCKT] Assessment criteria: Authentication failure protection.....	57

6.6.5	[AC-CRED] Assessment criteria: Protect stored critical security parameters and enforce credential strength.....	57
6.6.6	[AC-ACCS] Assessment criteria: Access control enforcement on operating system resources and functions.....	58
6.6.7	[AC-PRIV] Assessment criteria: Privilege separation and restriction.....	59
6.6.8	[AC-SESS] Assessment criteria: Interactive session lifecycle controls	60
6.6.9	[AC-ACSD] Assessment criteria: Access control for stored data	61
6.7	TR-CDST: Confidentiality of data stored on the product.....	62
6.7.1	[AC-ENST] Assessment criteria: Cryptographic encryption of stored data.....	62
6.8	TR-CDTX: Confidentiality of data transmitted by the product	63
6.8.1	[AC-CDTX] Assessment criteria: Protect confidentiality of user data transmitted by the product.....	63
6.8.2	[AC-RRDC] Assessment criteria: Document residual risk to confidentiality of data transmitted	64
6.8.3	[AC-ENTX] Assessment criteria: Cryptographic encryption of transmitted data	64
6.9	TR-CRYP: Encryption.....	65
6.9.1	[AC-CRYP] Assessment criteria: Conformance to Annex K.....	65
6.10	TR-IDST: Integrity of data stored on the product.....	66
6.10.1	[AC-DCST] Assessment criteria: Detect corruption of stored data	66
6.10.2	[AC-INTS] Assessment criteria: Cryptographic integrity protection of stored data	66
6.11	TR-IDTX: Integrity of data transmitted by the product.....	67
6.11.1	[AC-INTT] Assessment criteria: Cryptographic integrity protection of transmitted data	67
6.12	TR-DMIN: Data Minimisation	68
6.12.1	[AC-DJST] Assessment criteria: Document and justify processed data	68
6.13	TR-AVAI: Availability.....	69
6.13.1	[AC-AVNT] Assessment criteria: Availability of network functions.....	69
6.13.2	[AC-CSFR] Assessment criteria: Detection and recovery from critical service failures	70
6.13.3	[AC-RLIM] Assessment criteria: Resource usage limits and exhaustion fallback.....	70
6.13.4	[AC-PRIO] Assessment criteria: Workload prioritisation.....	71
6.13.5	[AC-RRDS] Assessment criteria: Document residual risk of denial of service	72
6.13.6	[AC-RTDL] Assessment criteria: Real-time deadline preservation	73
6.13.7	[AC-RTRY] Assessment criteria: Retry and degraded behaviour on unavailability of the remote data processing solution.....	73
6.14	TR-ISOL: Isolation.....	74
6.14.1	[AC-ISO-1] Assessment criteria: Access control across security boundaries	74
6.14.2	[AC-ISO-2] Assessment criteria: Process isolation.....	75
6.14.3	[AC-ISO-3] Assessment criteria: Isolation between the processes of different users	76
6.14.4	[AC-ISO-4] Assessment criteria: Isolation between the data of different users.....	77
6.14.5	[AC-ISO-5] Assessment criteria: Privilege model.....	77
6.14.6	[AC-ISO-6] Assessment criteria: Side-channel isolation.....	78
6.14.7	[AC-ISO-7] Assessment criteria: Binary hardening.....	80
6.15	TR-LOGG: Logging and monitoring.....	81
6.15.1	[AC-LOGG] Assessment criteria: Logging.....	81
6.16	TR-SCDL: Secure deletion	82
6.16.1	[AC-SDEL] Assessment criteria: Secure deletion.....	82
6.16.2	[AC-RRSD] Assessment criteria: Document residual risk to secure deletion.....	83
6.17	TR-SDTR: Secure data read and transfer	83
6.17.1	[AC-SDRF] Assessment criteria: Secure data read from product	83
6.17.2	[AC-SDTR] Assessment criteria: Document secure data transfer to another product or system	84

Annex A (informative):	Relationship between the present document and the essential cybersecurity requirements of Regulation (EU) 2024/2847	86
-------------------------------	--	-----------

Annex B (informative):	Security analysis.....	88
-------------------------------	-------------------------------	-----------

B.0	General	88
B.1	Assets	88
B.1.1	Data assets	88
B.1.2	Software assets.....	88
B.1.3	Hardware-interfacing assets.....	88
B.1.4	Network assets	89
B.1.5	Identity and access assets.....	89
B.1.6	Product functions.....	89
B.1.7	Impact of asset compromise.....	89

B.2	Risk factors.....	90
B.2.1	General comments regarding risk factors	90
B.2.2	RF-NUSR: Number of User Accounts	90
B.2.3	RF-CUSR: User Account Concurrency	90
B.2.4	RF-PPII: Potential for Collection of Personally Identifiable Information	91
B.2.5	RF-SNDS: Sensitivity of Data Stored.....	91
B.2.6	RF-SNDT: Sensitivity of Data Transmitted.....	91
B.2.7	RF-SENF: Sensitivity of Functions	91
B.2.8	RF-PHYS: Physical Access by Threat Actors to the Device	91
B.2.9	RF-UEIN: Processing of Untrusted External Inputs	91
B.2.10	RF-LOSS: Probability of Loss of the Device	92
B.2.11	RF-HWMD: Hardware Modifiability by End Users.....	92
B.2.12	RF-SWMD: Software Modifiability by End Users.....	92
B.2.13	RF-DVCS: Untrusted Peripheral Devices.....	92
B.2.14	RF-TNET: Access to a Public Network.....	92
B.2.15	RF-FNET: Accessed From Untrusted Networks Including a Public Network	93
B.2.16	RF-CONF: Configurability	93
B.2.17	RF-ADMN: Administration.....	93
B.2.18	RF-SUPP: Support and Foreseeable Updates	93
B.2.19	RF-RDPS: Remote data processing dependency	93
B.3	Assumptions.....	94
B.3.0	General.....	94
B.3.1	AS-PA: Proper administrator	94
B.4	Security analysis.....	94
B.4.1	Methodology.....	94
B.4.2	TH-UEVU: Unknown exploitable vulnerabilities	94
B.4.3	TH-KEVU: Known exploitable vulnerabilities	95
B.4.4	TH-SUPC: Compromise of the secure update mechanism	95
B.4.5	TH-UAPP: Unauthorised access to product assets via unprotected physical interfaces in default configuration.....	96
B.4.6	TH-UAPS: Unauthorised access to product assets via unprotected local software access in default configuration.....	97
B.4.7	TH-UAPN: Unauthorised access to product assets via unprotected network interfaces in default configuration.....	97
B.4.8	TH-UADT: Unauthorised access to confidential data transmitted	98
B.4.9	TH-UADX: Unauthorised access to data during transfer to another product	98
B.4.10	TH-PDOS: Denial of service attack on product functions via user or network access	99
B.4.11	TH-DDOS: Denial of service attack on other products via exploitation of vulnerabilities or unauthorised use of product functions.....	100
B.4.12	TH-MQSE: Masquerading authorised server	100
B.4.13	TH-XUSR: Unauthorised access, resource exhaustion, or privilege escalation between concurrent users ...	101
B.4.14	TH-LEAK: Data leak through side channels	101
B.4.15	TH-RDPS: Compromise of the remote data processing solution boundary.....	102
B.4.16	TH-SUPP: Supply chain compromise.....	102
B.4.17	TH-HARD: Compromise via hardware-level or platform trust components.....	103
B.5	Mapping of use cases to risk factors	103
B.5.1	General.....	103
B.5.2	Baseline risk-factor levels of the basic use cases.....	103
B.5.3	Condition increments.....	104
B.5.4	Deriving the risk profile of a product.....	104
B.6	Security profiles	104
B.6.1	General.....	104
B.6.2	Mapping of security profiles to risk factors	105
B.6.3	Determining the applicable mitigations	105
B.6.4	Relationship to the threat analysis	106
Annexes C to J: Void.....		107

Annex K (normative):	Generic requirements and assessment criteria for the use of state of the art cryptography.....	108
K.0	General	108
K.1	Cryptography.....	108
K.1.1	Requirement.....	108
K.1.2	Assessment of product cryptographic configuration.....	109
K.1.2.0	General	109
K.1.2.1	Assessment of ACM-listed cryptographic mechanisms	109
K.1.2.1.1	Assessment objective.....	109
K.1.2.1.2	Assessment preparation	109
K.1.2.1.3	Assessment activities	110
K.1.2.1.4	Assessment evidence	110
K.1.2.1.5	Assessment verdict	110
K.1.2.2	Assessment of ACM-extended cryptographic mechanisms	110
K.1.2.2.1	Assessment objective.....	110
K.1.2.2.2	Assessment preparation	110
K.1.2.2.3	Assessment activities	110
K.1.2.2.4	Assessment evidence	111
K.1.2.2.5	Assessment verdict	111
K.1.2.3	Assessment of interoperability-based cryptographic mechanisms	111
K.1.2.3.1	Assessment objective.....	111
K.1.2.3.2	Assessment preparation	111
K.1.2.3.3	Assessment activities	112
K.1.2.3.4	Assessment evidence	112
K.1.2.3.5	Assessment verdict	112
K.2	Crypto agility	113
K.2.1	Requirement.....	113
K.2.2	Assessment of crypto-agility.....	113
K.2.2.1	Assessment objective	113
K.2.2.2	Assessment preparation.....	114
K.2.2.3	Assessment activities.....	114
K.2.2.4	Assessment evidence.....	114
K.2.2.5	Assessment verdict.....	114
K.3	ACM-extended cryptographic mechanisms	115
K.3.1	Requirement.....	115
K.3.2	List of ACM-extended cryptographic mechanisms	115
K.3.3	Assessment	117
K.4	Interoperability-based cryptographic mechanisms.....	117
K.4.1	Requirement.....	117
K.4.2	List of interoperability-based cryptographic mechanisms	117
K.4.3	Assessment	119
Annex L (informative):	Change history	120
History		121

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)) may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

BLUETOOTH® is a trademark registered and owned by Bluetooth SIG, Inc.

Foreword

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Security (CYBER), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

The present document has been prepared under the Commission's standardisation request C(2025) 618 final [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (CRA) [i.1].

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Proposed national transposition dates	
Date of latest announcement of this EN (doa):	3 months after ETSI publication
Date of latest publication of new National Standard or endorsement of this EN (dop/e):	6 months after doa
Date of withdrawal of any conflicting National Standard (dow):	18 months after doa

Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

Introduction

The present document defines cybersecurity requirements for operating systems. These products are identified in Annex III, Class I, point 11 of Regulation (EU) 2024/2847 [i.1], the Cyber Resilience Act, referred to as "CRA".

The present document supports compliance with the CRA [i.1] by addressing the essential cybersecurity requirements defined in Annex I, Part I of the CRA [i.1], and provides a structured approach to identify the applicable cybersecurity requirements for the operating systems in scope, following a risk-based approach. The security measures and controls are thereby proportionate to the intended purpose, reasonably foreseeable use, deployment context, and threat exposure of the product. The present document is intended for manufacturers of operating systems and for the bodies that assess their conformity.

Clause 4 describes the product architecture and intended purpose in their context, and defines the use cases used to characterise the operating systems in scope. A product corresponds to exactly one basic use case, namely a restricted operating system (UC-REST) or a general-purpose computing platform (UC-GEN), together with any conditions that hold for it. The basic use case and the conditions reflect the reasonably foreseeable use of the product and serve as the basis for identifying the relevant cybersecurity risks. Clause 4.8 identifies dependencies on remote data-processing solutions.

Clause 5 specifies the technical cybersecurity requirements for the product. Each requirement is grouped under a technical requirement (TR-XXX) and is expressed as one or more mitigations (MI-XXX). Clause 5.3 defines the two security profiles, SP-REST and SP-GEN, one for each basic use case; a product is assigned the security profile of its basic use case. The mitigations that apply to a given product are the baseline mitigations of its security profile together with the mitigations carried by each condition that holds for the product.

Clause 6 defines the conformity assessment activities for each mitigation in clause 5.

Annex A maps the technical requirements of the present document to the essential cybersecurity requirements of the CRA.

Annex B describes the risk identification and assessment methodology used to derive the security profiles in clause 5.3 and the conditions in clause 4.7. It records the baseline risk-factor levels of the basic use cases and the risk-factor increments contributed by each condition, from which the applicable mitigations are determined.

Annex K specifies the requirement for the use of state of the art cryptography, the assessment of the product's cryptographic configuration, and the crypto-agility requirement. It classifies cryptographic mechanisms as state of the art and lists the cryptographic mechanisms recognised by the present document in addition to the ACM catalogue.

1 Scope

1.1 General

The present document specifies technical requirements and corresponding assessment criteria for operating systems related to cybersecurity. The products with digital elements in scope, thereafter "the operating system":

- are specified within the "technical description" of the "category of product" number 11 of Annex III, Class I by the Commission Implementing Regulation (EU) 2025/2392 [i.2] as:
"software products with digital elements that provide an abstract interface of the underlying hardware and control the execution of software, and that may provide services such as computing resource management and configuration, scheduling, input-output control, managing data, and providing an interface through which applications interact with system resources and peripherals. This category includes but is not limited to real-time operating systems, general-purpose and special-purpose operating systems".
- are only covered within the product context described in clause 4.

The present document covers those products to demonstrate compliance with essential cybersecurity requirements in the Regulation (EU) 2024/2847 [i.1] Annex I Part I under the conditions identified in Annex A.

The use of harmonised standards is voluntary.

1.2 Products in scope

1.2.1 General

Products in scope are products whose core function and intended or reasonably foreseeable use or misuse is as an operating system. Operating systems are defined in point 11 of Annex III, Class I of Regulation (EU) 2024/2847 [i.1] and described in Commission Implementing Regulation (EU) 2025/2392 [i.2] as "software products with digital elements that provide an abstract interface of the underlying hardware and control the execution of software, and that may provide services such as computing resource management and configuration, scheduling, input-output control, managing data, and providing an interface through which applications interact with system resources and peripherals. This category includes but is not limited to real-time operating systems, general-purpose and special-purpose operating systems".

The present document applies equally to real-time, general-purpose, and special-purpose operating systems. Where a specific requirement depends on hardware or software features that not all operating system architectures provide, the applicability of that requirement is stated in the applicability field of the corresponding mitigation in clause 5.

The underlying hardware may be virtualised to some degree, as when an operating system is running on a hypervisor.

This category includes but is not limited to:

- General purpose operating systems
 - Personal computing operating systems
 - Mobile operating systems
 - Server operating systems
- Special purpose operating systems
 - Real-time operating systems
 - Embedded operating systems
 - Single-purpose operating systems

Many products contain multiple operating systems which can affect the security functions of other operating system(s) in the product. For example, a Baseboard Management Controller (BMC) contains an operating system that can manage most or all of the hardware managed by the main system operating system. Radiofrequency transmission devices often have an embedded real-time operating system and the ability to read or write to system memory or trigger interrupts.

Where a product contains multiple operating systems, the present document applies to each operating system in scope separately. From the perspective of the operating system under assessment, any other operating system in the product is part of its operational environment.

Some of the operating systems may not always be readily available as separate products and are included as components of another product. Where there may be other specifications that target that product category, it may be more relevant to review the operating system as part of that larger system rather than independently via the present document.

1.2.2 Components of operating systems that are in scope

The present document applies to the operating system as a whole. The following non-exhaustive list identifies common component types where the cybersecurity requirements of the present document most often have effect. The list is informative; all components of the operating system are covered by the requirements.

The following non-exhaustive list of types of components are common to many operating systems and, when present, are considered security-relevant:

- **Kernel:** The central component responsible for managing hardware resources and enforcing access controls.
- **Device Drivers:** Software components supplied with the operating system that interact directly with hardware devices.
- **Cybersecurity Libraries:** Libraries used to provide cybersecurity services, such as encryption, authentication, and authorisation.
- **Authentication Services:** Authentication mechanisms required for operating system functionality.
- **Privileged Processes:** Operating system processes running with elevated privileges or access to sensitive resources.
- **Software Update Mechanisms:** Systems responsible for installing and updating software components supplied with the operating system.
- **Logging and Monitoring:** Functions performed by the operating system that record cybersecurity-relevant events or monitor system behaviour.
- **Configuration Management:** Management of the configuration of cybersecurity-relevant operating system settings, including provisioning of a secure-by-default configuration.

A given component may fall under more than one category. The categories are illustrative and not mutually exclusive.

1.3 Products covered by other CRA harmonised standards

Some product categories that provide functionality overlapping with an operating system are covered by their own CRA harmonised standard. Where such a standard exists for a product category, that standard applies to it. These categories include:

- Hypervisors and container runtime systems that support virtualised execution of operating systems (Annex III, Class II, point 1 of Regulation (EU) 2024/2847 [i.1]).
- Boot managers (Annex III, Class I, point 8 of Regulation (EU) 2024/2847 [i.1]).

For products that embed or interact with an operating system while having a different core functionality, manufacturers may refer to the present document as one part of demonstrating compliance for the operating system component.

2 References

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or nonspecific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

- [1] [ENISA Report 1747792503](#) (version 2 - April 2025): "European Cybersecurity Certification Group Sub-group on Cryptography Agreed Cryptographic Mechanisms".
- [2] [BSI TR-02102-1](#) (Version 2026-01, 23 January 2026): "Cryptographic Mechanisms: Recommendations and Key Lengths".
- [3] [NIST SP 800-108 Rev. 1 \(August 2022\)](#): "Recommendation for Key Derivation Using Pseudorandom Functions".
- [4] [NIST SP 800-131A Rev. 2 \(March 2019\)](#): "Transitioning the Use of Cryptographic Algorithms and Key Lengths".
- [5] [Canadian Centre for Cyber Security ITSP.40.062](#): "Guidance on Securely Configuring Network Protocols".
- [6] [IRTF RFC 7748 \(January 2016\)](#): "Elliptic Curves for Security".
- [7] [IRTF RFC 8032 \(January 2017\)](#): "Edwards-Curve Digital Signature Algorithm (EdDSA)".
- [8] [IETF RFC 8410 \(August 2018\)](#): "Algorithm Identifiers for Ed25519, Ed448, X25519, and X448 for Use in the Internet X.509 Public Key Infrastructure".
- [9] [IRTF RFC 8439 \(June 2018\)](#): "ChaCha20 and Poly1305 for IETF Protocols".
- [10] [IRTF RFC 9106 \(September 2021\)](#): "Argon2 Memory-Hard Function for Password Hashing and Proof-of-Work Applications".
- [11] [IETF RFC 7914 \(August 2016\)](#): "The scrypt Password-Based Key Derivation Function".
- [12] [IETF RFC 1321 \(April 1992\)](#): "The MD5 Message-Digest Algorithm".
- [13] [IETF RFC 3174 \(September 2001\)](#): "US Secure Hash Algorithm 1 (SHA1)".
- [14] [NIST SP 800-132 \(December 2010\)](#): "Recommendation for Password-Based Key Derivation, Part 1: Storage Applications".
- [15] [IETF RFC 2268 \(March 1998\)](#): "A Description of the RC2(r) Encryption Algorithm".
- [16] [IETF RFC 7465 \(February 2015\)](#): "Prohibiting RC4 Cipher Suites".
- [17] [IETF RFC 6229 \(May 2011\)](#): "Test Vectors for the Stream Cipher RC4".
- [18] [FIPS PUB 186-5 \(February 2023\)](#): "Digital Signature Standard (DSS)".
- [19] SEC2 SEC 2: "[Recommended Elliptic Curve Domain Parameters](#)", [Version 2.0, January 2010](#).
- [20] [NIST SP 800-135 Rev. 1 \(December 2011\)](#): "Recommendation for Existing Application-Specific Key Derivation Functions".
- [21] [FIPS PUB 180-4 \(August 2015\)](#): "Secure Hash Standard (SHS)".
- [22] [FIPS PUB 198-1 \(July 2008\)](#): "The Keyed-Hash Message Authentication Code (HMAC)".

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or nonspecific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's understanding but are not required for conformance to the present document.

- [i.1] [Regulation \(EU\) 2024/2847](#) of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).
 - [i.2] [Commission Implementing Regulation \(EU\) 2025/2392](#) of 28 November 2025 on the technical description of the categories of important and critical products with digital elements pursuant to Regulation (EU) 2024/2847 of the European Parliament and of the Council.
 - [i.3] [Standardisation request M/606 - C\(2025\)618](#): "Commission Implementing decision of 3.2.2025 on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)".
 - [i.4] prEN 40000-1-1: "Cybersecurity requirements for products with digital elements - Vocabulary", (produced by CEN/CENELEC).
- NOTE: Version and date to be added upon its publication by CEN/CENELEC.
- [i.5] ETSI EN 303 645: "CYBER; Cyber Security for Consumer Internet of Things: Baseline Requirements".
 - [i.6] EN 18031 series: "Common security requirements for radio equipment" (produced by CEN/CENELEC).
 - [i.7] CEN/CLC JTC13: "Cybersecurity and Data Protection".
 - [i.8] ISO/IEC 15408: "Information security, cybersecurity and privacy protection - Evaluation criteria for IT security".
 - [i.9] BSI CC-PP-0067: "Operating System Protection Profile".
 - [i.10] ISO 31000: "Risk management - Guidelines".
 - [i.11] IETF RFC 4987: "TCP SYN Flooding Attacks and Common Mitigations".
 - [i.12] ANSSI: "Recommendations for the secure configuration of a GNU/Linux system", Version 2.0.
 - [i.13] FIPS PUB 46-3 (October 1999): "Data Encryption Standard (DES)".
 - [i.14] ANSSI, Référentiel Général de Sécurité (RGS): ["Guide des mécanismes cryptographiques – Règles et recommandations concernant le choix et le dimensionnement des mécanismes cryptographiques"](#) (Cryptographic Mechanisms – Rules and Recommendations regarding the Choice and Sizing of Cryptographic Mechanisms), section B.1, version 2.04, 01/01/2020.

3 Definition of terms, symbols and abbreviations

3.1 Terms

For the purposes of the present document, the terms given in prEN 40000-1-1 [i.4] and the following apply:

NOTE: This clause provides terms and definitions based on CEN/CLC JTC13 WG09's [i.7] work on terms and definitions, terms and definitions provided by ETSI EN 303 645 [i.5] and by EN 18031 [i.6] series, and informed by terms used in the Common Criteria [i.8] and the NIAP Operating System Protection Plan [i.9] guide.

administrator: entity that is responsible for management activities, including setting policies that are applied by the enterprise on the operating system

NOTE: This administrator could be acting remotely through a management server, from which the system receives configuration policies. An administrator can enforce settings on the system which cannot be overridden by non-administrator users.

application: software that runs on a platform and performs tasks on behalf of the user or owner of the platform, as well as its supporting documentation

Application Programming Interface (API): specification of routines, data structures, object classes, and variables that allows an application to make use of services provided by another software component, such as a library

NOTE: APIs are often provided for a set of libraries included with the platform.

attack surface: user interfaces, target protocol interfaces and reachable data paths that can be attacked from inside or outside the system

command shell: text-based interface allowing execution of system programs

Common Criteria (CC): criteria for the evaluation of information technology security specified in ISO/IEC 15408 [i.8]

Common Weakness Enumeration (CWE): community-developed list of software and hardware weaknesses that can become vulnerabilities

compensating control: alternative control that meets the intent and rigour of a prescribed control when the prescribed control cannot be implemented for legitimate technical or business reasons

core function: function that is fundamental to the operation of the operating system, such as process scheduling, memory management, and input-output control, and whose loss of availability constitutes a denial-of-service condition

credential: data that establishes the identity of a user, e.g. a cryptographic key or password

cryptographic mechanism: security-related procedure using cryptography

NOTE 1: The term cryptographic mechanism is used as an umbrella term covering the categories used in the Agreed Cryptographic Mechanisms catalogue (ACM) [1], including cryptographic algorithms, primitives, schemes, protocols, protocol profiles, cipher suites, modes of operation, constructions and parameter sets.

NOTE 2: A cryptographic mechanism can be specified at different levels of abstraction. For example, AES is a cryptographic primitive, AES-GCM is a mode of operation and authenticated encryption construction, TLS 1.3 is a protocol, a TLS 1.3 restricted cipher-suite profile is a protocol profile, and TLS_AES_128_GCM_SHA256 is a cipher suite.

cryptographic property: property provided or supported by a cryptographic mechanism

NOTE: Cryptographic properties include, for example, confidentiality, integrity, authenticity, entity authentication, message authentication, key establishment, key confirmation, replay protection, collision resistance, preimage resistance, signature unforgeability, non-repudiation, and forward secrecy. Where relevant, a cryptographic property can be expressed using a formal cryptographic notion, for example IND-CPA, IND-CCA2, EUF-CMA or SUF-CMA.

data execution prevention: anti-exploitation feature of modern operating systems executing on modern computer hardware, which enforces a non-execute permission on pages of memory that are not code

NOTE: This prevents pages of memory from containing both data and instructions, which makes it more difficult for an attacker to introduce and execute code.

elevated privilege: level of access that allows accessing or changing security-relevant configuration, data, or functions on a system

essential function: function whose availability is necessary for the product to fulfil its intended purpose

general purpose operating system: class of operating system designed to support a wide variety of workloads consisting of concurrent applications or services

NOTE: Typical characteristics of this category include support for third-party applications, support for multiple users, and security separation between users and their respective resources. General Purpose Operating Systems lack the operational constraints which define Special Purpose Operating Systems, including Real Time Operating System (RTOS), that are typically used in routers, switches, and embedded devices.

Input/Output (I/O): process or function for passing data to or from a given process over a specific interface

NOTE: Such I/O interfaces include, but are not limited to, serial ports, network ports, long-term storage devices including hard drives and flash drives, as well as human-interface ports such as display and audio devices.

Operating System (OS): Software products with digital elements that provide an abstract interface of the underlying hardware and control the execution of software, and that may provide services such as computing resource management and configuration, scheduling, input-output control, managing data, and providing an interface through which applications interact with system resources and peripherals. This category includes but is not limited to real-time operating systems, general-purpose and special-purpose operating systems.

NOTE: This definition is the technical description of the category of products with digital elements set out in Annex III, Class I, point 11 of Regulation (EU) 2024/2847 [i.1], as given in Commission Implementing Regulation (EU) 2025/2392 [i.2].

Personally Identifiable Information (PII): any information about an individual maintained by an agency, including but not limited to, education, financial transactions, medical history, and criminal or employment history and information which can be used to distinguish or trace an individual's identity

principle of least privilege: design principle requiring that users, processes, and interfaces are granted only the minimum level of permission necessary to perform their legitimate functions, and nothing more

process isolation: techniques to prevent processes from accessing or changing each other's state

Remote Data Processing Solution (RDPS): data processing at a distance for which the software is designed and developed by the manufacturer, or under the responsibility of the manufacturer, and the absence of which would prevent the product from performing one of its functions

NOTE: As defined in Regulation (EU) 2024/2847 [i.1], Article 3, point 2.

residual risk: risk remaining after risk treatment has been applied [i.10]

security incident: event that compromises the confidentiality, integrity, or availability of the product, of the data it stores, processes, or transmits, or of the services or functions it provides

security profile: set of baseline mitigations associated with a basic use case and assigned to a product on the basis of that use case

NOTE: A product implements the mitigations of its security profile together with the conditioned mitigations for each condition it meets, as specified in clause [5.3](#).

sensitive data: sensitive data may include all user or enterprise data or may be specific application data such as PII, emails, messaging, documents, calendar items, contacts, credentials, and keys

system call interface: specification for the API between the application layer and the kernel or system layer

threat actor: entity that can adversely affect the system through malicious or unauthorised activities

user: entity that is subject to configuration policies applied to the operating system by administrators

NOTE: On some systems under certain configurations, a normal user can temporarily elevate privileges to that of an administrator. At that time, such a user should be considered an administrator.

user account: identity created in an operating system with associated access controls and privileges

NOTE: Users may have multiple user accounts and user accounts may have multiple users.

user data: data entered or modified by the user, or generated by the user's use of the product, as opposed to data delivered with the product

NOTE: User data includes, for example, files stored by the user and credentials provisioned to the product, such as private keys, certificates, and pre-shared keys.

3.2 Symbols

Void.

3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

ACM	Agreed Cryptographic Mechanisms
AEAD	Authenticated Encryption with Associated Data
API	Application Programming Interface
BMC	Baseboard Management Controller
CA	Certification Authority
CC	Common Criteria
CCCS	Canadian Centre for Cyber Security
CMA	Chosen-Message Attack
CMAC	Cipher-based Message Authentication Code
CPA	Chosen-Plaintext Attack
CPU	Central Processing Unit
CRA	Cyber Resilience Act
CVE	Common Vulnerabilities and Exposures
CWE	Common Weakness Enumeration
DES	Data Encryption Standard
DNS	Domain Name System
DNSSEC	Domain Name System Security Extensions
ECC	Elliptic Curve Cryptography
ECDH	Elliptic Curve Diffie-Hellman
ECDSA	Elliptic Curve Digital Signature Algorithm
EdDSA	Edwards-curve Digital Signature Algorithm
EUF	Existential Unforgeability
FIPS	Federal Information Processing Standard
GPIO	General-Purpose Input/Output
GPU	Graphics Processing Unit
HKDF	HMAC-based Key Derivation Function
HMAC	Keyed-Hash Message Authentication Code
I/O	Input/Output
I2C	Inter-Integrated Circuit
IND	Indistinguishability
JTAG	Joint Test Action Group
KMAC	KECCAK Message Authentication Code
MAC	Message Authentication Code
MD5	Message Digest 5
MI	Mitigation
MPU	Memory Protection Unit
NAT	Network Address Translation
NVD	National Vulnerability Database

OE	Operational Environment
OS	Operating System
PAM	Pluggable Authentication Module
PBKDF2	Password-Based Key Derivation Function 2
PCI	Peripheral Component Interconnect
PII	Personally Identifiable Information
PKCS	Public-Key Cryptography Standards
PKI	Public Key Infrastructure
POSIX	Portable Operating System Interface
PRF	Pseudorandom Function
PUB	Publication
RC2	Rivest Cipher 2
RC4	Rivest Cipher 4
RDPS	Remote Data Processing Solution
RF	Risk Factor
RTOS	Real-Time Operating System
S/MIME	Secure/Multipurpose Internet Mail Extensions
SEC	Standards for Efficient Cryptography
SHA	Secure Hash Algorithm
SP	Security Profile
SPI	Serial Peripheral Interface
SSH	Secure Shell
SSL	Secure Sockets Layer
SUF	Strong Unforgeability
SWD	Serial Wire Debug
SYN	Synchronization
TCP	Transmission Control Protocol
TH	Threat
TLS	Transport Layer Security
TR	Technical Requirement
UC	Use Case
USB	Universal Serial Bus
VPN	Virtual Private Network
XTS	XEX-based Tweaked-codebook mode with ciphertext Stealing

4 Product context

4.1 Intended purpose and reasonably foreseeable use

The intended purpose of this product is to provide an abstract interface of the underlying hardware and control the execution of software, and potentially provide services such as computing resource management and configuration, scheduling, input-output control, managing data, and providing an interface through which applications interact with system resources and peripherals.

Its reasonably foreseeable use is to facilitate the use of computing hardware and serve as a platform for other software.

4.2 Product functions

The functions of an operating system commonly include process isolation, memory isolation, I/O abstraction, device driver management, user authentication and access control, event logging, software management, device firmware management, and secure updates.

4.3 Product architecture

4.3.1 Overview

An operating system abstracts the hardware, allocates resources, and provides services to itself and any other software on the system. It often serves as a central organising authority that controls access to system resources by various pieces of software, dividing up available resources among the applications and its own subsystems to meet implicit or explicit goals or constraints. An operating system often uses a large part of the resources of the system it runs on, but in return it simplifies the development and deployment of the overall system.

Operating system architecture varies widely and depends on many factors, including the intended use case, the underlying platform, and the design philosophy of the developers. This overview will focus on the elements of operating system architecture that have a significant impact on the security functions and risk mitigations of an operating system.

4.3.2 Operating system security functions

Operating systems can vary in many ways which significantly affect security outcomes for the product. For this reason, the present document does not attempt to define specifics of operating system architecture. Some examples of differences include:

- the proportion of operating system code executed with different privileges;
- whether application code is executed with the same privileges as the operating system;
- the method of communication between processes with different privileges;
- the degree of reliance on hardware capabilities to enforce privilege separation and process isolation.

Each of these design variations makes different tradeoffs between security, performance, and ease of implementation.

The security of an operating system relies heavily on properly controlling the instructions executed by the system processor. Instruction flow is dependent on the program instructions, any data it accesses, and any hardware that has the ability to change either data or which instructions are being executed.

EXAMPLE 1: A network interface adapter can write directly to system memory, potentially altering data values and thereby influencing the behaviour of running programs or even causing unintended code execution.

EXAMPLE 2: A USB controller can raise an interrupt which can cause the interrupt controller to force the CPU to switch to executing interrupt handling code, altering the instruction flow.

4.3.3 Privileges

A fundamental building block of most operating systems is the principle of "privilege". Privilege determines which system resources or functions a program is allowed to access. The operating system grants a specific set of privileges to itself, its subsystems, and user-level programs, ensuring that each component operates within defined boundaries to maintain system security and stability.

Generally, privileges are enforced using hardware features such as a memory management unit and processor-defined privilege levels. If the hardware does not provide these features, the operating system can use a best effort approach, such as relying on the compiler to generate code that is less likely to accidentally interfere with the functions of the operating system or other parts of the system.

4.3.4 Access control mechanisms

Operating systems may control access to resources in different ways, including but not limited to:

- Access control lists: Each resource has a list of users or processes that are allowed to access it.

- Role-based access control: Users are assigned one or more roles, and roles have permissions associated with them.
- Capabilities: Access to a resource is linked to a token which can be passed between processes.

4.3.5 Resource management

Operating systems may control resource management in different ways, including but not limited to imposing per-process limitations on processor time, memory allocation, storage usage, number of file descriptors, or number of process table entries.

Operating systems may implement limits on the number or proportion of specific resources that an application or thread may use, and may group these limits by user, process, process group, or other mechanism.

4.3.6 Scheduling

Operating systems may provide voluntary or involuntary switching between different processes, and may rely on hardware capabilities to improve or limit parallel process execution and isolation.

Some common models include:

Cooperative scheduling: Each thread runs until it voluntarily yields control of the processor to another thread. No thread is interrupted unless it explicitly yields the CPU.

Preemptive scheduling: Threads can be involuntarily suspended by the scheduler and replaced with other threads, and they may also voluntarily yield the CPU.

Operating systems may perform scheduling based on many factors, such as but not limited to:

- Time spent executing during a previous time period
- Time since the thread was first marked runnable
- Explicit priorities associated with each thread
- Type of thread (kernel or application)
- Resource limits
- Performance considerations

4.4 Operational Environment

The operational environment of an operating system is highly varied. In general it includes at least a platform (virtual or physical), and may also include applications, separately shipped device drivers, device firmware, peripherals, and many other components. Operating systems may be a standalone software product on a single processor, or it may be part of suite of software products running on multiple processors. Many systems have multiple operating systems all managing different parts of the system at the same time.

For the purposes of the use cases in clause [4.7](#), the following aspects of the operational environment are distinguished, as they determine which conditions in clause [4.7](#) hold for a product:

- the platform on which the operating system runs, whether virtual or physical;
- the network environment, namely whether the product, in foreseeable use, has unrestricted access to a public network or can be reached from one, accesses a public network only for restricted functions such as retrieving security updates, or has no access to a public network;
- the physical environment, namely whether the product is regularly exposed to untrusted persons, or is a portable device with a foreseeable likelihood of loss or theft; and
- the remote data-processing solutions on which one or more product functions depend, as described in clause [4.8](#).

4.5 Distribution of security functions

4.5.1 General

For each security requirement, a product can:

- Provide the necessary security function(s) itself
- Require security functions be provided by some other part of its context
- Provide security functions for the use of installed applications

4.5.2 Security functions provided by some other part of its context

Operating systems often rely on essential external functionality to implement their necessary security functionality.

For example, many operating systems rely on hardware secure elements and a compatible boot manager prior to the beginning of the operating system's own execution in order for the operating system to execute securely.

4.5.3 Security functions provided to other components

Operating systems often provide essential security functions to other components of the system.

For example, most individual hardware components do not have a built-in method of secure firmware update, and rely on the presence of an operating system which can update firmware securely.

4.6 Users

Users of products may interact directly with the operating system, or the operating system may be integrated into a product in such a way that the end user does not interact directly with any functionality of the operating system.

For the purposes of the use cases in clause [4.7](#), the following user categories are distinguished, as they determine which conditions in clause [4.7](#) hold for a product:

- *end user*, a person who uses the functions the product provides, without responsibility for its administration;
- *administrator*, a person responsible for configuring and maintaining the product; an administrator may be a professional administrator acting for the manufacturer or the operator, or a non-professional end user who administers their own product; and
- *trusted and untrusted users*, whether the users whose accounts the product hosts are mutually trusted; an operating system may host more than one end-user account, and may host concurrent accounts for users who are not mutually trusted.

4.7 Use cases

4.7.1 General

This clause characterises the operating systems within the scope of the present document through use cases. A product is characterised by exactly one basic use case, as specified in clause [4.7.2](#), together with any conditions, as specified in clause [4.7.3](#), that the product meets. The use cases and conditions are described only by the characteristics relevant to threat identification, namely the user categories described in clause [4.6](#) and the operational environments described in clause [4.4](#).

The basic use case is determined by a single capability of the product: whether the product is a restricted operating system or a general-purpose computing platform. It fixes the baseline risk-factor levels of the product, as given in clause [4.7.5](#). Each applicable condition raises individual risk factors and determines the applicability of the requirements in clause [5](#). The use cases are neither exhaustive nor mutually exclusive.

4.7.2 Basic use cases

4.7.2.1 UC-REST: Restricted operating system

An operating system that, as placed on the market, serves a restricted and bounded purpose and is not a general-purpose computing platform: it does not allow the end user to install and run third-party software without restriction, and it does not, by default, serve as an extensible platform for unrelated applications. Examples include operating systems integrated into appliances, sensors, and controllers. A restricted operating system begins from the lowest baseline risk-factor levels in clause [4.7.5](#); the capabilities and exposures it does have are added through the conditions of clause [4.7.3](#).

4.7.2.2 UC-GEN: General-purpose operating system

An operating system that is a general-purpose computing platform, capable of running third-party software without restriction and of serving as a platform for unrelated applications. Examples include desktop, laptop, mobile, and server operating systems, and operating systems distributed as software for deployment on many kinds of device. A general-purpose product begins from the baseline risk-factor levels of a minimal single-user general-purpose system, as given in clause [4.7.5](#). Its further capabilities and exposures (network access, multiple accounts, installation of software, storage of sensitive data, administration by non-professional users, and the others in clause [4.7.3](#)) are added through the conditions that hold for it.

Where the manufacturer cannot determine whether a condition holds for a general-purpose product, for example because the product is distributed as software whose deployment the manufacturer cannot constrain, the condition is assumed to hold. A general-purpose product for which every condition is assumed to hold is assessed against the most demanding profile.

4.7.3 Conditions

A condition is a named property of a product that is associated with one or more risk factors. Where a condition holds for a product, it has both of the following effects:

- it raises each associated risk factor to at least the level stated in Table 4.7-1; and
- it determines the applicability of the requirements in clause [5](#) that carry the condition. A requirement that carries a condition applies only where that condition holds for the product.

The conditions are defined in Table 4.7-1.

Table 4.7-1: Conditions

Condition	Risk factors raised (minimum level)	Applicability condition
C-NET	TNET-2, FNET-2, UEIN-2	This requirement applies where the product, in foreseeable use, has unrestricted access to a public network or can be reached from a public network.
C-NETR	TNET-1	This requirement applies where the product accesses a public network only for restricted functions, such as retrieving security updates, and is not otherwise reachable from a public network.
C-MOD	SWMD-1, HWMD-1, CONF-2	This requirement applies where foreseeable use permits the end user to modify security-relevant software, firmware, or hardware.
C-APPS	SWMD-2	This requirement applies where the product facilitates the installation of third-party applications of uncertain provenance, for example through an application store or sideloading.
C-LOSS	LOSS-2, PHYS-1	This requirement applies where the product is a portable device with a foreseeable likelihood of loss or theft.
C-MULTI	NUSR-2	This requirement applies where the product hosts more than one end-user account.
C-UNTR	CUSR-2	This requirement applies where the operating system hosts concurrent accounts for users who are not mutually trusted.
C-DATA	SNDS-1, SNDT-1, PPII-1	This requirement applies where foreseeable use includes the processing, transmission, or short-term caching of sensitive or personal data.
C-FUNC	SENF-2	This requirement applies where the product provides sensitive functions by default.
C-RDPS	RDPS-1	This requirement applies where one or more product functions depend on a remote data-processing solution.
C-PHYS	PHYS-2, DVCS-2	This requirement applies where foreseeable use includes regular physical exposure to untrusted persons.
C-SELFADM	ADMN-2	This requirement applies where the product is administered by its own end users rather than by professional administrators.

4.7.4 Characterising a product

To characterise a product, the manufacturer shall:

- 1) identify the basic use case that corresponds to the product, namely UC-REST for a restricted operating system or UC-GEN for a general-purpose computing platform;
- 2) identify each condition in clause 4.7.3 that the product meets; where the product is characterised as UC-GEN and the manufacturer cannot determine whether a condition holds, the condition is treated as holding;
- 3) where the basic use case and one or more conditions assign different levels to the same risk factor, apply the highest of those levels; and
- 4) document the basis for each condition in clause 4.7.3 that is determined not to hold for the product.

The resulting set of risk-factor levels is the risk profile of the product. The product implements the security profile of its basic use case, defined in clause 5.3 (SP-REST for UC-REST, SP-GEN for UC-GEN), together with every mitigation carried by a condition that holds for the product. A mitigation that carries a condition applies only where that condition holds for the product.

4.7.5 Risk-factor levels of the basic use cases

Table 4.7-2 gives the level that each basic use case assigns to each risk factor. The risk factors and their levels are defined in Annex B, where level 0 is the lowest and level 2 the highest. The conditions in clause 4.7.3 raise individual risk factors above these levels where the conditions hold.

Table 4.7-2: Risk-factor levels of the basic use cases

Risk factor	UC-REST	UC-GEN
RF-NUSR Number of user accounts	0	1
RF-CUSR User-account concurrency	0	0
RF-PPII Collection of PII	0	0
RF-SNDS Sensitivity of data stored	0	0
RF-SNDT Sensitivity of data transmitted	0	0
RF-SENF Sensitivity of functions	0	1
RF-PHYS Physical access by threat actors	0	0
RF-UEIN Untrusted external inputs	0	1
RF-LOSS Probability of loss/theft	0	0
RF-HWMD Hardware modifiability	0	0
RF-SWMD Software modifiability	0	0
RF-DVCS Untrusted peripheral devices	0	0
RF-TNET Access to a public network	0	0
RF-FNET Reached from untrusted networks	0	0
RF-CONF Configurability	0	1
RF-ADMN Administration	2	1
RF-SUPP Support and foreseeable updates	1	2
RF-RDPS Remote data-processing dependency	0	0

4.8 Remote data-processing dependencies

4.8.1 General

This clause identifies the remote data-processing solutions within the scope of the present document, the interfaces through which the product communicates with them, and the product functions that depend on them. Where a product function depends on a remote data-processing solution, condition C-RDPS as specified in clause 4.7.3 holds, and the requirements in clause 5 that carry that condition apply. The scope of the present document is limited to the boundary between the product and the remote data-processing solution, namely the product-side endpoint and the interactions exchanged across that boundary. The present document does not extend the scope of the product to the remote service environment or to the underlying third-party infrastructure.

The remote data-processing solution is assumed to be subject to the security controls applied by its operator. The trust relationship between the product and the remote data-processing solution is assumed to be established at product initialisation through credentials or trust anchors provisioned by the manufacturer or the integrator.

NOTE: The requirements of the present document apply to the product side of the boundary. Where the manufacturer also controls the solution side, the manufacturer applies equivalent protection to the interactions received and acted upon on that side.

4.8.2 Remote data-processing solutions

A remote data-processing solution within the scope of the present document is a service operated by, or under the responsibility of, the manufacturer, the absence of which would prevent the product from performing one or more of its functions.

4.8.3 RDPS interfaces

The interface between the product and a remote data-processing solution is the communication boundary between the product-side endpoint, namely the client, agent, or connector running on the product, and the solution-side endpoint exposed by the remote data-processing solution. This interface typically traverses a public network that is not under the control of the user of the product. Communication across this interface is assumed to be conducted over a secure channel and to be authenticated at the endpoint level.

4.8.4 RDPS-dependent product functions

Product functions that may depend on a remote data-processing solution can include, but are not limited to, the following:

- cloud-backed authentication and account management, where the product authenticates the end user against a manufacturer-operated service;
- telemetry, attestation, and health reporting from the product to a manufacturer-operated service; and
- device management, where the product receives configuration or security-relevant commands from a manufacturer-operated service.

5 Technical requirements for products

5.1 Notes on the structure of the Requirements

5.1.0 General

The technical cybersecurity requirements in clause 5.2 are organised as a set of technical requirements, each identified as TR-XXX. A technical requirement groups the mitigations, each identified as MI-XXX, that address one security objective for the product, and is satisfied by implementing them. A mitigation is a specific, verifiable technical means of meeting that objective, and states the assessment objective against which it is verified. Each mitigation is stated together with the assessment activity that verifies it (clause 6) and, where it relies on a product feature that not all operating system architectures provide, an applicability field that limits it to products with that feature.

A product does not necessarily implement every mitigation. The mitigations that a given product shall implement are those of its security profile, together with those carried by the conditions the product meets, as specified in clause 5.3. The security profiles and conditions are derived from the risk analysis in Annex B, so that the mitigations required of a product are proportionate to its risk.

5.1.1 Necessity of Requirements

Not all requirements are necessary for all products. The set of mitigations necessary for a given product is determined by its security profile and the conditions it meets, as specified in clause 5.3, and derived from the risk analysis in Annex B. In addition, a mitigation that carries an applicability field, stated with the mitigation, applies only where the product has the feature that the field identifies.

5.1.2 Types of Technical Requirements

All technical requirements in the present document specify properties of the product or obligations of the manufacturer that are verifiable. Verification is performed through the assessment activities defined in clause 6, each corresponding to a mitigation in clause 5.2.

Where a product property can be verified by testing the product directly, the assessment activity is a test procedure with a measurable verdict.

Where a product property cannot be verified by testing the product directly, the assessment activity is a documentation review. In this case the manufacturer shall provide supporting documentation as conformity assessment evidence. The documentation does not replace the product property. It demonstrates that the property holds.

NOTE: Simple process statements (e.g. a statement that something has been done, without supporting evidence) are not acceptable as conformity assessment evidence.

5.1.3 Assumptions Regarding Requirements

5.1.3.1 Testability

Manufacturers are already required to provide the ability to enable testing and collect output on the product as placed on the market, and will supply instructions for enabling and collecting test data.

5.1.3.2 Mitigations

Mitigations are the technical means by which a technical requirement is satisfied. Each mitigation's applicability to a given product is determined by the risk factors and security profile mappings in clause 5.3 and Annex B.

Not all mitigations are necessary for all products. See clause 5.3 for the mapping of security profiles and conditions to mitigations, and Annex B for additional information.

5.1.3.3 Residual risk

Some cybersecurity risks cannot be fully eliminated by the product alone and result in residual risk after the product's mitigations have been applied. Where this is the case, the manufacturer shall document the residual risk and the actions the user or the operational environment can take to address it.

5.2 Technical security requirements specifications

5.2.1 General

This clause specifies the technical cybersecurity requirements for operating systems. Each technical requirement (TR-XXX) is satisfied by implementing the mitigations (MI-XXX) listed under it. The set of mitigations that a given product shall implement is determined by the security profile assigned to that product in clause 5.3: every baseline mitigation of that profile, together with every conditioned mitigation in clause 5.3.4 whose condition the product meets. Where a mitigation also carries an applicability field stated with its requirement, that mitigation applies only when the stated feature condition holds for the product. Compliance with a technical requirement is demonstrated by passing the assessment activities defined for each applicable mitigation.

5.2.2 TR-NKEV: No known exploitable vulnerabilities

5.2.2.1 MI-KEVM: Documentation of mitigation of known exploitable vulnerabilities

Assessment criteria: [\[AC-KEVM\]](#)

The product shall be accompanied by documentation demonstrating that all known exploitable vulnerabilities have been identified and either remediated or documented with the residual risk and any compensating control. The manufacturer shall consider public vulnerability databases (such as CVE, NVD) and upstream security advisories from component maintainers in addition to the manufacturer's own vulnerability research. Reported issues shall be triaged according to the manufacturer's documented secure development and vulnerability remediation policy, including severity classification, exploitability assessment, and compensating controls. The product is deemed to be compliant with this requirement if it:

- has no known exploitable vulnerabilities; or
- has known exploitable vulnerabilities that were disclosed within the manufacturer's documented vulnerability remediation timeline and for which assessment and remediation are in progress; and
- for each remaining vulnerability, has documentation of the residual risk and any compensating control.

NOTE: Publicly reported severity ratings and reports of known active exploitation are an input to, not a substitute for, the manufacturer's own assessment of a vulnerability's exploitability and impact in the context of the product. Where this product-specific assessment of the risk level differs from the publicly reported level, the manufacturer's assessment governs prioritisation, with the justification documented.

5.2.2.2 MI-KEVT: Testing for known exploitable vulnerabilities

Assessment criteria: [\[AC-KEVT\]](#)

Before release, the product shall undergo verification that all known exploitable vulnerabilities have been mitigated. Verification may use manual testing, automated scanning, or both. The manufacturer shall consider public vulnerability databases (such as CVE, NVD) and upstream security advisories from component maintainers in addition to the manufacturer's own vulnerability research. Reported issues shall be triaged according to the manufacturer's documented secure development and vulnerability remediation policy, including severity classification, exploitability assessment, and compensating controls. The product is deemed to be compliant with this requirement if it:

- has no known exploitable vulnerabilities; or
- has known exploitable vulnerabilities that were disclosed within the manufacturer's documented vulnerability remediation timeline and for which assessment and remediation are in progress; and
- for each tested vulnerability:
 - the test result shows that the vulnerability has been mitigated; or
 - the tested vulnerability has documentation of the residual risk and any compensating control.

NOTE: Publicly reported severity ratings and reports of known active exploitation are an input to, not a substitute for, the manufacturer's own assessment of a vulnerability's exploitability and impact in the context of the product. Where this product-specific assessment of the risk level differs from the publicly reported level, the manufacturer's assessment governs prioritisation, with the justification documented.

5.2.3 TR-MINI: Minimise impact on other devices and services

5.2.3.1 MI-RRIS: Document residual risk to other devices and services

Assessment criteria: [\[AC-RRIS\]](#)

The product shall be accompanied by documentation describing the residual risk to other devices and services on the network and the actions the user or the operational environment can take to mitigate it.

5.2.3.2 MI-MNET: Minimise negative impact of network transmission

Assessment criteria: [\[AC-MNET\]](#)

The product shall provide mechanisms that limit the rate and volume of network traffic it transmits so as to minimise impact on other products or services. The details of these mechanisms shall be documented, including the default configuration and how this contributes to minimising potential interference with other products or services on the network.

NOTE: Mechanisms include but are not limited to connection limits (per-client and total limits), retry/backoff strategies, rate limiting of unicast, broadcast or multicast traffic including per-connection limits, traffic shaping or traffic policing.

5.2.4 TR-SDEF: Secure by default configuration

5.2.4.1 MI-ADEF: Authorisation required by default to access security-relevant assets

Assessment criteria: [\[AC-ADEF\]](#)

The product, in its default state, shall require authentication and authorisation for access to security-relevant assets. The authentication mechanism and the authorisation rules applied to each class of security-relevant asset shall be documented by the manufacturer. For example, an autogenerated device-specific cryptographic key should not be readable without authentication and authorisation. Where the product is intended for integration into another product, the manufacturer shall document any security-relevant assets for which authentication and authorisation are not enforced by the product itself and are expected to be provided by the integrator.

5.2.4.2 MI-PDDI-1: Document how to control access to debug and management interfaces

Assessment criteria: [\[AC-PDDI-1\]](#)

All debug and management interfaces on the product shall be documented, and the documentation shall specify means to control access to or disable them.

- Applicability: This mitigation is for products intended for integration into subsequent products

5.2.4.3 MI-PDDI-2: Control local software access to debug and management interfaces

Assessment criteria: [\[AC-PDDI-2\]](#)

All debug and management interfaces which can be accessed by processes running on the system shall be access controlled or disabled by default, unless required for backward compatibility. Where the product allows the user to remove such protections, the manufacturer shall document the procedure, the residual risk, and the user roles permitted to perform the procedure.

NOTE: On general-purpose operating systems, device unlock and explicit authorised user consent is recognised as sufficient authorisation to enable these interfaces, without requiring predefined professional administrator roles.

5.2.4.4 MI-PDDI-3: Control network access to debug or management interfaces

Assessment criteria: [\[AC-PDDI-3\]](#)

All debug and management interfaces accessible via the network shall be access controlled or disabled by default, unless necessary for backward compatibility. Documentation regarding the removal of such protections by an appropriately sophisticated user may be provided, and shall include information regarding the risks.

- Applicability: Product exposes debug or management interfaces accessible via the network

5.2.5 TR-SCUD: Secure updates

5.2.5.1 MI-KEVD: Documentation for secure update before or during first use

Assessment criteria: [\[AC-KEVD\]](#)

The product shall be accompanied by documentation describing how the product may be securely updated, including how to update the product prior to, or as part of, first use.

- Applicability: The product has firmware or software update capability

5.2.5.2 MI-KEVA: Secure update before or during first use

Assessment criteria: [\[AC-KEVA\]](#)

The product shall implement a secure update mechanism that operates by default, including before or during first use.

The product shall provide a clear and easy-to-use mechanism allowing an authorised user to opt out of automatic security updates.

If an authorised user opted out of automatic security updates, the product shall provide, before or during first use, a mechanism to inform the user to initiate or postpone the update.

- Applicability: The product has firmware or software update capability

5.2.5.3 MI-SCUE: Security updates provided by the operational environment

Assessment criteria: [\[AC-SCUE\]](#)

The product shall be capable of receiving and applying secure updates provided by the operational environment, with their authenticity and integrity verified in accordance with MI-SUUI. The manufacturer shall document the requirements that the operational environment shall satisfy to deliver secure updates.

5.2.5.4 MI-SUUI: Update authenticity and integrity verification

Assessment criteria: [\[AC-SUUI\]](#)

The product shall verify the authenticity and integrity of update packages before installation. For a given update path, this verification may be satisfied by any one of the following mechanisms:

- verification of a cryptographic digital signature on the update package by the product;
- verification of update integrity only, by a hash or checksum, where authenticity is assured by compensating controls such as restricted access control, an authenticated delivery channel, or controlled tooling;
- an authenticated secure channel between the product and an authorised update source;
- controlled local or offline update through authorised personnel, trusted tools, and controlled update media; or
- a trusted platform component, such as a package manager or installer, that verifies the authenticity and integrity of update packages and controls their installation.

Where cryptographic mechanisms are used, they shall conform to TR-CRYP.

NOTE: For image-based operating systems, installation means activating the new image.

- Applicability: The product has firmware or software update capability

5.2.5.5 MI-SUDP: Anti-rollback protection

Assessment criteria: [\[AC-SUDP\]](#)

The product shall maintain a monotonic version counter or an equivalent mechanism to prevent the unauthorised installation of an earlier software version.

- Applicability: The product has firmware or software update capability

5.2.5.6 MI-SUAR: Authorised rollback

Assessment criteria: [\[AC-SUAR\]](#)

Where the product supports intentional, user-initiated rollback to an earlier software version, the rollback shall require explicit authorisation. Automated recovery mechanisms that revert to the immediately preceding operational state following a failed update or boot failure are considered recovery actions and are exempt from this explicit authorisation requirement.

- Applicability: The product supports intentional, user-initiated rollback to an earlier software version

5.2.6 TR-AUTH: Authentication and access control

5.2.6.1 MI-RAUT: Authenticate the remote data processing solution and validate its interactions at the RDPS boundary

Assessment criteria: [\[AC-RAUT\]](#)

Where the product communicates with a remote data processing solution, the product shall authenticate the remote data processing solution before transmitting data to it. Before acting upon an interaction received from a remote data processing solution that can influence the behaviour, state, configuration, or security of a product function, the product shall verify the authenticity and integrity of that interaction and shall reject replayed or stale interactions where replay or reuse could affect the secure operation of the product function. The required verification may be satisfied by the properties of a secure channel conforming to TR-CRYP.

- Applicability: Product depends on one or more remote data processing solutions

5.2.6.2 MI-AUTH-1: Require user authentication on interfaces providing access to the operating system

Assessment criteria: [\[AC-AUTH-1\]](#)

The operating system shall require user authentication by default on all interfaces that provide access to operating system resources or functions that are not intended for unauthenticated use.

- Applicability: Product provides an interface that supports user or administrator authentication

5.2.6.3 MI-AUTH-2: Require privilege or authorisation on interfaces providing access to the operating system

Assessment criteria: [\[AC-AUTH-2\]](#)

The operating system shall ensure that interfaces providing access to operating system resources or functions not intended for unauthenticated use cannot be invoked by an unauthorised account. Access shall require the account to hold the appropriate privilege or authorisation, whether presented by an interactively authenticated administrator or by an authorised service or machine identity.

- Applicability: Product provides an interface that supports user or administrator authentication

5.2.6.4 MI-LCKT: Authentication failure protection

Assessment criteria: [\[AC-LCKT\]](#)

The operating system shall by default enforce authentication failure protection on all authentication interfaces.

NOTE: Examples of enforcement mechanisms include progressive delays between failed attempts or temporary account lockout after a number of failed attempts.

- Applicability: Product provides an interface that supports user or administrator authentication

5.2.6.5 MI-CRED: Protect stored critical security parameters and enforce credential strength

Assessment criteria: [\[AC-CRED\]](#)

The operating system shall protect stored credentials, cryptographic keys, and other critical security parameters using mechanisms conforming to TR-CRYP, and shall by default enforce minimum credential strength requirements documented by the manufacturer for credentials it accepts through authentication interfaces.

- Applicability: Product stores credentials, cryptographic keys, or other critical security parameters, or accepts credentials through a user or administrator authentication interface

5.2.6.6 MI-ACCS: Access control enforcement on operating system resources and functions

Assessment criteria: [\[AC-ACCS\]](#)

The operating system shall enforce access control on operating system resources and functions based on the authenticated identity, role, privilege level, or other attributes of the requesting subject, as documented by the manufacturer.

- Applicability: Product supports differentiated access to operating system resources or functions among subjects

5.2.6.7 MI-PRIV: Privilege separation and restriction

Assessment criteria: [\[AC-PRIV\]](#)

Where the operating system supports multiple privilege levels, the operating system shall enforce privilege separation between subjects executing at different privilege levels, and shall restrict each subject to the operations permitted at its assigned privilege level and deny privilege escalation attempts within an active session without re-authentication or other documented authorisation.

- Applicability: Product supports multiple privilege levels

5.2.6.8 MI-SESS: Interactive session lifecycle controls

Assessment criteria: [\[AC-SESS\]](#)

Where the operating system supports authenticated interactive sessions that persist after initial authentication, the operating system shall invalidate the interactive session upon session logout or termination, with any security context or tokens derived from that session continuing only according to the product's documented session model.

- Applicability: Product supports authenticated interactive sessions that persist after initial authentication

5.2.6.9 MI-ACSD: Access control for stored data

Assessment criteria: [\[AC-ACSD\]](#)

The product shall protect stored data from unauthorised access or modification by enforcing access controls and privilege separation at the operating system level.

5.2.7 TR-CDST: Confidentiality of data stored on the product

5.2.7.1 MI-ENST: Cryptographic encryption of stored data

Assessment criteria: [\[AC-ENST\]](#)

Where the product stores user data, the product shall, by default, provide the option to protect the confidentiality of that data at rest using a cryptographic encryption mechanism conforming to TR-CRYP.

- Applicability: Product stores user data

5.2.8 TR-CDTX: Confidentiality of data transmitted by the product

5.2.8.1 MI-CDTX: Protect confidentiality of user data transmitted by the product

Assessment criteria: [\[AC-CDTX\]](#)

The product shall, by default, protect user data transmitted by the product from unauthorised access.

- NOTE: This only applies where the product initiates the data processing leading to transmission, and does not apply to user initiated actions while using the product.

- Applicability: Product transmits user data

5.2.8.2 MI-RRDC: Document residual risk to confidentiality of data transmitted

Assessment criteria: [\[AC-RRDC\]](#)

Where the product transmits user data, the product shall be accompanied by documentation describing the residual risk to the confidentiality of that data transmitted by the product and the actions the user or the operational environment can take to mitigate it.

NOTE: This only applies where the product initiates the data processing leading to transmission, and does not apply to user initiated actions while using the product.

- Applicability: Product transmits user data

5.2.8.3 MI-ENTX: Cryptographic encryption of transmitted data

Assessment criteria: [\[AC-ENTX\]](#)

Where the product transmits user data, the product shall, by default, protect the confidentiality of that data in transit using a cryptographic encryption mechanism conforming to TR-CRYP.

NOTE: This only applies where the product initiates the data processing leading to transmission, and does not apply to user initiated actions while using the product.

- Applicability: Product transmits user data

5.2.9 TR-CRYP: Encryption

5.2.9.1 MI-CRYP: Conformance to Annex K

Assessment criteria: [\[AC-CRYP\]](#)

The product shall conform to Annex K.

5.2.10 TR-IDST: Integrity of data stored on the product

5.2.10.1 MI-DCST: Detect corruption of stored data

Assessment criteria: [\[AC-DCST\]](#)

The product shall provide the capability to detect corruption of stored data.

NOTE 1: Mechanisms include but are not limited to checksums, parity, or error-correcting codes.

NOTE 2: The availability of the capability of the product in its operational environment might be dependent on user-choice of configuration such as the file system.

5.2.10.2 MI-INTS: Cryptographic integrity protection of stored data

Assessment criteria: [\[AC-INTS\]](#)

Where the product uses cryptographic mechanisms for integrity protection of stored data, they shall conform to TR-CRYP, such as message authentication codes or digital signatures.

- Applicability: Product uses cryptographic mechanisms for integrity protection of stored data

5.2.11 TR-IDTX: Integrity of data transmitted by the product

5.2.11.1 MI-INTT: Cryptographic integrity protection of transmitted data

Assessment criteria: [\[AC-INTT\]](#)

Where the product transmits user data, the product shall, by default, protect the integrity of that data in transit using a cryptographic integrity mechanism conforming to TR-CRYP, such as a message authentication code or a digital signature.

NOTE: This only applies where the product initiates the data processing leading to transmission, and does not apply to user initiated actions while using the product.

- Applicability: Product transmits user data

5.2.12 TR-DMIN: Data Minimisation

5.2.12.1 MI-DJST: Document and justify processed data

Assessment criteria: [\[AC-DJST\]](#)

All sources of user data processed by the product in its secure-by-default configuration shall be documented. All sources of user data processed shall have a documented rationale for why its processing is necessary for the functioning of the product in its secure-by-default configuration.

NOTE: This only applies where the product initiates the data processing leading to transmission, and does not apply to user initiated actions while using the product.

5.2.13 TR-AVAI: Availability

5.2.13.1 MI-AVNT: Availability of network functions

Assessment criteria: [\[AC-AVNT\]](#)

The product shall protect the availability of essential and core network functions through mitigation of denial-of-service attacks.

NOTE 1: Denial-of-service protection mechanisms may include TCP SYN flooding attack mitigations as specified in IETF RFC 4987 [i.11].

NOTE 2: Mechanisms to drop undesirable or excessive network packets before incurring significant resource usage associated with processing those packets can include SYN cookies, packet filtering before connection tracking, configurable timeouts for connections, and limits on the number of simultaneous connections.

5.2.13.2 MI-CSFR: Detection and recovery from critical service failures

Assessment criteria: [\[AC-CSFR\]](#)

The product shall implement mechanisms to detect and recover from failures of the services the manufacturer documents as critical services.

NOTE: For general-purpose operating systems, this could include mechanisms such as automatically restarting failed essential services, handling critical kernel faults, or providing a 'safe mode' recovery environment. Where appropriate for the use case (such as embedded or real-time operating systems) and supported by the hardware, the product may utilise a hardware watchdog to trigger a reset.

5.2.13.3 MI-RLIM: Resource usage limits and exhaustion fallback

Assessment criteria: [\[AC-RLIM\]](#)

The product shall provide configurable mechanisms that allow authorised users to constrain memory and resource usage for processes and network connections.

The product shall implement a fallback mechanism that constrains the processes or resource consumers the manufacturer documents as subject to the fallback, so as to preserve the availability of the functions the manufacturer documents as essential or core functions, when documented resource-exhaustion thresholds are reached.

Where the product exposes shared or limited resources to multiple concurrent users, these mechanisms shall also be capable of preventing a user from causing sustained denial of service to other users through resource exhaustion.

5.2.13.4 MI-PRIO: Workload prioritisation

Assessment criteria: [\[AC-PRIO\]](#)

The product shall implement scheduling capabilities that support priority levels for processes and network traffic. The product shall be able to prioritise the functions the manufacturer documents as core operating system functions over lower-priority workloads when documented resource-contention thresholds are reached.

5.2.13.5 MI-RRDS: Document residual risk of denial of service

Assessment criteria: [\[AC-RRDS\]](#)

The product shall be accompanied by documentation describing the residual risk of denial of service and the measures the operational environment can provide to mitigate it, such as an external or internal firewall, fair queueing or filtering, or a proxy.

5.2.13.6 MI-RTDL: Real-time deadline preservation

Assessment criteria: [\[AC-RTDL\]](#)

The product shall demonstrate that its security mechanisms do not cause the product to exceed documented worst-case execution times for real-time tasks.

- Applicability: Product has documented real-time deadlines

5.2.13.7 MI-RTRY: Retry and degraded behaviour on unavailability of the remote data processing solution

Assessment criteria: [\[AC-RTRY\]](#)

Where the availability or timeliness of interactions with a remote data processing solution is necessary for the secure operation of the product, the product shall detect unavailability of the remote data processing solution or unacceptable delay of expected interactions, apply defined timeout controls for expected interactions, retry failed communications within a manufacturer-documented retry window, justified in the product risk assessment and appropriate to the dependent product function, and apply a defined behaviour for the dependent product function when the remote data processing solution remains unavailable beyond the acceptable time.

- Applicability: Product depends on one or more remote data processing solutions

5.2.14 TR-ISOL: Isolation

5.2.14.1 MI-ISO-1: Access control across security boundaries

Assessment criteria: [\[AC-ISO-1\]](#)

The product shall enforce security boundaries that restrict access to security-relevant assets to authorised subjects and authorised operations. Where the product supports multiple users, applications, processes, execution contexts, privilege levels, or administrative roles, the product shall provide mechanisms that distinguish those subjects and restrict access across security boundaries according to the product's access-control and isolation model.

NOTE: This mitigation states, as a general security-boundary requirement, the access-control and privilege principles that MI-ACCS and MI-PRIV enforce under TR-AUTH.

5.2.14.2 MI-ISO-2: Process isolation

Assessment criteria: [\[AC-ISO-2\]](#)

The product shall enforce isolation between processes at the CPU, memory, I/O, and interrupt-handling levels, ensuring that one process cannot read or modify the resources of another process, and cannot degrade the availability of another process beyond what is permitted by the product's configured scheduling and resource-sharing policies.

NOTE: Performance variability caused by normal scheduling and resource sharing, for example reduced CPU time under load, is acceptable when it remains within the product's configured scheduling and resource-sharing policies.

- Applicability: Product executes more than one process concurrently

5.2.14.3 MI-ISO-3: Isolation between the processes of different users

Assessment criteria: [\[AC-ISO-3\]](#)

The product shall enforce isolation between processes belonging to different users, ensuring that one user cannot read or modify the resources of another user, and cannot degrade the availability of another user's processes beyond what is permitted by the product's configured scheduling and resource-sharing policies.

- Applicability: Product hosts more than one user account

5.2.14.4 MI-ISO-4: Isolation between the data of different users

Assessment criteria: [\[AC-ISO-4\]](#)

The product shall by default enforce isolation between data belonging to different users, ensuring that one user cannot read or modify the data of another user, and cannot degrade the availability of another user's data beyond what is permitted by the product's configured resource-sharing policies.

- Applicability: Product hosts more than one user account

5.2.14.5 MI-ISO-5: Privilege model

Assessment criteria: [\[AC-ISO-5\]](#)

The product shall provide a privilege model that provides different levels of access to system resources requiring separate authorisation according to the product's access-control and isolation model.

NOTE: This mitigation complements MI-PRIV under TR-AUTH, which enforces privilege separation between subjects executing at different privilege levels.

- Applicability: Product is a general-purpose operating system

5.2.14.6 MI-ISO-6: Side-channel isolation

Assessment criteria: [\[AC-ISO-6\]](#)

The product shall by default strengthen isolation with mitigations against known side-channel attacks between workloads sharing hardware resources, as documented by the product's risk assessment and relevant to the known attack classes applicable to the product and its supported hardware.

The product documentation shall include the mitigation's default state and rationale, and the residual risks.

The product shall enable, by default, the mitigations for the attack classes whose risk is present across the product's intended deployment scenarios.

Where the risk assessment shows that a class of side-channel attacks is deployment-specific and that enabling its mitigation would impose a disproportionate impact on the scenarios in which the risk is low or absent, the product may provide the mitigation off by default and include the process by which an authorised user can activate the mitigation.

Where effective mitigation depends on platform mechanisms outside the declared product boundary or outside the responsibility of the manufacturer, those mechanisms shall be treated as Operational Environment dependencies. The product security documentation shall identify the dependency and the expected security properties.

5.2.14.7 MI-ISO-7: Binary hardening

Assessment criteria: [\[AC-ISO-7\]](#)

The product binaries shall exhibit the hardening measures documented by the manufacturer for the target platform and the respective language or languages for the respective product binaries. The manufacturer shall document the risk-appropriate hardening measures and the rationale applied to each product binary and to groups of binaries, together with the residual risk and any compensating control.

NOTE: Example hardening measures depend on the programming language, the CPU architecture, and the CPU features. Non-memory-safe languages may use techniques such as heap corruption detection, buffer overflow detection, stack overflow protection, stack clash protection, non-executable heap, non-executable stack, and position-independent executables. Memory-safe languages may use the compiler itself for protection and a reduction in the number of unsafe constructs. Generic hardening measures include address space layout randomisation, control flow integrity, memory tagging, and mathematical proofs.

- Applicability: Product is implemented in a compiled language

5.2.15 TR-LOGG: Logging and monitoring

5.2.15.1 MI-LOGG: Logging

Assessment criteria: [\[AC-LOGG\]](#)

The product shall record time-stamped log messages for security-relevant events in accordance with the manufacturer's default secure configuration. Each log record shall include, as applicable to the event type, the time of the event, the outcome of the event, and the identity of the associated user, service, or process. The manufacturer shall document, based on its risk assessment, which events are treated as security-relevant for the product.

Log records produced in the product's default secure configuration shall not include plaintext credentials or full cryptographic keys. Log, telemetry, and diagnostic data shall be limited to that necessary for operation, troubleshooting, and security monitoring. Where the product collects data that may contain sensitive content, the manufacturer shall document that collection.

The product shall provide an authorised user with a mechanism to opt-out of the recording and monitoring of security-relevant events.

NOTE 1: Security-relevant events can include, but are not limited to, access or modification of system data, services or functions.

NOTE 2: Sensitive log content can include, but is not limited to, memory or crash dumps, register or pointer state, command-line or script capture, or debug payloads.

5.2.16 TR-SCDL: Secure deletion

5.2.16.1 MI-SDEL: Secure deletion

Assessment criteria: [\[AC-SDEL\]](#)

The product shall provide a means by which the user can securely delete user data and settings stored on the product, such that the deleted data and settings cannot subsequently be recovered through the product's interfaces.

NOTE: The means may be a reset to the secure-by-default state, a reinstallation, or a secure deletion function. For products employing hardware-backed storage encryption (conforming to TR-CRYP), cryptographic erasure (destruction of the encryption key) is recognised as a sufficient method of secure deletion regardless of data sensitivity.

- Applicability: Product has the capability for the user to write data and/or settings

5.2.16.2 MI-RRSD: Document residual risk to secure deletion

Assessment criteria: [\[AC-RRSD\]](#)

The product shall be accompanied by documentation describing the residual risk to secure deletion, including any user data or settings that the product cannot guarantee to delete, and the actions the user or the operational environment can take to mitigate it.

- Applicability: Product has the capability for the user to write data and/or settings

5.2.17 TR-SDTR: Secure data read and transfer

5.2.17.1 MI-SDRF: Secure data read from product

Assessment criteria: [\[AC-SDRF\]](#)

The product shall provide a method by which an authorised user can securely read their data and settings from the product. Reading system data or data shared by multiple users may be limited to an authorised user having sufficient privileges.

- Applicability: Product has the capability for the user to write data and/or settings

5.2.17.2 MI-SDTR: Document secure data transfer to another product or system

Assessment criteria: [\[AC-SDTR\]](#)

Where the product provides a method to transfer data and settings to another product or system, it shall be accompanied by documentation describing how the confidentiality and integrity of the data and settings are protected during the transfer.

- Applicability: Product has the capability for the user to write data and/or settings and to transfer them to another product or system

5.3 Security profiles

5.3.1 General

This clause specifies, normatively, the mitigations a product shall implement. There are two security profiles, SP-REST and SP-GEN, one for each basic use case in clause [4.7.2](#). A product is assigned the security profile of its basic use case, determined as in clause [4.7.4](#).

A product shall implement:

- every baseline mitigation listed for its security profile, in clause 5.3.2 for SP-REST or clause 5.3.3 for SP-GEN; and
- every conditioned mitigation in clause 5.3.4 whose condition the product meets, whatever the product's security profile.

Overlaps between the baseline and the conditioned mitigations resolve by union: where a conditioned mitigation already appears in the product's baseline, the condition adds nothing further. Where a mitigation also carries an applicability field stated with its requirement in clause 5, that mitigation applies only when the stated condition holds for the product.

Where a list shows alternative mitigations separated by "or", the manufacturer shall implement at least one of the listed alternatives. The selection shall be based on the product's implementation characteristics and capabilities. The manufacturer shall document which alternative was selected and the rationale for the selection, as part of the conformity assessment evidence.

5.3.2 SP-REST baseline mitigations

A restricted operating system (UC-REST) implements the following mitigations regardless of any condition. They address the known-vulnerability threat to a product that receives updates, and require state of the art cryptography in accordance with Annex K wherever the product uses cryptography; every other mitigation is contributed by a condition in clause 5.3.4:

- 1) (KEVD or KEVA)
- 2) KEVM
- 3) SCUE
- 4) SUVI
- 5) SUDP
- 6) SUAR
- 7) CRYP

5.3.3 SP-GEN baseline mitigations

A general-purpose operating system (UC-GEN) implements the following mitigations regardless of any condition:

- 1) (KEVD or KEVA)
- 2) KEVM
- 3) SCUE
- 4) SUVI
- 5) SUDP
- 6) SUAR
- 7) CRYP
- 8) ADEF
- 9) ISO-1
- 10) ISO-2
- 11) ISO-5
- 12) ISO-7

- 13) LOGG
- 14) AUTH-1
- 15) AUTH-2
- 16) CRED
- 17) LCKT
- 18) PDDI-1
- 19) RRDS
- 20) RLIM
- 21) ENST
- 22) ACSD
- 23) DCST
- 24) INTS
- 25) SDEL
- 26) RRSD

5.3.4 Conditioned mitigations

5.3.4.0 General

In addition to the baseline mitigations of its security profile, a product implements every mitigation listed below for a condition it meets (clause [4.7.3](#)), whatever the product's security profile.

5.3.4.1 C-NET: Public network access

- 1) AUTH-1
- 2) AUTH-2
- 3) CRED
- 4) LCKT
- 5) PDDI-1
- 6) PDDI-3
- 7) SESS
- 8) CDTX
- 9) ENTX
- 10) INTT
- 11) RRDC
- 12) RRDS
- 13) MNET

5.3.4.2 C-NETR: Restricted network access

- 1) AUTH-1
- 2) AUTH-2
- 3) CRED
- 4) LCKT
- 5) PDDI-1
- 6) CDTX
- 7) ENTX
- 8) INTT
- 9) RRDC
- 10) RRIS

5.3.4.3 C-MOD: User-modifiable software, firmware, or hardware

- 1) AUTH-1
- 2) AUTH-2
- 3) CRED
- 4) LCKT
- 5) PDDI-1

5.3.4.4 C-APPS: Third-party application installation

- 1) AUTH-1
- 2) AUTH-2
- 3) CRED
- 4) LCKT
- 5) PDDI-1
- 6) PDDI-2
- 7) ACCS
- 8) PRIV

5.3.4.5 C-LOSS: Loss or theft of a portable device

- 1) AUTH-1
- 2) AUTH-2
- 3) PDDI-1

5.3.4.6 C-MULTI: Multiple user accounts

- 1) AUTH-1
- 2) AUTH-2

- 3) CRED
- 4) LCKT
- 5) PDDI-1
- 6) PDDI-2
- 7) ACCS
- 8) PRIV
- 9) SESS
- 10) RRDS
- 11) RLIM
- 12) ISO-3
- 13) ISO-4

5.3.4.7 C-UNTR: Untrusted concurrent users

- 1) ACCS
- 2) PRIV
- 3) RRDS
- 4) RLIM
- 5) ISO-3
- 6) ISO-4
- 7) ISO-6

5.3.4.8 C-DATA: Sensitive or personal data

- 1) DJST
- 2) LOGG
- 3) ENST
- 4) ACSD
- 5) DCST
- 6) INTS
- 7) SDEL
- 8) RRSB
- 9) SDRF
- 10) SDTR

5.3.4.9 C-FUNC: Sensitive functions

- 1) AUTH-1
- 2) AUTH-2
- 3) AVNT

- 4) PRIO
- 5) RLIM
- 6) LOGG
- 7) CSFR
- 8) RTDL

5.3.4.10 C-RDPS: Remote data-processing dependency

- 1) RAUT
- 2) RTRY
- 3) CDTX
- 4) ENTX
- 5) INTT
- 6) LOGG

5.3.4.11 C-PHYS: Physical exposure to untrusted persons

- 1) AUTH-1
- 2) AUTH-2
- 3) PDDI-1

5.3.4.12 C-SELFADM: Self-administration

- 1) KEVA
- 2) KEVT

NOTE: The mitigations ADEF, ISO-1, ISO-2, and ISO-7 listed in the SP-GEN baseline (clause 5.3.3) are also required for an SP-REST product when any high-exposure condition holds, namely any of C-NET, C-LOSS, C-MULTI, C-UNTR, C-FUNC, or C-PHYS. They are part of the SP-GEN baseline and so need not be repeated under those conditions for an SP-GEN product.

6 Assessment criteria for compliance with technical requirements

6.1 Introduction to the assessment and compliance criteria

This clause details the assessment process for compliance with the requirements in clause 5 of the present document. Each assessment activity in this clause corresponds to a mitigation in clause 5.2.

NOTE: In this clause, *documentation* means any documentation provided to the assessor. This includes, but is not limited to, the technical specification, test results, and instructions to the user.

This clause provides objective and reproducible assessment criteria to determine whether a product complies with the technical security requirements of clause 5.

For each cybersecurity requirements defined in clause 5, the following clauses specify assessment criteria to determine if the technical requirement is met.

The assessment criteria for each security requirements are described in a structured manner, as follows:

- **Assessment reference:** Refers to the identifier of the concerned technical requirement.
- **Assessment objective:** Defines the security property or capability that shall be verified, ensuring that the assessment remains focused on the intent of the requirement.
- **Assessment preparation:** Describes the environment, setup, and preconditions required before executing the test with a view to guaranteeing consistent evaluation results. It includes the following elements as applicable:
 - Test environment: Describe the hardware, software, and network setup used for the assessment, including versions, topology, and any relevant dependencies.
 - Preconditions: Specify any configurations, credentials, or operational states that should be established before the test (e.g. product initialised, certificates loaded, user roles created).
 - Required tools: Identify the tools or software necessary to perform the assessment (e.g. vulnerability scanners, protocol fuzzers, traffic analysers, static code analysers, cryptographic test suites).
 - Required information/documentation for the assessment: Specify all information that is necessary to perform the assessment.
 - Reference any vendor-provided setup guides, configuration instructions, or operational manuals, as well as any relevant standards or technical notes, that define how the product shall be configured or operated for the assessment.
- **Assessment activities:** Provides execution steps to be performed such that the same assessment verdict would be reached when repeating these steps now or at a later point in time. Assessment activities may include, as applicable:
 - Review information/documentation for the assessment to confirm that the described implementation matches the requirement (e.g. verify that the security architecture document specifies TLS 1.2 or higher for all external interfaces, or that the password policy aligns with the defined threshold).
 - Perform security functional tests to verify the completeness and correctness of the information/documentation for the assessment.
 - Perform security functional or penetration tests to verify that implemented controls are correctly implemented e.g. to prevent unauthorised access or data modification (e.g. via attempting to log in with invalid credentials to test lockout enforcement or trying to modify protected configuration files without administrative privileges).
 - Analyse code or binaries to identify potential security weaknesses or misconfigurations (e.g. perform static analysis to detect hardcoded credentials or use dynamic analysis tools to identify buffer overflow or injection vulnerabilities).
 - Inspect configurations to ensure that required security parameters are correctly applied (e.g. check that weak cipher suites are disabled, two-factor authentication is enabled, and least-privilege access controls are configured in the system).
 - Observe runtime behaviour to confirm that protections such as encryption, authentication, and integrity verification operate as intended (e.g. monitor network traffic to ensure data in transit is encrypted or observe system logs to verify successful validation of digital signatures during startup).
- **Assessment verdict:** Defines the pass/fail criteria.
 - **Pass:** The assessment is considered passed if the product demonstrably fulfils the requirement and meets the defined security thresholds. Examples of such thresholds include:
 - Minimum cryptographic strength (e.g. AES-128 or higher);
 - Password policy limits (e.g. minimum of 12 characters);
 - Login protection mechanisms (e.g. account lockout after five consecutive failed attempts);
 - Resistance to a specified attack potential (e.g. equivalent to CSA High/AVA_VAN.3 or higher).

- **Fail:** The assessment is considered failed if the requirement is not fulfilled, or if the defined security thresholds are not achieved (e.g. insufficient key length, missing authentication enforcement, or inadequate resistance to the required attack potential).
- **Assessment evidence:** Defines the artefacts and documentation collected to demonstrate that the requirement has been assessed and fulfilled. The evidence shall be sufficient to enable independent verification of the assessment results and to demonstrate compliance with the relevant CRA essential requirements. The supporting evidence include, where applicable:
 - Test or assessment reports showing the steps performed and results obtained;
 - Logs, configuration files, or audit traces demonstrating the implementation of the requirement;
 - Screenshots, captures, or console outputs confirming the correct execution or protection behaviour;
 - Relevant vendor or design documentation describing the applied security measures;

6.2 TR-NKEV: No known exploitable vulnerabilities

6.2.1 [AC-KEVM] Assessment criteria: Documentation of mitigation of known exploitable vulnerabilities

Assessment reference

Mitigation [MI-KEVM](#).

Assessment objective

Prevent exploitation of known exploitable vulnerabilities.

Assessment preparation

- 1) Compile a list of known exploitable vulnerabilities in the product and its components by consulting public vulnerability databases (such as CVE, NVD) and the manufacturer's own vulnerability records.

Assessment activities

- 1) Compare the generated list of known exploitable vulnerabilities with the manufacturer's documentation of remediated and outstanding vulnerabilities.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) At least one known exploitable vulnerability is neither remediated nor documented with its residual risk and any compensating control, and exceeds the manufacturer's documented vulnerability remediation timeline without documented justification.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) No known exploitable vulnerabilities were found, or every known exploitable vulnerability is remediated, documented with its residual risk and any compensating control, or within the manufacturer's documented vulnerability remediation timeline with assessment and remediation in progress.

Assessment evidence

- 1) Documented vulnerability handling policy, list of known exploitable vulnerabilities, documentation of remediation or residual risk for each vulnerability, correlation of the list with the manufacturer's records.

6.2.2 [AC-KEVT] Assessment criteria: Testing for known exploitable vulnerabilities

Assessment reference

Mitigation [MI-KEVT](#).

Assessment objective

Prevent exploitation of known exploitable vulnerabilities.

Assessment preparation

- 1) Compile a list of known exploitable vulnerabilities in the product and its components by consulting public vulnerability databases (such as CVE, NVD) and the manufacturer's own vulnerability records.
- 2) Select the vulnerabilities to be tested, prioritising by severity, known active exploitation, impact on the product, and privilege escalation potential.
- 3) Collect or prepare test procedures for each selected vulnerability.

Assessment activities

- 1) On a new product, run the tests and compare the results with the generated list of known exploitable vulnerabilities.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) At least one tested vulnerability is neither mitigated nor documented with the residual risk and any compensating control, and exceeds the manufacturer's documented vulnerability remediation timeline without documented justification.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) No known exploitable vulnerabilities found, or every tested vulnerability is mitigated, documented with the residual risk and any compensating control, or within the manufacturer's documented vulnerability remediation timeline with assessment and remediation in progress.

Assessment evidence

- 1) Documented vulnerability handling policy, list of known exploitable vulnerabilities, test selection rationale, test results for each tested vulnerability, documentation of residual risk for any tested vulnerability that is not mitigated.

6.3 TR-MINI: Minimise impact on other devices and services

6.3.1 [AC-RRIS] Assessment criteria: Document residual risk to other devices and services

Assessment reference

Mitigation [MI-RRIS](#).

Assessment objective

Minimise impact on other devices and services on the network.

Assessment activities

- 1) Examine the documentation.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Residual risk to other devices and services on the network is not documented, or the documentation does not state the actions the user or the operational environment can take.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Residual risk to other devices and services on the network is documented, including the actions the user or the operational environment can take to mitigate it.

Assessment evidence

- 1) Documentation, analysis of documentation.

6.3.2 [AC-MNET] Assessment criteria: Minimise negative impact of network transmission

Assessment reference

Mitigation [MI-MNET](#).

Assessment objective

Verify that the product implements and documents mechanisms that limit the rate and volume of the network traffic it transmits to minimise adverse impact on other products or services on the network.

Assessment preparation

- 1) The manufacturer's documentation of the mechanisms that limit the rate and volume of the network traffic the product transmits, their default configuration, and how they minimise potential interference with other products or services on the network is available.

Assessment activities

- 1) Review the documentation to confirm it covers the mechanisms that limit the rate and volume of the network traffic the product transmits, details their default configuration, and explains how they minimise potential interference with other products or services on the network.
- 2) Inspect the product in its default state to verify that the documented rate- and volume-limiting mechanisms are present and configured as described.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) The documentation does not detail the mechanisms that limit the rate and volume of the transmitted network traffic, their default configuration, or how they minimise potential interference.
- 2) The product's active default configuration does not match the documented rate- and volume-limiting mechanisms.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) The documentation details the mechanisms that limit the rate and volume of the transmitted network traffic, their default configuration, and how they minimise potential interference with other products or services on the network.
- 2) The product's active default configuration matches the documented rate- and volume-limiting mechanisms.

Assessment evidence

- 1) Documentation of the transmit rate- and volume-limiting mechanisms, their default configuration, and the interference-minimisation rationale.

- 2) Test logs or inspection results verifying the active rate- and volume-limiting configuration on the product in its default state.

6.4 TR-SDEF: Secure by default configuration

6.4.1 [AC-ADEF] Assessment criteria: Authorisation required by default to access security-relevant assets

Assessment reference

Mitigation [MI-ADEF](#).

Assessment objective

Find any unauthorised access to security-relevant assets in default configuration and confirm the authentication mechanism and the authorisation rules, including any expected from the integrator, are documented.

Assessment preparation

- 1) Obtain the manufacturer's documentation of the classes of security-relevant assets. For each documented class, identify the interfaces or access paths through which the product exposes it.

Assessment activities

- 1) For each documented class of security-relevant asset, using the interfaces or access paths identified for it, attempt to access the asset without authentication and authorisation and record whether access was allowed or not.
- 2) Assess the documentation provided with the product and, where the product is intended for integration into another product, the documentation of security-relevant assets whose authentication and authorisation are expected to be provided by the integrator. For each class of security-relevant asset, confirm the documented authentication mechanism and authorisation rules match the behaviour observed in the access attempts.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) For at least one documented class of security-relevant asset, an interface or access path identified for it allows access without authentication and authorisation.
- 2) The authentication mechanism or the authorisation rules are not documented for at least one class of security-relevant asset, or do not match the observed behaviour, or any asset whose authentication and authorisation are expected from the integrator is not documented.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) For each documented class of security-relevant asset, no interface or access path identified for it allows access without authentication and authorisation.
- 2) The authentication mechanism and the authorisation rules are documented for each class of security-relevant asset and match the observed behaviour, and any assets whose authentication and authorisation are expected from the integrator are documented.

Assessment evidence

- 1) The manufacturer's documentation of the classes of security-relevant assets and the interfaces or access paths identified for each, the record of activities used to attempt unauthorised access, and the log of results of attempts.
- 2) Documentation of the authentication mechanism and authorisation rules for each class of security-relevant asset, and the comparison against the observed access-attempt results.

6.4.2 [AC-PDDI-1] Assessment criteria: Document how to control access to debug and management interfaces

Assessment reference

Mitigation [MI-PDDI-1](#).

Assessment objective

Confirm that all debug and management interfaces are documented and that the documentation specifies means to control access to or disable them.

Assessment preparation

- 1) Examine the documentation for how to control access to or disable the debug/management interfaces of the product.

Assessment activities

- 1) Examine the product for undocumented debug/management interfaces, then follow the instructions in the documentation to disable or control access to each documented interface, then attempt to access the interface without authorisation.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Any debug/management interface is not documented or any interface is accessible without authorisation after following the documentation to control access to or disable them.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) All debug/management interfaces are documented as to how to disable or control access to them, and no interfaces are accessible without authorisation after following the documentation to control access to or disable them.

Assessment evidence

- 1) Pictures of the product, list of discovered interfaces, comparison with documentation, notes as to which are documented how to disable or control access to, logs of access control and disable actions, logs of attempts to access interfaces after access was controlled or they were disabled.

6.4.3 [AC-PDDI-2] Assessment criteria: Control local software access to debug and management interfaces

Assessment reference

Mitigation [MI-PDDI-2](#).

Assessment objective

Confirm that debug and management interfaces accessible by processes running on the system are access controlled or disabled by default.

Assessment preparation

- 1) Examine the documentation of the localhost-accessible debug and management interfaces of the product and follow the instructions to mitigate the risk of any necessary interfaces that are not access controlled or are enabled.

Assessment activities

- 1) As an unprivileged process running on the system, attempt to access the system's local debug and management interfaces and make unauthorised changes. Additionally, scan accessible memory and inter-process-communication mechanisms for undocumented debug and management interfaces.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Any undocumented interface is found or any interface can be accessed without authorisation and is not documented as necessary, or, where the product allows the user to remove such protections, the instructions to the user do not document the procedure, the residual risk, or the permitted user roles.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) No undocumented interfaces are found and no interfaces can be accessed without authorisation other than those documented as necessary, and, where the product allows the user to remove such protections, the instructions to the user document the procedure, the residual risk, and the permitted user roles.

Assessment evidence

- 1) List of interfaces, log of attempts to access.

6.4.4 [AC-PDDI-3] Assessment criteria: Control network access to debug or management interfaces

Assessment reference

Mitigation [MI-PDDI-3](#).

Assessment objective

Confirm that debug and management interfaces accessible via the network are access controlled or disabled by default.

Assessment preparation

- 1) Examine the documentation of the network accessible debug and management interfaces of the product and follow the instructions to mitigate the risk of any necessary interfaces that are not access controlled or are enabled.

Assessment activities

- 1) Using a network scanner, scan the product for both documented and undocumented debug or remote management interfaces and determine whether they are enabled or access controlled.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Any undocumented interface is found or any interface can be accessed without authorisation and is not documented as necessary, or documentation regarding the removal of these protections is provided but does not include information regarding the risks.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) No undocumented interfaces are found and no interfaces can be accessed without authorisation other than those documented as necessary, and any documentation provided regarding the removal of these protections includes information regarding the risks.

Assessment evidence

- 1) List of interfaces, log of attempts to access.

6.5 TR-SCUD: Secure updates

6.5.1 [AC-KEVD] Assessment criteria: Documentation for secure update before or during first use

Assessment reference

Mitigation [MI-KEVD](#).

Assessment objective

Verify that the product documents how it may be securely updated, including before or during first use.

Assessment preparation

- 1) The manufacturer's documentation describing how the product may be securely updated, including how to update it prior to, or as part of, first use, is available.

Assessment activities

- 1) Assess the documentation to determine whether it describes how the product may be securely updated, including how to update the product prior to, or as part of, first use.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) The documentation does not describe how the product may be securely updated, or does not describe how to update the product prior to, or as part of, first use.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) The documentation describes how the product may be securely updated, including how to update the product prior to, or as part of, first use.

Assessment evidence

- 1) The product documentation and analysis of its completeness.

6.5.2 [AC-KEVA] Assessment criteria: Secure update before or during first use

Assessment reference

Mitigation [MI-KEVA](#).

Assessment objective

Verify that the product's secure update mechanism operates before or during first use, that an authorised user can opt out of automatic security updates, and that the user is informed to initiate or postpone the update after opting out.

Assessment preparation

- 1) The manufacturer's instructions for first-time installation and use of the product, and the secure updates the manufacturer makes available for the product, are available.

Assessment activities

- 1) Follow the instructions to install and use the product for the first time, and verify that the secure update mechanism operates by default before or during first use and applies the secure updates the manufacturer makes available.
- 2) Locate and exercise the product's mechanism for opting out of automatic security updates, which should be available both at first use and during subsequent use.

- 3) Opt out of automatic security updates using that mechanism, then follow the instructions to install and use the product for the first time.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) The secure update mechanism does not operate by default before or during first use, or does not apply the available secure updates.
- 2) The product provides no mechanism allowing an authorised user to opt out of automatic security updates, or the mechanism is not clear and easy to use.
- 3) After an authorised user opts out of automatic security updates, the product does not provide, before or during first use, a mechanism to inform the user to initiate or postpone the update.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) The secure update mechanism operates by default before or during first use and applies the available secure updates.
- 2) The product provides a clear and easy-to-use mechanism allowing an authorised user to opt out of automatic security updates.
- 3) After an authorised user opts out of automatic security updates, the product provides, before or during first use, a mechanism to inform the user to initiate or postpone the update.

Assessment evidence

- 1) Record of the first-use update behaviour and the updates applied.
- 2) The mechanism for opting out of automatic security updates and its documentation.
- 3) Record of the first-use behaviour after opting out, showing the mechanism to inform the user to initiate or postpone the update.

6.5.3 [AC-SCUE] Assessment criteria: Security updates provided by the operational environment

Assessment reference

Mitigation [MI-SCUE](#).

Assessment objective

Confirm that the product can receive and apply secure updates provided by the operational environment, and that the manufacturer documents the requirements the operational environment shall satisfy to deliver them.

Assessment activities

- 1) Assess the documentation provided with the product.
- 2) Through the operational-environment update path documented by the manufacturer, provide a secure update whose authenticity and integrity can be verified, and confirm the product receives and applies it; then provide an update whose authenticity or integrity cannot be verified, and confirm the product rejects it in accordance with MI-SUVI.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Documentation does not describe requirements for the secure updates provided by the operational environment.
- 2) The product does not receive and apply the update whose authenticity and integrity are verified, or accepts an update whose authenticity or integrity cannot be verified.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Documentation describes requirements for the secure updates provided by the operational environment.
- 2) The product receives and applies the update whose authenticity and integrity are verified, and rejects the update whose authenticity or integrity cannot be verified.

Assessment evidence

- 1) Documentation and analysis of completeness.
- 2) Record of the updates provided through the operational-environment update path and the product's acceptance or rejection of each.

6.5.4 [AC-SUVI] Assessment criteria: Update authenticity and integrity verification

Assessment reference

Mitigation [MI-SUVI](#).

Assessment objective

Verify that the product rejects update packages whose authenticity or integrity cannot be verified before installation.

Assessment preparation

- 1) Identify, from the documentation, each update path of the product and the mechanism by which the authenticity and integrity of update packages are verified for that path.

Assessment activities

- 1) For each update path, identify the verification mechanism it uses, and attempt to deliver an update that is not authentic or not integral by that mechanism, for example a tampered payload, an unsigned or wrongly-signed package, delivery from an unauthorised source, or delivery over an unauthenticated channel, and observe whether the product installs it. Additionally attempt to bypass or disable the verification for that update path, for example through a debug flag, an API override, a boot parameter, or an unmanaged update path, and observe whether the verification remains enforced.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) For any update path, an update that is not authentic or not integral is installed, or the verification can be bypassed without user consent.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) For every update path, an update that is not authentic or not integral is not installed, by whichever verification mechanism applies to that update path, and the verification cannot be bypassed without user consent.

Assessment evidence

- 1) Documentation of the update paths and their verification mechanisms, and test results showing that updates which are not authentic or not integral are not installed and that the verification cannot be bypassed without user consent.

6.5.5 [AC-SUDP] Assessment criteria: Anti-rollback protection

Assessment reference

Mitigation [MI-SUDP](#).

Assessment objective

Verify that the product prevents the unauthorised installation of an earlier software version.

Assessment preparation

- 1) Identify the current software version of the product and obtain an authorised update package for an earlier version.

Assessment activities

- 1) Attempt to install the earlier version on the product without authorisation and observe whether the product installs it.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) The product installs the earlier version without authorisation.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) The product prevents unauthorised installation of the earlier version.

Assessment evidence

- 1) Test results showing the product prevents the unauthorised installation of an earlier version.

6.5.6 [AC-SUAR] Assessment criteria: Authorised rollback

Assessment reference

Mitigation [MI-SUAR](#).

Assessment objective

Verify that intentional, user-initiated rollback to an earlier software version requires explicit authorisation, and that automated recovery mechanisms are treated as recovery actions exempt from that requirement.

Assessment preparation

- 1) Confirm from the documentation whether the product supports intentional, user-initiated rollback and identify the authorisation required.
- 2) Identify any automated recovery mechanisms that revert to the immediately preceding operational state following a failed update or boot failure.

Assessment activities

- 1) Attempt to perform an intentional, user-initiated rollback to an earlier version without the required authorisation, then repeat with the required authorisation.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) The product performs an intentional, user-initiated rollback without the required authorisation.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) The product performs an intentional, user-initiated rollback only when the required authorisation is provided.

Assessment evidence

- 1) Test results showing intentional, user-initiated rollback is performed only with the required authorisation, and documentation distinguishing automated recovery from rollback.

6.6 TR-AUTH: Authentication and access control

6.6.1 [AC-RAUT] Assessment criteria: Authenticate the remote data processing solution and validate its interactions at the RDPS boundary

Assessment reference

Mitigation [MI-RAUT](#).

Assessment objective

Authenticate the remote data processing solution and verify the authenticity, integrity, and freshness of interactions received across the RDPS boundary.

Assessment preparation

- 1) Documentation describing the authentication mechanism used for communication with each remote data processing solution is available.
- 2) Documentation describing the mechanisms used to verify the authenticity and integrity of received interactions and to detect replayed or stale interactions is available.
- 3) The product is in operational state with remote data processing solution connectivity configured.

Assessment activities

- 1) Review the documentation to identify the authentication mechanism used by the product to authenticate the remote data processing solution before transmitting data or acting upon received interactions.
- 2) Substitute the remote data processing solution with an endpoint that does not satisfy authentication. Observe whether the product transmits data to, or acts upon interactions from, the substituted endpoint.
- 3) Present to the product an interaction that carries the identity of the authenticated remote data processing solution but whose content has been modified after it was produced. Observe whether the product acts upon the modified interaction.
- 4) Replay to the product an interaction that was previously valid, in a context where replay or reuse could affect the secure operation of a product function. Observe whether the product acts upon the replayed interaction.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Documentation does not describe the authentication mechanism used by the product to authenticate the remote data processing solution.
- 2) The product transmits data to, or acts upon interactions from, an endpoint that does not satisfy authentication.
- 3) The product acts upon the modified interaction.
- 4) The product acts upon the replayed or stale interaction.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Documentation describes the authentication mechanism used by the product to authenticate the remote data processing solution.

- 2) The product does not transmit data to, or act upon interactions from, an endpoint that does not satisfy authentication.
- 3) The product rejects the modified interaction and does not act upon it.
- 4) The product detects and rejects the replayed or stale interaction.

Assessment evidence

- 1) Documentation describing the authentication mechanism used by the product.
- 2) Test results showing the product authenticates the remote data processing solution before transmitting data or acting upon interactions.
- 3) Test results showing the product rejects interactions whose integrity is not intact.
- 4) Test results showing the product detects and rejects replayed or stale interactions.

6.6.2 [AC-AUTH-1] Assessment criteria: Require user authentication on interfaces providing access to the operating system

Assessment reference

Mitigation [MI-AUTH-1](#).

Assessment objective

Require user authentication by default on interfaces providing access to the operating system.

Assessment preparation

- 1) List all interfaces through which the operating system exposes access to operating system resources or functions to users, including login interfaces (such as PAM-based text and graphical logins, remote shell daemons, console interfaces) and programmatic interfaces requiring user context.
- 2) Documentation describing the user authentication mechanism applied to each interface by default, the set of functions the interface exposes, and any interfaces deliberately not requiring user authentication by default together with the justification for the exception.

Assessment activities

- 1) Review the documentation to verify that every interface providing user access to operating system resources or functions either requires user authentication by default or is documented as deliberately unauthenticated with justification.
- 2) For each documented authenticated interface, attempt to access operating system resources or functions through that interface without presenting valid user authentication. Verify that access is denied.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Any interface providing user access neither requires user authentication by default nor is documented as deliberately unauthenticated with justification.
- 2) Any documented authenticated interface grants access without valid user authentication.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Every interface either requires user authentication by default or is documented as deliberately unauthenticated with justification.
- 2) Every documented authenticated interface denies access without valid user authentication.

Assessment evidence

- 1) Documentation listing every interface, its user authentication mechanism, and any unauthenticated-interface justifications.
- 2) Test results showing that each authenticated interface denies access without user authentication.

6.6.3 [AC-AUTH-2] Assessment criteria: Require privilege or authorisation on interfaces providing access to the operating system

Assessment reference

Mitigation [MI-AUTH-2](#).

Assessment objective

Ensure that interfaces providing access to operating system resources or functions not intended for unauthenticated use require the account to hold the appropriate privilege or authorisation.

Assessment preparation

- 1) List all interfaces through which the operating system exposes access to operating system resources or functions not intended for unauthenticated use, including administrative login interfaces, privilege-elevation utilities, management APIs, administrative tooling, and remote management interfaces provided by the operating system.
- 2) Documentation describing the privilege or authorisation required to invoke each interface, the set of functions the interface exposes, and any interfaces deliberately not requiring privilege or authorisation together with the justification for the exception.

Assessment activities

- 1) Review the documentation to verify that every interface providing access to operating system resources or functions not intended for unauthenticated use either requires the account to hold the appropriate privilege or authorisation or is documented as deliberately unauthenticated with justification.
- 2) For each documented interface, attempt to invoke it as an unauthorised account, without holding the appropriate privilege or authorisation. Verify that access is denied.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Any interface providing access to operating system resources or functions not intended for unauthenticated use neither requires the appropriate privilege or authorisation nor is documented as deliberately unauthenticated with justification.
- 2) Any documented interface grants access to an unauthorised account that does not hold the appropriate privilege or authorisation.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Every interface either requires the account to hold the appropriate privilege or authorisation or is documented as deliberately unauthenticated with justification.
- 2) Every documented interface denies access to an unauthorised account that does not hold the appropriate privilege or authorisation.

Assessment evidence

- 1) Documentation listing every such interface, the privilege or authorisation it requires, and any unauthenticated-interface justifications.
- 2) Test results showing that each interface denies access to an unauthorised account that does not hold the appropriate privilege or authorisation.

6.6.4 [AC-LCKT] Assessment criteria: Authentication failure protection

Assessment reference

Mitigation [MI-LCKT](#).

Assessment objective

Prevent brute-force attacks against operating system authentication interfaces.

Assessment preparation

- 1) Documentation describing, for each authentication interface, the authentication failure protection that the operating system enforces by default.

Assessment activities

- 1) Review the documentation to verify that every authentication interface is associated with a documented authentication failure protection mechanism.
- 2) For each authentication interface, with the product in its default configuration, perform repeated authentication attempts with invalid credentials, and verify that the interface enforces the documented authentication failure protection.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Any authentication interface has no documented authentication failure protection mechanism.
- 2) Any authentication interface does not enforce the documented authentication failure protection by default under repeated invalid authentication attempts.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Every authentication interface is associated with a documented authentication failure protection mechanism.
- 2) Every authentication interface enforces the documented authentication failure protection by default under repeated invalid authentication attempts.

Assessment evidence

- 1) Documentation of the authentication failure protection enforced per authentication interface.
- 2) Test results showing authentication failure protection is enforced per interface.

6.6.5 [AC-CRED] Assessment criteria: Protect stored critical security parameters and enforce credential strength

Assessment reference

Mitigation [MI-CRED](#).

Assessment objective

Protect stored credentials and critical security parameters and enforce minimum credential strength on accepted credentials.

Assessment preparation

- 1) List all categories of critical security parameters stored by the operating system, including credential hashes or equivalent verification material, cryptographic keys managed by kernel keyrings or operating system key stores, certificate private keys, and trust anchors.

- 2) Documentation describing the protection mechanism applied to each category of stored critical security parameter, conforming to TR-CRYP, and the minimum credential strength requirements enforced by default by each authentication interface.

Assessment activities

- 1) Review the documentation to verify that every category of stored critical security parameter is associated with a documented protection mechanism conforming to TR-CRYP, and that every authentication interface is associated with a documented minimum credential strength requirement.
- 2) Inspect the storage representation of each category of critical security parameter on the operating system and verify that the documented protection mechanism is applied.
- 3) For each authentication interface, with the product in its default configuration, attempt to configure a credential that does not meet the documented minimum strength requirement. Verify that the operating system rejects the attempt.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Any category of stored critical security parameter lacks a documented protection mechanism conforming to TR-CRYP, or any authentication interface lacks a documented minimum credential strength requirement.
- 2) The documented protection mechanism is not applied to at least one category of stored critical security parameter.
- 3) Any authentication interface accepts, by default, a credential that does not meet the documented minimum strength requirement.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Every category of stored critical security parameter is associated with a documented protection mechanism conforming to TR-CRYP, and every authentication interface is associated with a documented minimum credential strength requirement.
- 2) The documented protection mechanism is applied to every category of stored critical security parameter.
- 3) Every authentication interface rejects, by default, credentials that do not meet the documented minimum strength requirement.

Assessment evidence

- 1) Documentation listing categories of stored critical security parameters with their protection mechanisms, and the minimum credential strength requirements per authentication interface.
- 2) Test results showing the storage representation of each category of critical security parameter and the protection mechanism applied.
- 3) Test results showing rejection of low-strength credentials per authentication interface.

6.6.6 [AC-ACCS] Assessment criteria: Access control enforcement on operating system resources and functions

Assessment reference

Mitigation [MI-ACCS](#).

Assessment objective

Enforce access control on operating system resources and functions.

Assessment preparation

- 1) Documentation describing the access control model used by the operating system, including the mechanism (such as discretionary access control through filesystem permissions, POSIX capabilities, mandatory access control frameworks, role-based access control, or compile-time fixed access rules), the protected resource categories, and the authorisation attributes considered when granting access.

Assessment activities

- 1) Review the documentation to verify that the access control model is described, the protected resource categories are enumerated, and the authorisation attributes are defined.
- 2) For each protected resource category, attempt access from a subject that is authorised according to the documented model and verify the access succeeds. Attempt access from a subject that is not authorised according to the documented model and verify the access is denied.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Documentation does not describe the access control model, the protected resource categories, or the authorisation attributes.
- 2) Any authorised subject is denied access or any unauthorised subject is permitted access for any protected resource category.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Documentation describes the access control model, the protected resource categories, and the authorisation attributes.
- 2) Authorised subjects are permitted access and unauthorised subjects are denied access for every protected resource category.

Assessment evidence

- 1) Documentation describing the access control model, protected resource categories, and authorisation attributes.
- 2) Test results showing access outcomes for authorised and unauthorised subjects per protected resource category.

6.6.7 [AC-PRIV] Assessment criteria: Privilege separation and restriction

Assessment reference

Mitigation [MI-PRIV](#).

Assessment objective

Enforce privilege separation, restrict subjects to their assigned privilege level, and deny in-session privilege escalation without re-authentication or other documented authorisation, on operating systems supporting multiple privilege levels.

Assessment preparation

- 1) Documentation describing the privilege-level model of the operating system, including the distinct privilege levels (such as kernel and user mode, POSIX effective user identifiers, POSIX capabilities sets, or ring-based privilege hierarchies), the operations permitted at each privilege level, the transitions between privilege levels, and the authorisation required for privilege escalation within an active session.

Assessment activities

- 1) Review the documentation to verify that the distinct privilege levels, the operations permitted at each privilege level, the transitions between privilege levels, and the authorisation required for privilege escalation are described.

- 2) For each privilege level, attempt to perform operations not permitted at that privilege level from a subject executing at that privilege level. Verify that the operating system denies the operation.
- 3) In an active session, attempt to escalate to a higher privilege level without providing the documented authorisation, and verify that the escalation is denied.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Documentation does not describe the distinct privilege levels, the operations permitted at each privilege level, the transitions between privilege levels, or the authorisation required for privilege escalation.
- 2) Any subject can perform an operation not permitted at its assigned privilege level.
- 3) Privilege escalation within an active session succeeds without the documented authorisation.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Documentation describes the distinct privilege levels, the operations permitted at each privilege level, the transitions between privilege levels, and the authorisation required for privilege escalation.
- 2) Every subject is restricted to the operations permitted at its assigned privilege level.
- 3) Privilege escalation within an active session is denied without the documented authorisation.

Assessment evidence

- 1) Documentation describing the privilege-level model.
- 2) Test results showing denial of unauthorised operations per privilege level.
- 3) Test results showing that in-session privilege escalation is denied without the documented authorisation.

6.6.8 [AC-SESS] Assessment criteria: Interactive session lifecycle controls

Assessment reference

Mitigation [MI-SESS](#).

Assessment objective

Enforce lifecycle controls on authenticated interactive sessions.

Assessment preparation

- 1) Documentation describing the interactive session model of the operating system, including the events that trigger session invalidation, and describing any sessions or security tokens derived from the interactive session that remain valid beyond the termination event.

Assessment activities

- 1) Review the documentation to verify that the interactive session model and the session-invalidation triggers are described.
- 2) Establish an authenticated interactive session, perform session logout or termination, and verify that the interactive session is invalidated upon logout or termination according to the product's documented session model.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Documentation does not describe the interactive session model or the session-invalidation triggers.

- 2) The interactive session is not invalidated upon logout or termination according to the product's documented session model.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Documentation describes the interactive session model and the session-invalidation triggers.
- 2) The interactive session is invalidated upon logout or termination according to the product's documented session model.

Assessment evidence

- 1) Documentation describing the interactive session lifecycle.
- 2) Test results showing session invalidation upon logout or termination according to the product's documented session model.

6.6.9 [AC-ACSD] Assessment criteria: Access control for stored data

Assessment reference

Mitigation [MI-ACSD](#).

Assessment objective

Protect stored data from unauthorised access and modification.

Assessment preparation

- 1) List the types of data stored on the product that are protected from unauthorised access or modification, and for each the mechanism the manufacturer documents, whether access controls and privilege separation at the operating system level, another documented mechanism, or a documented formal proof, and the methods of accessing or modifying that data available to an attacker based on the risk assessment.

Assessment activities

- 1) For each type of stored data and each access method, determine the mechanism used to prevent unauthorised access and attempt to read the data without authorisation.
- 2) For each type of stored data, where the mechanism is enforced at runtime, attempt to modify the data without authorisation.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) At least one attempt to read the stored data without authorisation succeeds, or the mechanism preventing unauthorised access for a type of stored data is not documented.
- 2) At least one attempt to modify the stored data without authorisation succeeds, or the mechanism preventing unauthorised modification for a type of stored data is not documented.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) The product prevents unauthorised access to the stored data, whether by access controls and privilege separation, by another documented mechanism, or by a documented formal proof, and all attempts to read the data without authorisation fail.
- 2) The product prevents unauthorised modification of the stored data, whether by access controls and privilege separation, by another documented mechanism, or by a documented formal proof, and all attempts to modify the data without authorisation fail.

Assessment evidence

- 1) Documentation of the access-protection mechanism per data type, and results of attempts to read the data without authorisation.

- 2) Documentation of the modification-protection mechanism per data type, and results of attempts to modify the data without authorisation.

NOTE: Guidance: Stored data may be protected from unauthorised access or modification by the environment, permissions, encryption, salting and hashing, offline storage, hardware-backed secrets, duplication, backups, or checksums; where cryptographic mechanisms are used, the requirements of TR-CRYP apply. A formal proof, in a formal verification tool, that the product protects stored data from unauthorised access or modification is an acceptable alternative means of demonstrating conformance with this mitigation, provided the tool selection and configuration criteria, the formal definition of confidentiality and integrity, and the formal argument applying it to a formalisation of the product's source code are documented.

6.7 TR-CDST: Confidentiality of data stored on the product

6.7.1 [AC-ENST] Assessment criteria: Cryptographic encryption of stored data

Assessment reference

Mitigation [MI-ENST](#).

Assessment objective

Verify the product provides, by default, the option to protect the confidentiality of stored user data at rest using a cryptographic encryption mechanism conforming to TR-CRYP.

Assessment preparation

- 1) Obtain manufacturer documentation describing the cryptographic encryption mechanism the product provides by default as an option for stored user data, including the algorithm used, the keying material or key-derivation mechanism, and the hardware-backed or software-backed key-storage mechanism used to protect the encryption keys.

Assessment activities

- 1) Review the documentation to verify that the product provides, by default, an option to protect the confidentiality of stored user data at rest using a cryptographic encryption mechanism conforming to TR-CRYP.
- 2) Starting from the product in its default configuration, enable the documented encryption option and inspect the operating system in its operational state, examining the raw storage representation of the stored user data. Verify that, when the option is enabled, the documented cryptographic encryption mechanism is applied and that the algorithm in use matches the documentation and conforms to TR-CRYP.
- 3) With the encryption option enabled, attempt to recover the stored content from the raw storage representation without access to the keying material. Verify that the content cannot be recovered.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Documentation does not describe an option available in the product's default configuration to protect stored user data at rest using a cryptographic encryption mechanism, or the documented mechanism does not conform to TR-CRYP.
- 2) The encryption option is not available in the default configuration or cannot be enabled, or when enabled the cryptographic encryption mechanism is not applied or the algorithm in use does not conform to TR-CRYP.
- 3) When the encryption option is enabled, the stored content can be recovered from the raw storage representation without access to the keying material.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Documentation describes an option, available in the product's default configuration, to protect stored user data at rest using a cryptographic encryption mechanism conforming to TR-CRYP.
- 2) The encryption option is available in the default configuration and can be enabled and, when enabled, the cryptographic encryption mechanism is applied to the stored user data and the algorithm in use conforms to TR-CRYP.
- 3) When the encryption option is enabled, the stored content cannot be recovered from the raw storage representation without access to the keying material.

Assessment evidence

- 1) Documentation describing the option to encrypt stored user data and the cryptographic encryption mechanism it uses.
- 2) Test results showing the raw storage representation of stored user data with the encryption option enabled and the cryptographic encryption mechanism applied to it.
- 3) Test results showing that, with the encryption option enabled, stored content cannot be recovered from the raw storage representation without access to the keying material.

6.8 TR-CDTX: Confidentiality of data transmitted by the product

6.8.1 [AC-CDTX] Assessment criteria: Protect confidentiality of user data transmitted by the product

Assessment reference

Mitigation [MI-CDTX](#).

Assessment objective

Protect, by default, user data transmitted by the product from unauthorised access.

Assessment preparation

- 1) List all types of data that may be transmitted on the product that should not be readable without authorisation, the confidentiality mechanism documented by the manufacturer as applied by default for each type, all methods of accessing that data available to an attacker based on the risk assessment, and the authorisation methods documented by the manufacturer for each access method.

Assessment activities

- 1) With the product in its default configuration, for each type of data and each access mechanism, determine the method of ensuring confidentiality used, and attempt to read the data without authorisation.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Any method of ensuring confidentiality applied by default does not match the type of the data transmitted, or any attempt to read confidential data without authorisation succeeds.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) All methods of ensuring confidentiality applied by default match the type of the data transmitted, and all the attempts to read confidential data without authorisation fail.

Assessment evidence

- 1) Logs of determination of type of data and method of confidentiality and attempts to read confidential data without authorisation.

NOTE: Guidance: Data transmitted may be protected by the environment or by encryption. Where encryption is used, the requirements of TR-CRYP apply.

6.8.2 [AC-RRDC] Assessment criteria: Document residual risk to confidentiality of data transmitted

Assessment reference

Mitigation [MI-RRDC](#).

Assessment objective

Confirm that the product is accompanied by documentation describing the residual risk to the confidentiality of transmitted user data and the actions that can be taken to mitigate it.

Assessment activities

- 1) Examine the documentation.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Transfer of risk is not documented, or the documentation does not state the residual risks or the user mitigations.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Transfer of risk is documented, including the residual risks accepted by the user and the actions the user can take to mitigate them.

Assessment evidence

- 1) Documentation, analysis of documentation.

6.8.3 [AC-ENTX] Assessment criteria: Cryptographic encryption of transmitted data

Assessment reference

Mitigation [MI-ENTX](#).

Assessment objective

Protect the confidentiality of transmitted user data, by default, using a cryptographic encryption mechanism.

Assessment preparation

- 1) List all categories of user data transmitted by the operating system, including data transmitted through operating-system-provided network protocols (such as TLS, SSH, IPsec, and VPN client or server implementations), remote administration interfaces, remote filesystem and file sharing protocols, remote logging and audit streams, remote management or telemetry channels, and channels exchanging credentials, cryptographic keys, or other critical security parameters.
- 2) Documentation describing the cryptographic encryption mechanism applied by default to each category of transmitted user data is available, including the algorithm used, the keying material or session key used, and the key establishment or negotiation mechanism.

Assessment activities

- 1) Review the documentation to verify that every category of transmitted user data is associated with a documented cryptographic encryption mechanism conforming to TR-CRYP.

- 2) Inspect the operating system in its default configuration while it transmits data in each documented category. Capture the transmitted data on the network and verify that the documented cryptographic encryption mechanism is applied and that the algorithm in use matches the documentation and conforms to TR-CRYP.
- 3) For each category of transmitted user data, attempt to recover the transmitted content from a passive network capture without access to the keying material. Verify that the content cannot be recovered.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Documentation does not associate every category of transmitted user data with a cryptographic encryption mechanism, or any documented mechanism does not conform to TR-CRYP.
- 2) The cryptographic encryption mechanism is not applied by default to at least one category of transmitted user data, or the algorithm in use does not conform to TR-CRYP.
- 3) The transmitted content can be recovered from the network capture without access to the keying material.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Documentation associates every category of transmitted user data with a cryptographic encryption mechanism conforming to TR-CRYP.
- 2) The cryptographic encryption mechanism is applied by default to every category of transmitted user data and the algorithm in use conforms to TR-CRYP.
- 3) The transmitted content cannot be recovered from the network capture without access to the keying material.

Assessment evidence

- 1) Documentation listing every category of transmitted user data and the cryptographic encryption mechanism applied to each.
- 2) Test results from network traffic captures showing the cryptographic encryption mechanism applied to each category of transmitted user data and the algorithm in use.
- 3) Test results showing that transmitted content cannot be recovered from the network capture without access to the keying material.

6.9 TR-CRYP: Encryption

6.9.1 [AC-CRYP] Assessment criteria: Conformance to Annex K

Assessment reference

Mitigation [MI-CRYP](#).

Assessment objective

Confirm that the product conforms to Annex K.

Assessment preparation

- 1) Documentation describing the cryptographic mechanisms used in the product's default configuration, as required by Annex K.

Assessment activities

- 1) Assess the product against Annex K, applying the assessment of the product's cryptographic configuration in clause K.1.2 and the assessment of crypto-agility in clause K.2.2.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) The product does not conform to Annex K.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) The product conforms to Annex K.

Assessment evidence

- 1) The evidence required by the assessments in Annex K.

6.10 TR-IDST: Integrity of data stored on the product

6.10.1 [AC-DCST] Assessment criteria: Detect corruption of stored data

Assessment reference

Mitigation [MI-DCST](#).

Assessment objective

Detect corruption of stored data.

Assessment preparation

- 1) List the types of data stored on the product for which the product provides the capability to detect corruption, and the corruption-detection mechanism the manufacturer documents for each.

Assessment activities

- 1) For each type of stored data and its corruption-detection mechanism, enable the mechanism, introduce corruption that it is designed to detect, and verify that the product detects it.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) The product does not provide the capability to detect corruption of at least one type of stored data, or does not detect the introduced corruption.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) The product provides the capability to detect corruption of each type of stored data and detects the introduced corruption.

Assessment evidence

- 1) Documentation of the corruption-detection capability per data type, and results showing detection of introduced corruption.

6.10.2 [AC-INTS] Assessment criteria: Cryptographic integrity protection of stored data

Assessment reference

Mitigation [MI-INTS](#).

Assessment objective

Verify that cryptographic mechanisms used for integrity protection of stored data conform to TR-CRYP.

Assessment preparation

- 1) List the categories of stored data for which the product uses cryptographic integrity mechanisms, and for each the cryptographic mechanism and algorithm documented by the manufacturer.

Assessment activities

- 1) Review the documentation to verify that each cryptographic integrity mechanism used for stored data conforms to TR-CRYP.
- 2) Inspect the operating system in its operational state and verify that the cryptographic integrity mechanisms in use for stored data match the documentation and conform to TR-CRYP.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Any cryptographic integrity mechanism used for stored data does not conform to TR-CRYP.
- 2) A cryptographic integrity mechanism in use for stored data does not match the documentation or does not conform to TR-CRYP.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Every cryptographic integrity mechanism used for stored data conforms to TR-CRYP.
- 2) The cryptographic integrity mechanisms in use for stored data match the documentation and conform to TR-CRYP.

Assessment evidence

- 1) Documentation of the cryptographic integrity mechanisms and algorithms used for stored data.
- 2) Results showing the cryptographic integrity mechanisms in use for stored data and their conformance to TR-CRYP.

6.11 TR-IDTX: Integrity of data transmitted by the product

6.11.1 [AC-INTT] Assessment criteria: Cryptographic integrity protection of transmitted data

Assessment reference

Mitigation [MI-INTT](#).

Assessment objective

Protect the integrity of transmitted user data, by default, using a cryptographic integrity mechanism.

Assessment preparation

- 1) List all categories of user data transmitted by the operating system, including data transmitted through operating-system-provided network protocols (such as TLS, SSH, IPsec, and DNSSEC client or server implementations), remote administration interfaces, remote filesystem and file sharing protocols, remote logging and audit streams, and remote management or telemetry channels.
- 2) Documentation describing the cryptographic integrity mechanism applied by default to each category of transmitted user data is available, including the algorithm used, the keying material or signing key used, and the verification behaviour applied by the receiver.

Assessment activities

- 1) Review the documentation to verify that every category of transmitted user data is associated with a documented cryptographic integrity mechanism conforming to TR-CRYP.

- 2) Inspect the operating system in its default configuration while it transmits data in each documented category. Confirm that the documented cryptographic integrity mechanism is applied to the transmitted data and that the cryptographic algorithm in use matches the documentation and conforms to TR-CRYP.
- 3) For each category of transmitted user data, modify the data in transit between the product and the receiving endpoint and verify that the receiving endpoint rejects the modified data on the basis of the cryptographic integrity mechanism.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Documentation does not associate every category of transmitted user data with a cryptographic integrity mechanism, or any documented mechanism does not conform to TR-CRYP.
- 2) The cryptographic integrity mechanism is not applied by default to at least one category of transmitted user data, or the algorithm in use does not conform to TR-CRYP.
- 3) The receiving endpoint accepts at least one modification of the transmitted data.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Documentation associates every category of transmitted user data with a cryptographic integrity mechanism conforming to TR-CRYP.
- 2) The cryptographic integrity mechanism is applied by default to every category of transmitted user data and the algorithm in use conforms to TR-CRYP.
- 3) The receiving endpoint rejects every modification of the transmitted data.

Assessment evidence

- 1) Documentation listing every category of transmitted user data and the cryptographic integrity mechanism applied to each.
- 2) Test results showing the cryptographic integrity mechanism applied to each category of transmitted user data and the algorithm in use.
- 3) Test results showing that modified transmitted data is rejected by the receiving endpoint.

6.12 TR-DMIN: Data Minimisation

6.12.1 [AC-DJST] Assessment criteria: Document and justify processed data

Assessment reference

Mitigation [MI-DJST](#).

Assessment objective

Document and justify every source of user data processed by the product in its secure-by-default configuration.

Assessment preparation

- 1) Obtain the manufacturer's documentation of user data processed, stating for each source of user data, where and when it is processed and the rationale that the processing is adequate, relevant and limited to what is necessary.
- 2) Enumerate the product's sources of user data. For each source of user data, identify a method to detect whether the product, in its secure-by-default configuration, is processing user data from that source.

Assessment activities

- 1) With the product in its secure-by-default configuration, using the list of sources of user data, and the method to detect whether the product is processing user data from that source, list all sources of user data processed. Compare to the documented list.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Any source of user data processed in the secure-by-default configuration is not documented or lacks rationale.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) All sources of user data processed in the secure-by-default configuration are documented, including rationale.

Assessment evidence

- 1) List of sources of user data, documentation of each source of user data, list of sources of user data processed, connection between each discovered source of processed user data to its documentation.

6.13 TR-AVAI: Availability

6.13.1 [AC-AVNT] Assessment criteria: Availability of network functions

Assessment reference

Mitigation [MI-AVNT](#).

Assessment objective

Protect availability of network functions.

Assessment preparation

- 1) Obtain the manufacturer's documented list of essential and core network functions and the denial-of-service mitigations applied to each.
- 2) List all network functions and identify essential and core network functions.
- 3) For each documented mitigation, derive a representative load sufficient to exercise the mitigation.

Assessment activities

- 1) For each essential or core network function, examine the documentation for the denial-of-service mitigations the manufacturer has documented.
- 2) For each essential or core network function, subject it to a representative denial-of-service load that exercises the documented denial-of-service mitigations, and observe whether the function remains available.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Any essential or core network function is not documented, or any mitigation is not documented by the manufacturer.
- 2) Any essential or core network function does not remain available under the representative denial-of-service load.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Every essential or core network function is documented and the mitigations are documented by the manufacturer.

- 2) Every essential or core network function remains available under the representative denial-of-service load.

Assessment evidence

- 1) All configuration files for network functions, documentation of network functions and the ways to mitigate a denial-of-service attack on it, internal lists of listening ports, results of an external port scan.
- 2) Record of the denial-of-service load applied to each essential or core network function and the observed availability of the function under load.

6.13.2 [AC-CSFR] Assessment criteria: Detection and recovery from critical service failures

Assessment reference

Mitigation [MI-CSFR](#).

Assessment objective

Detect and recover from failures of documented critical services.

Assessment preparation

- 1) Obtain the manufacturer's documentation of the services it documents as critical services and the conditions that constitute a failure of each.

Assessment activities

- 1) Cause a failure of each documented critical service to occur and observe whether the product detects the failure and recovers.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) For at least one documented critical service, the product does not detect the failure or does not recover.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) For each documented critical service, the product detects the failure and recovers.

Assessment evidence

- 1) Documentation of the critical services and the failure conditions, and log messages or records showing the product's detection and recovery for each.

6.13.3 [AC-RLIM] Assessment criteria: Resource usage limits and exhaustion fallback

Assessment reference

Mitigation [MI-RLIM](#).

Assessment objective

Constrain memory and resource usage, and preserve the availability of the functions documented as essential or core functions when documented resource-exhaustion thresholds are reached.

Assessment preparation

- 1) Identify, from the documentation, the configurable mechanisms the product provides to constrain memory and resource usage for processes and for network connections, and the fallback mechanism it applies, including the processes or resource consumers the manufacturer documents as subject to the fallback, the functions the manufacturer documents as essential or core functions, and the documented resource-exhaustion thresholds.

Assessment activities

- 1) Examine the documentation and the product to verify that it provides configurable mechanisms allowing an authorised user to constrain memory and resource usage for processes and for network connections, then configure a constraint and attempt to exceed it.
- 2) Drive the product to the documented resource-exhaustion thresholds and observe whether the fallback mechanism constrains the processes or resource consumers documented as subject to the fallback and the product preserves the availability of the functions documented as essential or core functions.
- 3) Where the product supports concurrent users, verify that the configured constraints prevent one user's resource exhaustion from denying service to another, assessed in the configuration documented by the manufacturer for the applicable use case.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) The product does not provide configurable mechanisms to constrain memory and resource usage for processes or for network connections, or a configured constraint is not enforced.
- 2) When the documented resource-exhaustion thresholds are reached, the fallback mechanism does not constrain the processes or resource consumers documented as subject to the fallback, or the product does not preserve the availability of the functions documented as essential or core functions.
- 3) A user can cause sustained denial of service to another user through resource exhaustion under the documented configuration.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) The product provides configurable mechanisms that allow an authorised user to constrain memory and resource usage for processes and for network connections, and the configured constraints are enforced.
- 2) When the documented resource-exhaustion thresholds are reached, the fallback mechanism constrains the processes or resource consumers documented as subject to the fallback and the product preserves the availability of the functions documented as essential or core functions.
- 3) A user cannot cause sustained denial of service to another user through resource exhaustion under the documented configuration.

Assessment evidence

- 1) Documentation of the configurable constraint mechanisms, and test results showing a configured constraint is enforced.
- 2) Test results showing the fallback mechanism's behaviour when the documented resource-exhaustion thresholds are reached and the preservation of the availability of the functions documented as essential or core functions.
- 3) Test results showing that one user's resource exhaustion does not deny service to another user under the documented configuration.

6.13.4 [AC-PRIO] Assessment criteria: Workload prioritisation**Assessment reference**

Mitigation [MI-PRIO](#).

Assessment objective

Support priority-based scheduling of processes and network traffic, and prioritise the functions documented as core operating system functions when documented resource-contention thresholds are reached.

Assessment preparation

- 1) Identify, from the documentation, the scheduling priority mechanisms the product provides for processes and for network traffic, and how it prioritises the functions documented as core operating system functions when documented resource-contention thresholds are reached.

Assessment activities

- 1) Configure different priority levels for processes and for network traffic, generate contended load, and observe whether higher-priority work is scheduled preferentially.
- 2) Generate load to the documented resource-contention thresholds with lower-priority workloads present, and observe whether the product prioritises the functions documented as core operating system functions over the lower-priority workloads.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) The product does not schedule processes or network traffic according to the configured priority levels.
- 2) When the documented resource-contention thresholds are reached, the product does not prioritise the functions documented as core operating system functions over lower-priority workloads.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) The product schedules processes and network traffic according to the configured priority levels.
- 2) When the documented resource-contention thresholds are reached, the product prioritises the functions documented as core operating system functions over lower-priority workloads.

Assessment evidence

- 1) Documentation of the scheduling priority mechanisms, and test results showing prioritised scheduling under contended load.
- 2) Test results showing the functions documented as core operating system functions are prioritised over lower-priority workloads when the documented resource-contention thresholds are reached.

6.13.5 [AC-RRDS] Assessment criteria: Document residual risk of denial of service

Assessment reference

Mitigation [MI-RRDS](#).

Assessment objective

Document residual risk of denial of service.

Assessment activities

- 1) Assess the documentation provided with the product.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Documentation does not describe the residual risk of denial of service, or does not describe the measures the operational environment can provide to mitigate it.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Documentation describes the residual risk of denial of service and the measures the operational environment can provide to mitigate it.

Assessment evidence

- 1) Documentation and analysis of completeness.

6.13.6 [AC-RTDL] Assessment criteria: Real-time deadline preservation**Assessment reference**

Mitigation [MI-RTDL](#).

Assessment objective

Ensure security mechanisms do not compromise real-time availability.

Assessment preparation

- 1) List all real-time tasks and their documented worst-case execution times.

Assessment activities

- 1) Run documented real-time tasks concurrently with security-relevant operations (e.g. MPU fault handling, integrity verification, cryptographic operations). Measure the worst-case execution time of each real-time task under this load.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Any real-time task exceeds its documented worst-case execution time.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Every real-time task completes within its documented worst-case execution time.

Assessment evidence

- 1) Timing measurements, task execution logs, documented worst-case execution time specifications.

6.13.7 [AC-RTRY] Assessment criteria: Retry and degraded behaviour on unavailability of the remote data processing solution**Assessment reference**

Mitigation [MI-RTRY](#).

Assessment objective

Detect and recover from unavailability of the remote data processing solution.

Assessment preparation

- 1) Documentation describing the timeout, retry, and degraded-behaviour mechanisms used for communication with each remote data processing solution is available.
- 2) The product is in operational state with remote data processing solution connectivity configured.

Assessment activities

- 1) Review the documentation to identify the timeout controls, retry interval, and defined behaviour applied on prolonged unavailability for each remote data processing solution.
- 2) Block connectivity to the remote data processing solution and monitor the product's behaviour. Verify that the product detects the unavailability, retries within the documented retry window, and applies the defined behaviour for the dependent product function after the timeout expires.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Documentation does not describe timeout controls, retry behaviour, or defined behaviour on prolonged unavailability.
- 2) The product fails to detect unavailability, fails to retry within the documented retry window, or does not apply the defined behaviour on prolonged unavailability.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Documentation describes timeout controls, retry within the documented retry window, and a defined behaviour on prolonged unavailability for each remote data processing solution.
- 2) The product detects unavailability, retries within the documented retry window, and applies the defined behaviour on prolonged unavailability.

Assessment evidence

- 1) Documentation describing timeout, retry, and degraded-behaviour mechanisms.
- 2) Test results showing detection, retry attempts, and degraded behaviour.

6.14 TR-ISOL: Isolation

6.14.1 [AC-ISO-1] Assessment criteria: Access control across security boundaries

Conformance to MI-ACCS satisfies this mitigation. Where MI-ACCS has been assessed, AC-ISO-1 may be discharged by reference to the AC-ACCS result.

Assessment reference

Mitigation [MI-ISO-1](#).

Assessment objective

Enforce security boundaries that restrict access to security-relevant assets to authorised subjects and operations.

Assessment preparation

- 1) Documentation describing the security boundaries of the product, the subject types distinguished (such as users, applications, processes, execution contexts, privilege levels, or administrative roles), the security-relevant assets they protect, and the access-control and isolation model that governs access across those boundaries.
- 2) A test configuration in which at least one authorised subject and one unauthorised subject can be exercised against each security boundary.

Assessment activities

- 1) Review the documentation to verify that the security boundaries, the distinguished subject types, the security-relevant assets, and the access-control and isolation model are described.
- 2) For each security boundary, attempt an operation on a security-relevant asset from an authorised subject and verify that it is permitted, then attempt the same operation from a subject not authorised by the documented model and verify that it is denied.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Documentation does not describe the security boundaries, the distinguished subjects, the security-relevant assets, or the access-control and isolation model.
- 2) Any unauthorised subject is permitted access across a security boundary.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Documentation describes the security boundaries, the distinguished subjects, the security-relevant assets, and the access-control and isolation model.
- 2) Authorised subjects are permitted and unauthorised subjects are denied for every security boundary tested.

Assessment evidence

- 1) Documentation describing the security boundaries and the access-control and isolation model.
- 2) Test results showing permitted and denied access across each security boundary.

6.14.2 [AC-ISO-2] Assessment criteria: Process isolation**Assessment reference**

Mitigation [MI-ISO-2](#).

Assessment objective

Enforce isolation between processes at the CPU, memory, I/O, and interrupt-handling levels.

Assessment preparation

- 1) Documentation of the process-isolation model of the product, covering CPU scheduling, memory management and mapping, device and I/O assignment, and interrupt handling, identifying which resources are shared and which are dedicated per process, and the configured scheduling and resource-sharing policies.
- 2) A test configuration with at least two processes with distinct identities on the same product instance, with the ability to run test code in each to probe memory, devices, CPU load, and interrupt behaviour.

Assessment activities

- 1) Review the memory-assignment and mapping configuration to confirm that memory allocated to one process is not mapped into another, then from one process attempt, without authorisation, to read or modify memory allocated to another process, including through any shared-memory or mapping mechanism the product provides.
- 2) Identify the devices and I/O resources assigned to each process, then from one process attempt to access devices or storage assigned to another process, and verify that each process can access only its own assigned devices and I/O resources.
- 3) Confirm from documentation and configuration that CPU state and interrupts are isolated per process, then under sustained load generated by one process verify that another process continues to operate within the scheduling and resource-sharing behaviour documented by the manufacturer (its default behaviour where no explicit policy is configured) and does not receive spurious interrupts or exhibit interference beyond that documented behaviour.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) A process can read or modify memory allocated to another process without authorisation.
- 2) A process can access devices or I/O resources assigned to another process.

- 3) A process can degrade another process's CPU or interrupt behaviour beyond the scheduling and resource-sharing behaviour documented by the manufacturer.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) A process cannot read or modify memory allocated to another process without authorisation.
- 2) A process can access only its own assigned devices and I/O resources.
- 3) A process operates within the scheduling and resource-sharing behaviour documented by the manufacturer under load from another process, without spurious interrupts or interference beyond that documented behaviour.

Assessment evidence

- 1) Configuration of memory assignment and mapping, and test results showing blocked cross-process memory access.
- 2) Test results showing that device and I/O access is confined to each process's assignment.
- 3) Test results showing bounded CPU and interrupt impact under load from another process.

6.14.3 [AC-ISO-3] Assessment criteria: Isolation between the processes of different users

Assessment reference

Mitigation [MI-ISO-3](#).

Assessment objective

Enforce isolation between the processes of different users.

Assessment preparation

- 1) Documentation describing how the product isolates processes belonging to different users and the scheduling and resource-sharing behaviour documented by the manufacturer (its default behaviour where no explicit policy is configured) that bounds the availability one user's processes may affect for another.
- 2) A test configuration with at least two users, each running processes, and the ability to run commands as each user.

Assessment activities

- 1) As one user, attempt to read, modify, or signal the processes and process resources of another user, and verify that only the user's own processes and their resources can be read, modified, or controlled.
- 2) Under sustained load generated by one user's processes, verify that another user's processes continue to be scheduled within the scheduling and resource-sharing behaviour documented by the manufacturer.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) A user can read, modify, or signal the processes or process resources of another user.
- 2) A user can degrade the availability of another user's processes beyond that documented behaviour.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) A user can read, modify, or signal only their own processes and process resources.
- 2) A user's processes continue to be scheduled within the documented behaviour under load from another user.

Assessment evidence

- 1) Test results showing that process visibility and control are confined to each user.
- 2) Test results showing bounded scheduling impact across users under load.

6.14.4 [AC-ISO-4] Assessment criteria: Isolation between the data of different users

Assessment reference

Mitigation [MI-ISO-4](#).

Assessment objective

Enforce, by default, isolation between the data of different users.

Assessment preparation

- 1) Documentation describing the default data-isolation mechanisms of the product, such as filesystem permissions and per-user storage, and the resource-sharing behaviour documented by the manufacturer (its default behaviour where no explicit policy is configured) that bounds the availability one user's data may affect for another.
- 2) A test configuration with at least two users holding distinct data, the ability to act as each user, and the tools to generate sustained load against the storage or resources backing a user's data and to observe another user's data availability.

Assessment activities

- 1) In the default configuration, as one user enumerate and attempt to read or modify the data of another user, other than data intentionally shared, and verify that the access is prevented.
- 2) From one user, generate sustained load or contention against the storage or resources that back another user's data, beyond normal usage, and verify that the other user continues to access their data in accordance with the resource-sharing behaviour documented by the manufacturer, with any degradation limited to that documented behaviour.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) A user can read or modify another user's data in the default configuration.
- 2) A user can degrade the availability of another user's data beyond that documented behaviour.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) A user cannot read or modify another user's data in the default configuration.
- 2) A user cannot degrade the availability of another user's data beyond the documented behaviour.

Assessment evidence

- 1) Test results showing blocked cross-user data access in the default configuration.
- 2) Test results showing bounded availability impact on another user's data.

6.14.5 [AC-ISO-5] Assessment criteria: Privilege model

Conformance to MI-PRIV satisfies this mitigation. Where MI-PRIV has been assessed, AC-ISO-5 may be discharged by reference to the AC-PRIV result.

Assessment reference

Mitigation [MI-ISO-5](#).

Assessment objective

Provide a privilege model whose access levels to system resources require separate authorisation.

Assessment preparation

- 1) Documentation describing the privilege model of the product, the different levels of access to system resources it defines, and the separate authorisation required to obtain each level according to the access-control and isolation model.
- 2) A test configuration in which access can be attempted at more than one privilege level.

Assessment activities

- 1) Review the documentation to verify that the privilege model, the different levels of access to system resources, and the separate authorisation required for each level are described.
- 2) Attempt to obtain a level of access to system resources without providing the separate authorisation documented for that level, and verify that the product denies the access.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Documentation does not describe the privilege model, the access levels, or the separate authorisation required for each level.
- 2) A level of access to system resources is obtained without the separate authorisation documented for that level.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Documentation describes the privilege model, the access levels, and the separate authorisation required for each level.
- 2) Access to a level of system resources is granted only when the separate authorisation documented for that level is provided.

Assessment evidence

- 1) Documentation describing the privilege model and its access levels.
- 2) Test results showing that each access level requires its documented separate authorisation.

6.14.6 [AC-ISO-6] Assessment criteria: Side-channel isolation

Assessment reference

Mitigation [MI-ISO-6](#).

Assessment objective

Strengthen isolation, by default, against the side-channel attack classes the product's risk assessment identifies as applicable to the product and its supported hardware. Enable by default those whose risk is present across the intended deployment scenarios. Document the default state, rationale, and residual risks, and provide an activation process for any mitigation left off by default.

Assessment preparation

- 1) The product's risk assessment identifying the known side-channel attack classes applicable to the product and its supported hardware, the corresponding mitigations, and for each mitigation its default state (enabled or disabled), rationale and the residual risks.

- 2) Documentation of the product's intended deployment scenarios and, for each attack class, whether its risk is present across those scenarios.
- 3) For any mitigation provided off by default: the risk-assessment justification (deployment-specific class and disproportionate impact where the risk is low or absent) and the process by which an authorised user can activate it.
- 4) Documentation of any operational environment dependencies relied on for effective mitigation, with their expected security properties.
- 5) The test environment: platform and CPU features relevant to the claimed mitigations, and the co-residency configuration of the workloads used.

Assessment activities

- 1) Review the documentation to verify that it identifies the known side-channel attack classes applicable to the product and its supported hardware, as identified from the manufacturer's documented risk assessment, and, for each class, records:
 - a) the corresponding mitigation together with its default state and rationale, and the residual risk, and, where applicable, the process by which an authorised user can activate the mitigation;
 - b) a documented residual risk with the expected security properties any Operational Environment dependency would need to provide to mitigate it; or
 - c) a statement, with rationale, that the class is not applicable to the product's supported hardware.
- 2) In the product's default configuration, verify through means such as configuration views, status commands, or logs that the default state of each mitigation can be determined.
- 3) For a representative off-by-default mitigation, follow the documented process and confirm the mitigation becomes enabled.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) For at least one applicable attack class, the documentation does not record the mitigation, its default state and rationale, and the residual risks.
- 2) For each attack class documented as having risk present across the intended deployment scenarios, its mitigation is not enabled in the default configuration.
- 3) For at least one mitigation provided off by default, the risk assessment does not justify it as deployment-specific with a disproportionate impact where the risk is low or absent, the activation process is not documented, or following the documented activation process does not enable the mitigation.
- 4) The mitigation state cannot be determined where claimed, or an OE dependency or its expected security properties are not documented.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) For each applicable attack class, the documentation records the mitigation, its default state and rationale, and the residual risks.
- 2) For each attack class documented as having risk present across the intended deployment scenarios, its mitigation is enabled in the default configuration.
- 3) For each mitigation provided off by default, the risk assessment justifies it as deployment-specific with a disproportionate impact where the risk is low or absent, the activation process is documented, and following that process enables the mitigation.
- 4) The mitigation state is determinable where the capability is provided, and any OE dependencies and their expected security properties are documented.

Assessment evidence

- 1) The risk assessment documentation.
- 2) System output showing the default state of each such mitigation.
- 3) The justification per off-by-default mitigation, the documented activation process, and the result of following it.
- 4) Configuration/status output showing the mitigation state, and documentation of any OE dependencies and their expected properties.

6.14.7 [AC-ISO-7] Assessment criteria: Binary hardening

Assessment reference

Mitigation [MI-ISO-7](#).

Assessment objective

Verify that the product binaries exhibit the risk-appropriate hardening measures documented by the manufacturer.

Assessment preparation

- 1) Documentation describing, for each product binary or group of binaries, the target platform, the implementation language or languages, the risk-appropriate hardening measures applied and the rationale for them, and the residual risk together with any compensating control.
- 2) The tools necessary to inspect the product binaries for the presence of the documented hardening measures.

Assessment activities

- 1) Review the documentation to verify that the hardening measures, the rationale, and the residual risk with any compensating control are described for each product binary or group of binaries.
- 2) For a representative set of product binaries, inspect the binaries and verify that they exhibit the hardening measures documented for their target platform and implementation language.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Documentation does not describe the hardening measures, the rationale, or the residual risk for at least one product binary or group of binaries.
- 2) Any inspected product binary does not exhibit a hardening measure documented for its target platform and language.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Documentation describes the hardening measures, the rationale, and the residual risk with any compensating control for each product binary or group of binaries.
- 2) The inspected product binaries exhibit the hardening measures documented for their target platform and language.

Assessment evidence

- 1) Documentation describing per-binary hardening measures, rationale, and residual risk.
- 2) Results of binary inspection showing the documented hardening measures are present.

6.15 TR-LOGG: Logging and monitoring

6.15.1 [AC-LOGG] Assessment criteria: Logging

Assessment reference

Mitigation [MI-LOGG](#).

Assessment objective

Monitoring and recording security-relevant events, and providing an opt-out for that recording.

Assessment preparation

- 1) Place the product in its default secure configuration.
- 2) Obtain the manufacturer's documentation identifying which events are treated as security-relevant for the product and the basis for that determination in the manufacturer's risk assessment.
- 3) Obtain the manufacturer's documentation describing any collection of log, telemetry, or diagnostic data that may contain sensitive content.
- 4) From that documentation, compile the list of security-relevant event types as defined by the manufacturer.

Assessment activities

- 1) Review the manufacturer's documentation of security-relevant events and of data collection, and the categories of log, telemetry, and diagnostic data the product produces in its default secure configuration.
- 2) With the product in its default secure configuration, trigger each security-relevant event type and examine the log records produced.
- 3) Acting as an authorised user, use the product's mechanism to opt out of the recording and monitoring of security-relevant events, then trigger security-relevant events again.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) The manufacturer does not document which events are treated as security-relevant, or the determination is not based on its risk assessment.
- 2) The log, telemetry, or diagnostic data produced in the default secure configuration exceed that necessary for operation, troubleshooting, and security monitoring.
- 3) The product collects data that may contain sensitive content that is not described in the manufacturer's documentation.
- 4) For at least one triggered event, the log contains no record indicating the event.
- 5) For at least one record, a field applicable to the event type (time, outcome, or identity) is missing.
- 6) At least one log record contains a plaintext credential or a full cryptographic key.
- 7) The product provides no mechanism for an authorised user to opt out of the recording and monitoring of security-relevant events.
- 8) After the authorised user opts out, the product continues to record or monitor security-relevant events.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) The manufacturer documents, based on its risk assessment, which events are treated as security-relevant.
- 2) The log, telemetry, and diagnostic data produced in the default secure configuration are limited to that necessary for operation, troubleshooting, and security monitoring.

- 3) Any collection of data that may contain sensitive content is described in the manufacturer's documentation.
- 4) For each triggered event, the log contains a time-stamped record indicating the event.
- 5) Each such record includes, as applicable to the event type, the time of the event, the outcome of the event, and the identity of the associated user, service, or process.
- 6) No log record produced contains a plaintext credential or a full cryptographic key.
- 7) The product provides an authorised user with a mechanism to opt out of the recording and monitoring of security-relevant events.
- 8) After the authorised user opts out, the product does not record or monitor security-relevant events.

Assessment evidence

- 1) The manufacturer's documentation of security-relevant events and of sensitive-content collection, and the categories of log, telemetry, and diagnostic data produced.
- 2) Method of triggering events, and the log records produced, annotated with the event type and the fields present.
- 3) The opt-out mechanism and its documentation, and log records before and after opt-out.

NOTE: Guidance: One type of event whose log message can accidentally include a secret is a failed password authentication attempt. Since people often type their password into the username field, including the username field in the log message may result in including a secret in the log message.

6.16 TR-SCDL: Secure deletion

6.16.1 [AC-SDEL] Assessment criteria: Secure deletion

Assessment reference

Mitigation [MI-SDEL](#).

Assessment objective

Confirm that the product provides a means by which the user can securely delete user data and settings, such that they cannot subsequently be recovered through the product's interfaces.

Assessment preparation

- 1) Review the documentation about the means by which the user can securely delete user data and settings stored on the product.

Assessment activities

- 1) Write an instance of the data and setting, stored on the product, that is different from the default, execute the documented secure deletion means, and try to read the data from the product.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) The written data or setting can be recovered through the product's interfaces after the secure deletion means is executed.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) The written data or setting cannot be recovered through the product's interfaces after the secure deletion means is executed.

Assessment evidence

- 1) Record of the data or setting written, the secure deletion means executed, and what the subsequent read returned.

6.16.2 [AC-RRSD] Assessment criteria: Document residual risk to secure deletion

Assessment reference

Mitigation [MI-RRSD](#).

Assessment objective

Document residual risk to secure deletion.

Assessment activities

- 1) Assess the documentation provided with the product.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Documentation does not describe the residual risk to secure deletion, or does not describe the actions the user or the operational environment can take to mitigate it.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Documentation describes the residual risk to secure deletion, including any user data or settings that the product cannot guarantee to delete, and the actions the user or the operational environment can take to mitigate it.

Assessment evidence

- 1) Documentation and analysis of completeness.

6.17 TR-SDTR: Secure data read and transfer

6.17.1 [AC-SDRF] Assessment criteria: Secure data read from product

Assessment reference

Mitigation [MI-SDRF](#).

Assessment objective

Confirm that an authorised user can securely read their data and settings from the product, and that unauthorised users cannot.

Assessment preparation

- 1) List the data and settings each authorised user is entitled to read at their privilege level.

Assessment activities

- 1) For each authorised user, read the data and settings the user is entitled to read at their privilege level using the product's secure read method, then attempt to read data and settings the user is not entitled to read.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) An authorised user cannot read the data and settings they are entitled to read at their privilege level using the product's secure read method, or the method allows an unauthorised user to read data and settings they are not entitled to read.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Each authorised user can read the data and settings they are entitled to read at their privilege level using the product's secure read method, and the method does not allow an unauthorised user to read data and settings they are not entitled to read.

Assessment evidence

- 1) List of the data and settings each authorised user is entitled to read, log message showing success or failure of each read attempt.

6.17.2 [AC-SDTR] Assessment criteria: Document secure data transfer to another product or system

Assessment reference

Mitigation [MI-SDTR](#).

Assessment objective

Document and verify secure data transfer to another product or system.

Assessment preparation

- 1) Review the documentation to identify the method used to transfer data and settings to another product or system and the mechanisms it states are used to protect their confidentiality and integrity during the transfer.

Assessment activities

- 1) Review the documentation to verify that it describes how the confidentiality and integrity of the transferred data and settings are protected during the transfer.
- 2) Transfer data and settings to another product or system using the documented method, attempt to read or alter the data and settings in transit as an unauthorised party, and read the data and settings on the target product or system.

Assessment verdict

The verdict fail is assigned if any of the following conditions apply:

- 1) Documentation does not describe how the confidentiality and integrity of the data and settings are protected during transfer to another product or system.
- 2) The transfer does not behave as documented, an unauthorised party can read or alter the data or settings in transit, or the data and settings on the target product or system do not match the source wherever technically possible.

The verdict pass is assigned if none of the above conditions apply and all of the following conditions are met:

- 1) Documentation describes how the confidentiality and integrity of the data and settings are protected during transfer to another product or system.
- 2) The transfer behaves as documented, an unauthorised party cannot read or alter the data and settings in transit, and the data and settings on the target product or system match the source wherever technically possible.

Assessment evidence

- 1) Documentation of the transfer method and the stated protection mechanisms.

- 2) Test results showing the documented protection mechanisms are effective and the transferred data and settings match the source.

Annex A (informative): Relationship between the present document and the essential cybersecurity requirements of Regulation (EU) 2024/2847

The present document has been prepared under the Commission's standardisation request C(2025) 618 final [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (CRA) [i.1].

Once the present document is cited in the Official Journal of the European Union under Regulation (EU) 2024/2847, compliance with the normative clauses of the present document given in the table below confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

**Table A.1: Relationship between the present document and
the requirements of Regulation (EU) 2024/2847 [i.1] - the Cyber Resilience Act**

Description	Essential Requirements of Regulation (EU) 2024/2847	Clause(s) of the present document	Remarks / Notes
Annex I, Part I, (1)	"Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks."	Clauses 4 , 5 and 6	
Annex I, Part I, (2)(a)	"Products with digital elements shall be made available on the market without known exploitable vulnerabilities."	TR-NKEV (5.2.2 , 6.2)	
Annex I, Part I, (2)(b)	"Products with digital elements shall be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state."	TR-SDEF, TR-SCDL (5.2.4 , 5.2.16 , 6.4 , 6.16)	
Annex I, Part I, (2)(c)	"Products with digital elements shall ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them."	TR-SCUD (5.2.5 , 6.5)	
Annex I, Part I, (2)(d)	"Products with digital elements shall ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access."	TR-AUTH, TR-LOGG (5.2.6 , 5.2.15 , 6.6 , 6.15)	
Annex I, Part I, (2)(e)	"Products with digital elements shall protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by best practice mechanisms, and by using other technical means."	TR-CDST, TR-CDTX, TR-CRYP, TR-AUTH (5.2.7 , 5.2.8 , 5.2.9 , 5.2.6 , 6.7 , 6.8 , 6.9 , 6.6)	
Annex I, Part I, (2)(f)	"Products with digital elements shall protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions."	TR-IDST, TR-IDTX, TR-AUTH, TR-LOGG (5.2.10 , 5.2.11 , 5.2.6 , 5.2.15 , 6.10 , 6.11 , 6.6 , 6.15)	
Annex I, Part I, (2)(g)	"Products with digital elements shall process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation)."	TR-DMIN (5.2.12 , 6.12)	

Description	Essential Requirements of Regulation (EU) 2024/2847	Clause(s) of the present document	Remarks / Notes
Annex I, Part I, (2)(h)	"Products with digital elements shall protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks."	TR-AVAI (5.2.13 , 6.13)	
Annex I, Part I, (2)(i)	"Products with digital elements shall minimise the negative impact by the products themselves or connected products on the availability of services provided by other products or networks."	TR-MINI, TR-SDEF, TR-AVAI (5.2.3 , 5.2.4 , 5.2.13 , 6.3, 6.4, 6.13)	
Annex I, Part I, (2)(j)	"Products with digital elements shall be designed, developed and produced to limit attack surfaces, including external interfaces."	TR-SDEF, TR-ISOL (5.2.4 , 5.2.14 , 6.4, 6.14)	
Annex I, Part I, (2)(k)	"Products with digital elements shall be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques."	TR-AVAI, TR-ISOL (5.2.13 , 5.2.14 , 6.13, 6.14)	
Annex I, Part I, (2)(l)	"Products with digital elements shall provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user."	TR-LOGG (5.2.15 , 6.15)	
Annex I, Part I, (2)(m)	"Products with digital elements shall provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner."	TR-SCDL, TR-SDTR (5.2.16 , 5.2.17 , 6.16, 6.17)	

Key to columns:

Description A textual reference to the requirement.

Requirements of Regulation

Identification of point(s) defining the requirement in Regulation (EU) 2024/2847 - the Cyber Resilience Act.

Clause(s) of the present document

Identification of clause(s) addressing the requirement in the present document.

Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list published in the Official Journal of the European Union. Users of the present document should consult frequently the latest list published in the Official Journal of the European Union.

Other Union legislation may be applicable to the product(s) falling within the scope of the present document.

Annex B (informative): Security analysis

B.0 General

This annex describes how the security requirements in clause 5 are derived. Assets, product functions, risk factors, assumptions, and threats are described in clauses B.1 through B.4. Each threat lists the requirements that mitigate it. The mapping of use cases to risk factors in clause B.5 and the security profiles in clause B.6 together determine which mitigations apply to a given product.

B.1 Assets

B.1.1 Data assets

- User data (documents, media, application state)
- Logs (system logs, security audit logs, application logs)
- Credentials and keys (passwords, API keys, cryptographic keys, tokens)
- Certificates (TLS certificates, code-signing certificates, root CA stores)
- Configuration files (system configuration, service configuration, security policies)

B.1.2 Software assets

- Kernel (including kernel modules)
- System libraries and runtime components
- Applications and system services
- Device drivers
- Boot firmware and bootloader
- Firmware images (update packages, recovery images)

B.1.3 Hardware-interfacing assets

- Memory (system memory, memory-mapped I/O)
- Storage (internal storage, removable media)
- Processing units (CPUs, co-processors, GPUs)
- Peripheral interfaces (USB, PCI, SPI, I2C, GPIO)
- Network interfaces (Ethernet, Wi-Fi®, Bluetooth®, cellular)
- Debug and management interfaces (JTAG, SWD, serial console, BMC)

B.1.4 Network assets

- Network services (listening services, exposed APIs)
- Active connections (established sessions, tunnels)
- Routing and firewall state (routing tables, firewall rules, NAT state)
- DNS resolution (resolver configuration, cached entries)

B.1.5 Identity and access assets

- User accounts and administrator accounts
- Sessions (active login sessions, authentication tokens)
- Access control policies (file permissions, mandatory access control rules, capability sets)

B.1.6 Product functions

- Resource allocation (memory management, scheduling, storage quotas, other resource usage limits)
- Isolation (memory protection, storage protection, other permissions)
- Abstract I/O (network stack, file systems, video, sound, input devices)
- Hardware communication (device drivers)
- Power management
- Hardware management
- Configuration (software to run, hardware configuration, I/O configuration)
- Initialisation (initialise hardware, start software services)
- Authentication
- Authorisation
- Software management (software verification, software installation, security updates, software upgrade, software removal, firmware upgrades, load kernel modules)
- Logging
- Monitoring and notifications

B.1.7 Impact of asset compromise

The following summarises the potential impact when assets from each category are compromised in terms of confidentiality, integrity, and availability:

- **Data assets:** loss of confidentiality exposes user data, credentials, or keys to unauthorised parties. Loss of integrity allows an attacker to modify configuration or inject false log entries. Loss of availability prevents the product from accessing data it needs to function.
- **Software assets:** loss of integrity allows an attacker to modify the kernel, libraries, or firmware, potentially gaining persistent control of the product. Loss of availability prevents the product from starting or operating.

- **Hardware-interfacing assets:** loss of confidentiality of memory contents exposes sensitive data. Loss of integrity of debug interfaces allows unauthorised code execution. Loss of availability of storage or network interfaces degrades product functions.
- **Network assets:** loss of confidentiality of active connections exposes transmitted data. Loss of integrity of routing or firewall state allows traffic redirection or bypass. Loss of availability of network services denies service to users.
- **Identity and access assets:** loss of confidentiality of accounts or sessions enables impersonation. Loss of integrity of access control policies allows privilege escalation. Loss of availability of authentication locks out legitimate users.
- **Product functions:** loss of integrity of isolation, resource allocation, or authorisation functions undermines the security guarantees that other mitigations depend on. Loss of availability of any core function is a denial-of-service condition.

B.2 Risk factors

B.2.1 General comments regarding risk factors

Risk factors determine which mitigation(s) satisfy each of the technical requirements in clause 5.2.

Manufacturers determine the level of each risk factor via the development of a threat model and risk profile based on the intended and foreseeable use and misuse of the operating system.

Risk factors can increase the likelihood of an incident, increase the impact of an incident, or both. As a result, different mitigation strategies can be more or less relevant to different risk factors.

The overall risk related to each use case is calculated by combining risk factors affecting both likelihood and impact of an incident.

B.2.2 RF-NUSR: Number of User Accounts

The number of user accounts of end-users expected on the system, excluding administrator accounts:

- NUSR-0: foreseeable use does not include user accounts for end-users
- NUSR-1: foreseeable use is only one user account for an end-user
- NUSR-2: foreseeable use of the operating system is multiple user accounts for end-users

B.2.3 RF-CUSR: User Account Concurrency

The number of user accounts expected to use the system concurrently, including administrator accounts if they are configurable or accessible by end-users:

- CUSR-0: foreseeable use is one authenticated end-user using the device at a time, including authentication by physical access
- CUSR-1: foreseeable use of the operating system is small number of authenticated users simultaneously active on the operating system who are trusted not to actively attempt to compromise the system
- CUSR-2: foreseeable use of the operating system is multiple authenticated untrusted users simultaneously active on the operating system

B.2.4 RF-PPII: Potential for Collection of Personally Identifiable Information

Potential for collection of personally identifiable information about an individual person:

- PPII-0: foreseeable use includes no or incidental collection of PII
- PPII-1: foreseeable use includes collection of PII

B.2.5 RF-SNDS: Sensitivity of Data Stored

Sensitivity of data stored, as measured by impact of loss of its integrity, confidentiality, or availability:

- SNDS-0: foreseeable use includes no or incidental storage of sensitive data
- SNDS-1: foreseeable use includes storing sensitive data

B.2.6 RF-SNDT: Sensitivity of Data Transmitted

Sensitivity of data transmitted, as measured by impact of loss of its integrity, confidentiality, or availability:

- SNDT-0: foreseeable use includes no or incidental transmission of sensitive data
- SNDT-1: foreseeable use includes transmission of sensitive data

B.2.7 RF-SENF: Sensitivity of Functions

Sensitivity of functions of device, as measured by impact of loss of its integrity, confidentiality, or availability:

- SENF-0: foreseeable use includes no or incidental provision of sensitive functions
- SENF-1: foreseeable use can provide arbitrary sensitive functions
- SENF-2: foreseeable use provides sensitive functions by default

B.2.8 RF-PHYS: Physical Access by Threat Actors to the Device

Exposure of the device to physical access by users:

- PHYS-0: foreseeable use is only in environments without physical exposure to untrusted persons
- PHYS-1: foreseeable use includes incidental physical exposure to untrusted persons
- PHYS-2: foreseeable use includes regular physical exposure to untrusted persons

B.2.9 RF-UEIN: Processing of Untrusted External Inputs

Exposure to untrusted external inputs that are processed by the platform:

- UEIN-0: only used in environments without processing of untrusted external inputs
- UEIN-1: can incidentally process untrusted external inputs
- UEIN-2: used primarily to process untrusted external inputs

B.2.10 RF-LOSS: Probability of Loss of the Device

Likelihood of loss or theft of the device, allowing threat actors unlimited physical access to the device:

- LOSS-0: foreseeable use is in a device with no or incidental loss likelihood
- LOSS-1: foreseeable use is in a device with moderate loss likelihood
- LOSS-2: foreseeable use is in a device with a high loss likelihood, such as devices which are common targets of theft such as mobile phones

B.2.11 RF-HWMD: Hardware Modifiability by End Users

Likelihood that the hardware of the platform will be changed from its secure-by-default state:

- HWMD-0: foreseeable use limited to devices with hardware that is not modifiable by end-users
- HWMD-1: foreseeable use includes hardware modifications by skilled administrators
- HWMD-2: foreseeable use includes hardware modification by unskilled users

B.2.12 RF-SWMD: Software Modifiability by End Users

Likelihood that the software on the platform (including firmware) will be changed from its secure-by-default state:

- SWMD-0: foreseeable use only allows the installation of trusted and verified software, such as updates
- SWMD-1: foreseeable use allows for the installation of arbitrary software or for substantial modification of pre-installed software
- SWMD-2: foreseeable use actively encourages and facilitates the installation of frequently malicious software

B.2.13 RF-DVCS: Untrusted Peripheral Devices

Likelihood of untrusted peripheral devices being attached to the platform via a connection that is a plausible attack vector, such as by USB or PCI bus:

- DVCS-0: foreseeable use has no accessible peripheral ports
- DVCS-1: foreseeable use includes only trusted and safe peripheral devices
- DVCS-2: foreseeable use allows for arbitrary peripheral device attachment

B.2.14 RF-TNET: Access to a Public Network

Likelihood that the device will initiate connections to public networks:

- TNET-0: foreseeable use has no mechanism to reasonably connect to a public network
- TNET-1: foreseeable use allows internet access for only highly restricted functions, such as retrieving security updates
- TNET-2: foreseeable use allows for arbitrary access to a public network, such as by browsing the web

B.2.15 RF-FNET: Accessed From Untrusted Networks Including a Public Network

Likelihood that the device will be exposed to incoming traffic from public networks:

- FNET-0: foreseeable use is limited to trusted and private networks
- FNET-1: foreseeable use includes untrusted local networks but not the open internet
- FNET-2: foreseeable use includes being connected directly to the open internet

B.2.16 RF-CONF: Configurability

Degree of security-relevant configuration change of the operating system necessary for use:

- CONF-0: foreseeable use does not require storing operating system configuration changes
- CONF-1: foreseeable use involves operating system configuration changes only by skilled administrators
- CONF-2: foreseeable use of the operating system includes configuration changes by end-users

B.2.17 RF-ADMN: Administration

Availability and skill of administrators:

- ADMN-0: foreseeable use does not require administration
- ADMN-1: foreseeable use always has skilled administrators available on call
- ADMN-2: foreseeable use can involve unskilled administrators

B.2.18 RF-SUPP: Support and Foreseeable Updates

How long the product is expected to be in use, and whether the product is expected to be updated throughout its life cycle:

- SUPP-0: foreseeable use does not require that the operating system be updated at any point in its lifecycle
- SUPP-1: foreseeable use includes the installation of updates by end-users with access to the operating system
- SUPP-2: foreseeable use necessitates that the manufacturer provide frequent, automatic, and/or time-sensitive updates to the product, and can reasonably be expected to do so

B.2.19 RF-RDPS: Remote data processing dependency

Whether the product depends on one or more remote data processing solutions for product functions, as described in clause [4.8](#):

- RDPS-0: the product does not depend on any remote data processing solution for any product function
- RDPS-1: the product depends on one or more remote data processing solutions for at least one product function

B.3 Assumptions

B.3.0 General

Assumptions can be updated to be less stringent as more use cases and mitigations are added to the present document.

B.3.1 AS-PA: Proper administrator

The product administrator is not intentionally hostile and is engaging in good faith efforts to administer the system properly.

B.4 Security analysis

B.4.1 Methodology

The baseline risk-factor levels for each basic use case, and the increments contributed by each condition, are given in clause B.5. They are determined by reading the descriptions for each risk-factor level (see clause B.2) and choosing the one that most accurately represents the highest risk for the use case or condition. The third column of each threat table below ("Reached by") records which security profile (SP-REST or SP-GEN, clause B.6) or condition (clause 4.7.3) reaches that likelihood or impact level.

For each threat, a formula based on the risk factor levels is used to calculate the Likelihood and Impact of the threat, on a scale of Low, Medium, and High.

Some threats describe residual risks that the product cannot mitigate. These are identified as such and are not assigned Likelihood and Impact levels.

B.4.2 TH-UEVU: Unknown exploitable vulnerabilities

Attacker can use unknown exploitable vulnerabilities in the product implementation to get unauthorised access to product assets.

Assets affected: Software assets, Data assets, Identity and access assets, and Product functions.

Requirements that mitigate this threat: TR-SDEF, TR-LOGG, TR-ISOL

Mitigations for Likelihood:

- Medium to Low: ADEF, ISO-7
- High to Low: ADEF, ISO-2, ISO-7

Table B.4-1: Likelihood of TH-UEVU

Risk factors	Likelihood	Reached by
none of NUSR, CUSR, SENF, PHYS, FNET, or UEIN is above level 0	Low	SP-REST
all others	Medium	SP-GEN
any of NUSR, CUSR, SENF, PHYS, FNET, or UEIN is at level 2	High	C-NET, C-MULTI, C-UNTR, C-FUNC, C-PHYS

Mitigations for Impact:

- Medium to Low: LOGG
- High to Low: LOGG

Table B.4-2: Impact of TH-UEVU

Risk factors	Impact	Reached by
none of SNDS, SNTD, SENF, or PPII is above level 0	Low	SP-REST
the highest of SNDS, SNTD, SENF, and PPII is at level 1	Medium	SP-GEN, C-DATA
SENF is at level 2	High	C-FUNC

B.4.3 TH-KEVU: Known exploitable vulnerabilities

Attacker can use known exploitable vulnerabilities in the product implementation to get unauthorised access to product assets.

Assets affected: Software assets, Data assets, Identity and access assets, and Product functions.

Requirements that mitigate this threat: TR-NKEV, TR-SCUD, TR-SDEF, TR-LOGG, TR-ISOL

All mitigations from TH-UEVU apply (using that requirement's risk formula), in addition to:

Mitigations for Likelihood:

- Medium to Low: (KEVD or KEVA), KEVM, SCUE
- High to Low: KEVA, KEVM, KEVT, SCUE

Table B.4-3: Likelihood of TH-KEVU

Risk factors	Likelihood	Reached by
ADMN is at level 0 or SUPP is at level 0	Low	None
all others	Medium	SP-REST, SP-GEN
both ADMN and SUPP are at level 2	High	C-SELFADM

Table B.4-4: Impact of TH-KEVU

Risk factors	Impact	Reached by
none of SNDS, SNTD, SENF, or PPII is above level 0	Low	SP-REST
the highest of SNDS, SNTD, SENF, and PPII is at level 1	Medium	SP-GEN, C-DATA
SENF is at level 2	High	C-FUNC

B.4.4 TH-SUPC: Compromise of the secure update mechanism

Attacker can tamper with update packages or their metadata, deliver updates from an untrusted or unauthorised source, abuse stolen or misissued update trust credentials, bypass the update verification mechanism, force the installation of an earlier vulnerable version, or disrupt an update in progress, in order to install unauthorised software on the product or render it inoperable.

Assets affected: Software assets, Data assets, and Product functions.

Requirements that mitigate this threat: TR-SCUD, TR-CRYP, TR-LOGG

Mitigations for Likelihood:

- Medium to Low: SUVI, SCUE
- High to Low: SUVI, SUDP, SUAR, CRYP

Table B.4-5: Likelihood of TH-SUPC

Risk factors	Likelihood	Reached by
SUPP is at level 0	Low	None
all others	Medium	SP-REST, SP-GEN
TNET or FNET is at level 2	High	C-NET

Mitigations for Impact:

- Medium to Low: LOGG
- High to Low: LOGG

Table B.4-6: Impact of TH-SUPC

Risk factors	Impact	Reached by
none of SNDS, SNDT, SENF, or PPII is above level 0	Low	SP-REST
the highest of SNDS, SNDT, SENF, and PPII is at level 1	Medium	SP-GEN, C-DATA
SENF is at level 2	High	C-FUNC

B.4.5 TH-UAPP: Unauthorised access to product assets via unprotected physical interfaces in default configuration

Attacker can use unprotected debug or management interfaces to get unauthorised access to product assets via physical access in the default configuration of the product.

Assets affected: Hardware-interfacing assets, Data assets, and Identity and access assets.

Requirements that mitigate this threat: TR-SDEF, TR-AUTH, TR-LOGG, TR-CDST, TR-IDST, TR-SCDL

Mitigations for Likelihood:

- Medium to Low: PDDI-1, AUTH-1, AUTH-2
- High to Low: ADEF, AUTH-1, AUTH-2

Table B.4-7: Likelihood of TH-UAPP

Risk factors	Likelihood	Reached by
none of PHYS, DVCS, or HWMD is above level 0	Low	SP-REST, SP-GEN
all others	Medium	C-LOSS, C-MOD, C-PHYS
PHYS is above level 0 and SENF is at level 2	High	C-LOSS or C-PHYS, with C-FUNC

Mitigations for Impact:

- Medium to Low: LOGG, ENST, ACSD, DCST, INTS, SDEL, RRS
- High to Low: LOGG, ENST, ACSD, DCST, INTS, SDEL, RRS

Table B.4-8: Impact of TH-UAPP

Risk factors	Impact	Reached by
none of SNDS, SNDT, SENF, or PPII is above level 0	Low	SP-REST
the highest of SNDS, SNDT, SENF, and PPII is at level 1	Medium	SP-GEN, C-DATA
SENF is at level 2	High	C-FUNC

B.4.6 TH-UAPS: Unauthorised access to product assets via unprotected local software access in default configuration

Attacker can use unprotected debug or management interfaces to get unauthorised access to product assets via local software access in the default configuration of the product.

Assets affected: Software assets, Data assets, Identity and access assets, and Product functions.

Requirements that mitigate this threat: TR-SDEF, TR-AUTH, TR-LOGG, TR-ISOL, TR-CDST, TR-IDST, TR-SCDL

Mitigations for Likelihood:

- Medium to Low: PDDI-1, AUTH-1, AUTH-2, LCKT, CRED
- High to Low: ADEF, PDDI-2, AUTH-1, AUTH-2, LCKT, CRED, ISO-1, ACCS, PRIV, SESS

Table B.4-9: Likelihood of TH-UAPS

Risk factors	Likelihood	Reached by
none of NUSR, SWMD, or CONF is above level 0	Low	SP-REST
all others	Medium	SP-GEN, C-MOD, C-APPS, C-MULTI
any of NUSR or SWMD is at level 2 and SENF is at level 2	High	C-APPS or C-MULTI, with C-FUNC

Mitigations for Impact:

- Medium to Low: LOGG, ENST, ACSD, DCST, INTS, SDEL
- High to Low: LOGG, ENST, ACSD, DCST, INTS, SDEL

Table B.4-10: Impact of TH-UAPS

Risk factors	Impact	Reached by
none of SNDS, SNDT, SENF, or PPII is above level 0	Low	SP-REST
the highest of SNDS, SNDT, SENF, and PPII is at level 1	Medium	SP-GEN, C-DATA
SENF is at level 2	High	C-FUNC

B.4.7 TH-UAPN: Unauthorised access to product assets via unprotected network interfaces in default configuration

Attacker can use unprotected debug or management interfaces to get unauthorised access to product assets via the network in the default configuration of the product.

Assets affected: Network assets, Data assets, and Identity and access assets.

Requirements that mitigate this threat: TR-SDEF, TR-AUTH, TR-LOGG, TR-CDST, TR-IDST, TR-SCDL

Mitigations for Likelihood:

- Medium to Low: PDDI-1, AUTH-1, AUTH-2, LCKT, CRED
- High to Low: ADEF, PDDI-3, AUTH-1, AUTH-2, LCKT, CRED, ACCS, SESS

Table B.4-11: Likelihood of TH-UAPN

Risk factors	Likelihood	Reached by
none of FNET or TNET is above level 0	Low	SP-REST, SP-GEN
all others	Medium	C-NET, C-NETR
any of FNET or TNET is above level 0 and SENF is at level 2	High	C-NET or C-NETR, with C-FUNC

Mitigations for Impact:

- Medium to Low: LOGG, ENST, ACSD, DCST, INTS, SDEL
- High to Low: LOGG, ENST, ACSD, DCST, INTS, SDEL

Table B.4-12: Impact of TH-UAPN

Risk factors	Impact	Reached by
none of SNDS, SNDT, SENF, or PPII is above level 0	Low	SP-REST
the highest of SNDS, SNDT, SENF, and PPII is at level 1	Medium	SP-GEN, C-DATA
SENF is at level 2	High	C-FUNC

B.4.8 TH-UADT: Unauthorised access to confidential data transmitted

Attacker can use network access to get unauthorised access to confidential data transmitted by the product.

Assets affected: Data assets, Network assets, and Identity and access assets.

Requirements that mitigate this threat: TR-CDTX, TR-CRYP, TR-IDTX, TR-DMIN

Mitigations for Likelihood:

- Medium to Low: RRDC
- High to Low: CDTX, ENTX, CRYP, INTT, RRDC

Table B.4-13: Likelihood of TH-UADT

Risk factors	Likelihood	Reached by
TNET is at level 0	Low	SP-REST, SP-GEN
TNET is at level 1	Medium	C-NETR
TNET is at level 2	High	C-NET

Mitigations for Impact:

- Medium to Low: DJST

Table B.4-14: Impact of TH-UADT

Risk factors	Impact	Reached by
neither SNDT nor PPII is above level 0	Low	SP-REST, SP-GEN
the highest of SNDT and PPII is at level 1	Medium	C-DATA

B.4.9 TH-UADX: Unauthorised access to data during transfer to another product

Attacker can get unauthorised access to confidential data, or compromise its integrity, while an authorised user reads it out of the product or transfers it to another product or system.

Assets affected: Data assets and Identity and access assets.

Requirements that mitigate this threat: TR-SDTR, TR-CRYP, TR-DMIN

Mitigations for Likelihood:

- Medium to Low: SDRF, SDTR, CRYP

Table B.4-15: Likelihood of TH-UADX

Risk factors	Likelihood	Reached by
none of SNDS or SNTD is above level 0	Low	SP-REST, SP-GEN
the highest of SNDS and SNTD is at level 1	Medium	C-DATA

Mitigations for Impact:

- Medium to Low: DJST

Table B.4-16: Impact of TH-UADX

Risk factors	Impact	Reached by
none of SNDS, SNTD, or PPII is above level 0	Low	SP-REST, SP-GEN
the highest of SNDS, SNTD, and PPII is at level 1	Medium	C-DATA

B.4.10 TH-PDOS: Denial of service attack on product functions via user or network access

Attacker can use user or network access for a denial-of-service attack on product functions.

Assets affected: Product functions.

Requirements that mitigate this threat: TR-AUTH, TR-AVAI, TR-LOGG

Mitigations for Likelihood:

- Medium to Low: RRDS
- High to Low: RRDS

Table B.4-17: Likelihood of TH-PDOS

Risk factors	Likelihood	Reached by
none of NUSR, CUSR, or FNET is above level 0	Low	SP-REST
the highest of NUSR, CUSR, and FNET is at level 1	Medium	SP-GEN
any of NUSR, CUSR, or FNET is at level 2	High	C-MULTI, C-UNTR, C-NET

Mitigations for Impact:

- Medium to Low: RLIM, LOGG
- High to Low: AUTH-1, AUTH-2, AVNT, RLIM, PRIO, LOGG, CSFR, RTDL

Table B.4-18: Impact of TH-PDOS

Risk factors	Impact	Reached by
SENF is at level 0	Low	SP-REST
SENF is at level 1	Medium	SP-GEN
SENF is at level 2	High	C-FUNC

B.4.11 TH-DDOS: Denial of service attack on other products via exploitation of vulnerabilities or unauthorised use of product functions

Attacker can use the network to exploit vulnerabilities in the product to attack other products.

Assets affected: Product functions and Network assets.

Requirements that mitigate this threat: TR-NKEV, TR-SCUD, TR-SDEF, TR-MINI, TR-LOGG, TR-ISOL

All mitigations from TH-KEVU apply (using that requirement's risk formula), plus:

Table B.4-19: Likelihood of TH-DDOS

Risk factors	Likelihood	Reached by
FNET is at level 0	Low	SP-REST, SP-GEN
FNET is at level 1	Medium	None
FNET is at level 2	High	C-NET

Mitigations for Impact:

- Medium to Low: RRIS
- High to Low: MNET

Table B.4-20: Impact of TH-DDOS

Risk factors	Impact	Reached by
TNET is at level 0	Low	SP-REST, SP-GEN
TNET is at level 1	Medium	C-NETR
TNET is at level 2	High	C-NET

B.4.12 TH-MQSE: Masquerading authorised server

Attacker can masquerade as an authorised server to get unauthorised access to product assets.

Assets affected: Network assets, Identity and access assets, and Data assets.

Requirements that mitigate this threat: TR-CDTX, TR-CRYP, TR-IDTX, TR-AUTH, TR-LOGG

Mitigations for Likelihood:

- Medium to Low: AUTH-1, AUTH-2, CDTX, ENTX, CRYP, INTT
- High to Low: AUTH-1, AUTH-2, CDTX, ENTX, CRYP, INTT

Table B.4-21: Likelihood of TH-MQSE

Risk factors	Likelihood	Reached by
TNET is at level 0	Low	SP-REST, SP-GEN
TNET is at level 1	Medium	C-NETR
TNET is at level 2	High	C-NET

Mitigations for Impact:

- Medium to Low: LOGG
- High to Low: LOGG

Table B.4-22: Impact of TH-MQSE

Risk factors	Impact	Reached by
none of SNDS, SNTD, SENF, or PPII is above level 0	Low	SP-REST
the highest of SNDS, SNTD, SENF, and PPII is at level 1	Medium	SP-GEN, C-DATA
SENF is at level 2	High	C-FUNC

B.4.13 TH-XUSR: Unauthorised access, resource exhaustion, or privilege escalation between concurrent users

An authorised user of a product that hosts more than one user account can exploit inadequate isolation between users to gain unauthorised access to another user's data or processes, to exhaust shared resources and deny service to other users, or to acquire privileges beyond those authorised for the account.

Assets affected: Data assets, Identity and access assets, and Product functions.

Requirements that mitigate this threat: TR-ISOL, TR-AUTH, TR-AVAI, TR-LOGG

Mitigations for Likelihood:

- Medium to Low: ISO-3, ISO-4, RLIM
- High to Low: ISO-3, ISO-4, RLIM, ISO-5, ACCS, PRIV

Table B.4-23: Likelihood of TH-XUSR

Risk factors	Likelihood	Reached by
NUSR is below level 2 and CUSR is at level 0	Low	SP-REST, SP-GEN
NUSR is at level 2 and CUSR is below level 2	Medium	C-MULTI
CUSR is at level 2	High	C-UNTR

Mitigations for Impact:

- Medium to Low: LOGG

Table B.4-24: Impact of TH-XUSR

Risk factors	Impact	Reached by
none of SNDS, SNTD, or PPII is above level 0	Low	SP-REST, SP-GEN
the highest of SNDS, SNTD, and PPII is at level 1	Medium	C-DATA

B.4.14 TH-LEAK: Data leak through side channels

Attacker can use the ability to run arbitrary software on the product to get unauthorised read access to confidential data.

Assets affected: Data assets and Hardware-interfacing assets.

Requirements that mitigate this threat: TR-DMIN, TR-ISOL

Mitigations for Likelihood:

- Medium to Low: ISO-6

Table B.4-25: Likelihood of TH-LEAK

Risk factors	Likelihood	Reached by
CUSR is at level 0 or none of SNDS or SNTD is above level 0	Low	SP-REST, SP-GEN
all others	Medium	C-UNTR with C-DATA

Mitigations for Impact:

- Medium to Low: DJST

Table B.4-26: Impact of TH-LEAK

Risk factors	Impact	Reached by
none of SNDS, SNDT, or PPII is above level 0	Low	SP-REST, SP-GEN
the highest of SNDS, SNDT, and PPII is at level 1	Medium	C-DATA

B.4.15 TH-RDPS: Compromise of the remote data processing solution boundary

Attacker can compromise the boundary between the product and a remote data processing solution by impersonating the remote endpoint, or by disrupting availability of interactions exchanged across the boundary, affecting the behaviour, state, configuration, or security of the RDPS-dependent product function described in clause [4.8](#).

Assets affected: Network assets, Data assets, Identity and access assets, and Product functions.

Requirements that mitigate this threat: TR-AUTH, TR-AVAI, TR-CRYP, TR-CDTX, TR-IDTX, TR-LOGG

Mitigations for Likelihood:

- Medium to Low: RAUT, CRYP, CDTX, ENTX, INTT

Table B.4-27: Likelihood of TH-RDPS

Risk factors	Likelihood	Reached by
RDPS is at level 0	Not applicable	SP-REST, SP-GEN
RDPS is at level 1	Medium	C-RDPS

Mitigations for Impact:

- Medium to Low: RTRY, LOGG

Table B.4-28: Impact of TH-RDPS

Risk factors	Impact	Reached by
RDPS is at level 0	Not applicable	SP-REST, SP-GEN
RDPS is at level 1	Medium	C-RDPS

B.4.16 TH-SUPP: Supply chain compromise

An attacker compromises a dependency used in the product's build process, such as a low-level driver, cryptographic library, or firmware, to inject a backdoor or exploitable vulnerability.

Assets affected: Software assets, Data assets, Identity and access assets, and Product functions.

The product's build process is outside the visibility and control of product-based protection mechanisms, so attacks on its integrity remain a residual risk that cannot be fully mitigated by the product.

B.4.17 TH-HARD: Compromise via hardware-level or platform trust components

Hardware-level capabilities, for example a compromised CPU, firmware, hardware security module, or physical access to deployed systems, can compromise the product or associated platform components below the software control plane. Such attacks can exploit manufacturer backdoors in processors or firmware, supply chain implants in platform components, or physical tampering vectors.

Assets affected: Software assets, Data assets, Identity and access assets, and Product functions.

Because hardware-level compromise can operate at privilege levels that exceed the visibility and control of software-based protection mechanisms, these attacks can bypass or undermine the integrity verification, integrity checks, and isolation mechanisms defined in the present document. Hardware-level compromise remains a residual risk that cannot be fully mitigated by the product.

B.5 Mapping of use cases to risk factors

B.5.1 General

Each basic use case in clause 4.7.2 is associated with a baseline level for every risk factor defined in clause B.2. The basic use case is determined by a single capability of the product, namely whether it is a restricted operating system (UC-REST) or a general-purpose computing platform (UC-GEN). Each condition in clause 4.7.3 raises one or more risk factors. The risk profile of a product is obtained by taking, for each risk factor, the highest level assigned by the product's basic use case and by any condition that holds for it, as described in clause 4.7.4. Where the product is characterised as UC-GEN and a condition cannot be determined, the condition is taken to hold. This clause records the baseline levels and the condition increments from which the security profiles in clause B.6 are derived. Levels follow clause B.2, where level 0 is the lowest and level 2 the highest.

B.5.2 Baseline risk-factor levels of the basic use cases

Table B.5-1 gives the baseline level that each basic use case assigns to each risk factor. UC-REST begins from the lowest levels for all capability and exposure factors, reflecting a restricted, self-administered product; UC-GEN begins from the levels of a minimal single-user general-purpose system. All further capabilities and exposures are added through the conditions in clause B.5.3.

Table B.5-1: Baseline risk-factor levels of the basic use cases

Risk factor	UC-REST	UC-GEN
RF-NUSR Number of user accounts	0	1
RF-CUSR User-account concurrency	0	0
RF-PPII Collection of PII	0	0
RF-SNDS Sensitivity of data stored	0	0
RF-SNDT Sensitivity of data transmitted	0	0
RF-SENF Sensitivity of functions	0	1
RF-PHYS Physical access by threat actors	0	0
RF-UEIN Untrusted external inputs	0	1
RF-LOSS Probability of loss/theft	0	0
RF-HWMD Hardware modifiability	0	0
RF-SWMD Software modifiability	0	0
RF-DVCS Untrusted peripheral devices	0	0
RF-TNET Access to a public network	0	0
RF-FNET Reached from untrusted networks	0	0
RF-CONF Configurability	0	1
RF-ADMN Administration	2	1
RF-SUPP Support and foreseeable updates	1	2
RF-RDPS Remote data-processing dependency	0	0

NOTE: Risk factors that depend on a capability or exposure the product does or does not have (network access, multiple accounts, installation of software, storage of sensitive data, physical exposure, loss likelihood, and remote data-processing dependency) are not set by the basic use case. They are set by the conditions in clause [B.5.3](#), so that a product is rated for the capabilities and exposures it actually has.

B.5.3 Condition increments

Table B.5-2 gives, for each condition, the risk factors it raises and the minimum level to which it raises them. A condition takes effect only where it holds for the product, as determined in clause [4.7.4](#). These increments mirror the conditions defined in clause [4.7.3](#).

Table B.5-2: Risk-factor increments of the conditions

Condition	Risk factors raised to at least
C-NET	TNET-2, FNET-2, UEIN-2
C-NETR	TNET-1
C-MOD	SWMD-1, HWMD-1, CONF-2
C-APPS	SWMD-2
C-LOSS	LOSS-2, PHYS-1
C-MULTI	NUSR-2
C-UNTR	CUSR-2
C-DATA	SNDS-1, SNTD-1, PPII-1
C-FUNC	SENF-2
C-RDPS	RDPS-1
C-PHYS	PHYS-2, DVCS-2
C-SELFADM	ADMN-2

B.5.4 Deriving the risk profile of a product

The risk profile of a product is the vector of risk-factor levels obtained by combining the baseline of its basic use case (Table B.5-1) with the increments of every condition that holds (Table B.5-2), taking the highest level for each risk factor. The risk profile is the basis for the security profile in clause [B.6](#).

EXAMPLE: A personal laptop that connects to public networks, permits arbitrary software installation, is a foreseeable target of theft, and holds sensitive personal data is characterised as UC-GEN with conditions C-NET, C-MOD, C-LOSS, and C-DATA. Starting from the UC-GEN baseline of Table B.5-1, C-NET raises TNET, FNET, and UEIN to at least 2; C-MOD raises SWMD and HWMD to at least 1 and CONF to 2; C-LOSS raises LOSS to 2 and PHYS to 1; and C-DATA raises SNDS, SNTD, and PPII to 1. The highest level is taken for each factor, giving the product's risk profile.

B.6 Security profiles

B.6.1 General

There are two security profiles, SP-REST and SP-GEN, one for each basic use case in clause [4.7.2](#). The security profiles are defined normatively in clause [5.3](#). Each security profile is associated with the baseline risk-factor levels of its basic use case, as given in Table B.5-1. A product is assigned the security profile that corresponds to its basic use case.

The conditions in clause [4.7.3](#) are not separate security profiles. Each mitigation that addresses a risk introduced by a condition carries that condition as its applicability condition, as described in clause [4.7.3](#), and applies to a product, in addition to its security profile, wherever the condition holds, independently of the basic use case. The mitigations a product implements are therefore:

- every unconditioned mitigation listed for the product's security profile in clause [5.3](#); together with
- every mitigation that carries a condition the product meets, whatever the product's security profile.

NOTE: Expressing capabilities and exposures as a condition overlay rather than as separate profiles keeps the number of security profiles at two, instead of requiring a distinct profile for every combination of capabilities. A product's risk profile (clause B.5.4) is covered by its security profile together with the conditioned mitigations that apply to it, so no further profile selection is needed. A general-purpose product whose conditions are all assumed to hold (clause 4.7.4) implements every conditioned mitigation, which corresponds to the most demanding profile.

B.6.2 Mapping of security profiles to risk factors

Table B.6-1 associates each security profile with the risk-factor levels of its basic use case. These are the baseline levels of Table B.5-1; the increments of Table B.5-2 are realised through the applicability of the conditioned mitigations rather than through additional security profiles.

Table B.6-1: Mapping of security profiles to risk factors

Risk factor	SP-REST	SP-GEN
RF-NUSR Number of user accounts	0	1
RF-CUSR User-account concurrency	0	0
RF-PPII Collection of PII	0	0
RF-SNDS Sensitivity of data stored	0	0
RF-SNDT Sensitivity of data transmitted	0	0
RF-SENF Sensitivity of functions	0	1
RF-PHYS Physical access by threat actors	0	0
RF-UEIN Untrusted external inputs	0	1
RF-LOSS Probability of loss/theft	0	0
RF-HWMD Hardware modifiability	0	0
RF-SWMD Software modifiability	0	0
RF-DVCS Untrusted peripheral devices	0	0
RF-TNET Access to a public network	0	0
RF-FNET Reached from untrusted networks	0	0
RF-CONF Configurability	0	1
RF-ADMN Administration	2	1
RF-SUPP Support and foreseeable updates	1	2
RF-RDPS Remote data-processing dependency	0	0

B.6.3 Determining the applicable mitigations

The mitigations a product implements are determined as follows:

- 1) characterise the product as in clause 4.7.4, giving its basic use case and the conditions that hold;
- 2) select the security profile that corresponds to the basic use case, namely SP-REST or SP-GEN, and read its mitigations from clause 5.3;
- 3) implement every mitigation of that security profile that does not carry a condition;
- 4) implement every mitigation, of that security profile or otherwise, that carries a condition the product meets; and
- 5) for each mitigation whose condition does not hold, record the basis for the determination, as required by clause 4.7.4.

Where a security profile lists alternative mitigations, the manufacturer implements at least one of the listed alternatives, as specified in clause 5.3.

B.6.4 Relationship to the threat analysis

Mitigations of a security profile address one or more of the threats in clause [B.4](#) whose likelihood or impact is raised by the risk factors at the levels of that profile (Table B.6-1), and each conditioned mitigation addresses a threat whose likelihood or impact is raised by the risk factors that the corresponding condition raises (Table B.5-2). The security analysis in clause [B.4](#) is therefore the principal basis both for the contents of the security profiles and for the conditions carried by the individual mitigations.

Two further bases apply to the baseline mitigations. First, state of the art cryptography (Annex K) and the secure update mitigations are horizontal requirements of the CRA: they apply to every product that uses cryptography or that receives updates, independently of its risk-factor levels, and are therefore included in both baselines rather than derived from a single threat tier. Second, the general-purpose baseline (SP-GEN) additionally includes the stored-data protection mitigations and the secure-development, isolation, and hardening mitigations, because a general-purpose operating system stores and processes user data and is expected to meet at least one high-exposure condition in foreseeable use. A restricted operating system reaches these same mitigations only through the conditions that apply to it.

Annexes C to J:
Void

Annex K (normative): Generic requirements and assessment criteria for the use of state of the art cryptography

K.0 General

This annex specifies the cryptographic requirement for the present document, the assessment of the product's cryptographic configuration, the crypto-agility requirement, and the cryptographic mechanisms recognised by the present document in addition to the European Cybersecurity Certification Group's Agreed Cryptographic Mechanisms catalogue (ACM) [1]. The terms cryptographic mechanism and cryptographic property used in this annex are defined in clause 3.1.

K.1 Cryptography

K.1.1 Requirement

The product's default configuration shall only use cryptographic mechanisms that meet at least one of the following criteria:

- 1) ACM-listed: the cryptographic mechanism is listed in the ACM catalogue [1];
- 2) ACM-extended: the cryptographic mechanism is not listed in the ACM catalogue [1] and meets at least one of the following conditions:
 - a) the cryptographic mechanism is listed in clause [K.3.2](#) as an ACM-extended cryptographic mechanism for the specific product function(s);
 - b) where the cryptographic mechanism is not listed in clause [K.3.2](#), the cryptographic mechanism meets all the following criteria:
 - i) the cryptographic mechanism, or where applicable the ACM-listed cryptographic mechanism on which it is based, is not deprecated per the ACM catalogue [1];
 - ii) the cryptographic mechanism has been specified, developed or maintained through a transparent process by a recognised European, international or sector-specific standards development organisation, or by an industry specification organisation accountable for the relevant specification (for example ETSI, ISO/IEC, IETF, IEEE, 3GPP or ITU-T); or the cryptographic mechanism is listed as suitable in a publicly available cryptographic catalogue maintained by a recognised national or governmental cybersecurity authority, where the catalogue is maintained under a documented revision and retirement process (for example BSI TR-02102 [2], ANSSI Référentiel Général de Sécurité Annex B2 [i.14], the NIST Special Publication 800 series [4], or CCCS ITSP.40.062 [5]);
 - iii) the cryptographic mechanism is described in a valid, publicly available and uniquely referenceable specification;
 - iv) the cryptographic properties of the cryptographic mechanism are known;
 - v) no known weakness affects the cryptographic mechanism in a way that affects its cryptographic properties;
 - vi) the cryptographic mechanism is required for a specific set of product functions.
 - c) interoperability-based: the cryptographic mechanism is listed in clause [K.4.2](#) as an interoperability-based cryptographic mechanism for specific product function(s) and external specification(s) or external requirement(s).

NOTE 1: The reference to the product's default configuration is intended to define a clear and assessable baseline, corresponding to the configuration in which the product is placed on the market. The product can provide several configurations that fulfil the requirement.

NOTE 2: For products supplied as hardware platforms or components to be configured by an integrator, references in this annex to the product's default configuration refer to the configuration specified for the intended operational use of the product after integration, including the relevant integration assumptions and configuration constraints.

NOTE 3: The applicable ACM catalogue version is identified in the normative references of the present document. The lifecycle treatment of mechanisms affected by ACM deprecation dates, expiry dates, migration conditions or usage limitations is addressed in clause [K.2](#).

NOTE 4: In this clause, an external specification or external requirement means a specification or requirement that is imposed on the product, and which requires the use of a specific cryptographic mechanism for the product to interoperate with an identified system, platform or operational context. An external requirement can be a regulatory requirement, operational constraint, technical interoperability constraint, or platform compatibility requirement.

NOTE 5: Inclusion of a cryptographic mechanism under the interoperability-based criterion does not classify that mechanism as state of the art cryptography.

EXAMPLE: Examples of product functions of an operating system include secure communication based on TLS 1.3; authenticated encryption of stored or communicated data based on AES-GCM; storage confidentiality based on AES-XTS; kernel module and boot signature verification based on Ed25519 or ECDSA; protection of stored credentials based on Argon2id; and key derivation based on HKDF.

K.1.2 Assessment of product cryptographic configuration

K.1.2.0 General

The assessment in this clause verifies the cryptographic mechanisms used in the product's default configuration against clause [K.1.1](#).

For ACM-extended cryptographic mechanisms, the assessment verifies that the cryptographic mechanism is either listed in clause [K.3.2](#) or fulfils the criteria specified in clause [K.1.1](#) item 2)b). For interoperability-based cryptographic mechanisms, the assessment verifies that the cryptographic mechanism is listed in clause [K.4.2](#). The assessment also verifies that the product uses the cryptographic mechanism in accordance with the relevant characteristics, product functions, use cases where applicable, external specifications or external requirements, and conditions specified in the present document.

K.1.2.1 Assessment of ACM-listed cryptographic mechanisms

K.1.2.1.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause [K.1.1](#) item 1) and used in the product's default configuration are listed in the ACM catalogue [1].

K.1.2.1.2 Assessment preparation

- Preconditions for the assessment: the product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause [K.1.1](#) item 1), including the related product function, relevant parameters where applicable, and the relevant ACM entry.

K.1.2.1.3 Assessment activities

The assessment shall include verification that:

- 1) each cryptographic mechanism claimed under clause [K.1.1](#) item 1) is identified by reference to a relevant ACM entry;
- 2) the ACM entry corresponds to the cryptographic mechanism used in the product's default configuration, including relevant parameters where applicable;
- 3) where the ACM entry includes lifecycle information, such as expiry date, deprecation date, migration condition or usage limitation, this information is reflected in the documentation.

K.1.2.1.4 Assessment evidence

The assessment evidence shall include, as applicable:

- 1) description of the product's default configuration;
- 2) list of cryptographic mechanisms claimed under clause [K.1.1](#) item 1);
- 3) references to the relevant ACM entries;
- 4) relevant parameters, profiles, cipher suites or configuration constraints, where applicable;
- 5) relevant lifecycle information from the ACM catalogue, where applicable.

K.1.2.1.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause [K.1.1](#) item 1).
- The verdict FAIL shall be assigned otherwise.

K.1.2.2 Assessment of ACM-extended cryptographic mechanisms

K.1.2.2.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause [K.1.1](#) item 2) and used in the product's default configuration are either listed as ACM-extended cryptographic mechanisms in clause [K.3.2](#) or fulfil the criteria specified in clause [K.1.1](#) item 2.b, and are used for the claimed product function(s).

K.1.2.2.2 Assessment preparation

- Preconditions for the assessment: the product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause [K.1.1](#) item 2), including the related product function, use case where applicable, relevant parameters where applicable, and at least one of the following: the relevant entry in clause [K.3.2](#); or evidence that the cryptographic mechanism fulfils all applicable criteria in clause [K.1.1](#) item 2)b).

K.1.2.2.3 Assessment activities

The assessment shall include verification that:

- 1) each cryptographic mechanism claimed under clause [K.1.1](#) item 2) is either listed in clause [K.3.2](#) as an ACM-extended cryptographic mechanism or supported by evidence demonstrating fulfilment of the applicable criteria in clause [K.1.1](#) item 2)b);
- 2) the cryptographic mechanism used by the product corresponds to the mechanism listed in clause [K.3.2](#) or described in the evidence provided under clause [K.1.1](#) item 2)b);

- 3) the product function using the cryptographic mechanism, and the use case where applicable, correspond to the related product function and use case specified in clause [K.3.2](#) or justified under clause [K.1.1](#) item 2)b);
- 4) the relevant characteristics, parameters, profiles, cipher suites or configuration constraints of the cryptographic mechanism correspond to those specified in clause [K.3.2](#) or justified under clause [K.1.1](#) item 2)b), where applicable;
- 5) where clause [K.3.2](#) or the justification under clause [K.1.1](#) item 2)b) defines conditions or limitations for the use of the cryptographic mechanism, these conditions or limitations are reflected in the product's default configuration;
- 6) where technically feasible, the cryptographic mechanism, parameters and configuration identified in the documentation correspond to the assessed product configuration.

K.1.2.2.4 Assessment evidence

The assessment evidence shall include, as applicable:

- 1) description of the product's default configuration;
- 2) list of cryptographic mechanisms claimed under clause [K.1.1](#) item 2);
- 3) reference to the relevant entry in clause [K.3.2](#), where the mechanism is listed there;
- 4) evidence that the cryptographic mechanism fulfils the criteria in clause [K.1.1](#) item 2)b), where compliance is claimed on the basis of those criteria;
- 5) identification of the related product function using the cryptographic mechanism and the use case where applicable;
- 6) relevant characteristics, parameters, profiles, cipher suites or configuration constraints, where applicable;
- 7) evidence that the cryptographic mechanism is used in accordance with the conditions or limitations specified in clause [K.3.2](#) or in the justification under clause [K.1.1](#) item 2)b), where applicable.

K.1.2.2.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause [K.1.1](#) item 2).
- The verdict FAIL shall be assigned otherwise.

K.1.2.3 Assessment of interoperability-based cryptographic mechanisms

K.1.2.3.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause [K.1.1](#) item 3) and used in the product's default configuration are listed as interoperability-based cryptographic mechanisms in clause [K.4.2](#) and are used in accordance with the characteristics, product functions, use cases where applicable, external specifications or external requirements, and conditions specified in clause [K.4.2](#).

K.1.2.3.2 Assessment preparation

- Preconditions for the assessment: the product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause [K.1.1](#) item 3), including the related product function, use case where applicable, relevant parameters where applicable, the external specification or external requirement requiring its use, and the relevant entry in clause [K.4.2](#).

K.1.2.3.3 Assessment activities

The assessment shall include verification that:

- 1) each cryptographic mechanism claimed under clause [K.1.1](#) item 3) is listed in clause [K.4.2](#) as an interoperability-based cryptographic mechanism;
- 2) the cryptographic mechanism used by the product corresponds to the cryptographic mechanism listed in clause [K.4.2](#);
- 3) the product function using the cryptographic mechanism, and the use case where applicable, correspond to the related product function and use case specified in clause [K.4.2](#);
- 4) the external specification or external requirement requiring the use of the cryptographic mechanism corresponds to the external specification or external requirement specified in clause [K.4.2](#);
- 5) the relevant characteristics, parameters, profiles, cipher suites or configuration constraints of the cryptographic mechanism correspond to those specified in clause [K.4.2](#), where applicable;
- 6) the conditions or limitations specified in clause [K.4.2](#) for the use of the cryptographic mechanism are reflected in the product's default configuration;
- 7) where technically feasible, the cryptographic mechanism, parameters and configuration identified in the documentation correspond to the assessed product configuration.

K.1.2.3.4 Assessment evidence

The assessment evidence shall include, as applicable:

- 1) description of the product's default configuration;
- 2) list of cryptographic mechanisms claimed under clause [K.1.1](#) item 3);
- 3) reference to the relevant entry in clause [K.4.2](#);
- 4) identification of the related product function using the cryptographic mechanism and the use case where applicable;
- 5) identification of the external specification or external requirement requiring use of the cryptographic mechanism;
- 6) relevant characteristics, parameters, profiles, cipher suites or configuration constraints, where applicable;
- 7) evidence that the cryptographic mechanism is used in accordance with the conditions or limitations specified in clause [K.4.2](#).

K.1.2.3.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause [K.1.1](#) item 3).
- The verdict FAIL shall be assigned otherwise.

NOTE 1: The assessment of the external specification or external requirement itself is outside the scope of this assessment case. The assessment verifies that the external specification or external requirement is identified in clause [K.4.2](#) and that the cryptographic mechanism is used by the product for the related product function.

NOTE 2: Documentation review is a minimum assessment activity under the present annex. Functional or resistance testing activities can be added by the present document where relevant for the product category, product function or cryptographic mechanism.

K.2 Crypto agility

K.2.1 Requirement

Where the product's default configuration uses a cryptographic mechanism for which the ACM catalogue [1], or the present document, specifies a deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product, the product shall provide means for addressing the affected cryptographic mechanism by one or more of the following:

- a) updating the cryptographic mechanism;
- b) using another cryptographic mechanism that complies with clause [K.1.1](#) and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation;
- c) disabling the use of the affected cryptographic mechanism; or
- d) limiting the use of the affected product functions accordingly.

EXAMPLE: Where a security mechanism uses a hybrid cryptographic construction, for example a hybrid key-encapsulation mechanism combining a classical and a post-quantum primitive, the lifecycle status of each constituent primitive is relevant to the lifecycle status of the construction. Hybridisation can be used as part of a planned migration strategy where permitted by the ACM catalogue or by the present document. However, hybridisation does not, by itself, extend the recommended usage lifetime of a constituent primitive that has been deprecated.

NOTE 1: Where a hybrid cryptographic construction includes multiple cryptographic primitives, the lifecycle status of each constituent primitive is relevant to the lifecycle status of the construction. Hybridisation is not assumed to mitigate the deprecation of a constituent primitive unless the ACM catalogue or the present document classifies the hybrid construction as suitable for the corresponding product function.

NOTE 2: Crypto agility supports maintaining appropriate cryptographic protection within the intended lifetime of the product, in addition to the capability of updating cryptographic mechanisms on the product in accordance with secure update and secure communication mechanisms.

NOTE 3: Deprecation information from sources other than the ACM catalogue or the present document can be considered as input to vulnerability management or security risk assessment but does not by itself trigger the requirement in clause [K.2.1](#).

NOTE 4: Where the product provides cryptographic capabilities for use by other products, components or layers, the mechanism required by clause [K.2.1](#) can consist of update, configuration, disabling, deprecation or limitation capabilities usable by the integrating product, system operator or user, where applicable.

NOTE 5: The applicability condition of this requirement can express exceptions based on product characteristics, for example a cryptographic implementation based on an immutable hardware co-processor or a hardware-based root of trust, or long-lived silicon used in a long-lived non-updateable environment.

K.2.2 Assessment of crypto-agility

K.2.2.1 Assessment objective

The purpose of this assessment case is to verify whether, where the product's default configuration uses a cryptographic mechanism for which the ACM catalogue [1], or the present document, specifies a deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product, the product provides means to address the affected cryptographic mechanism in accordance with clause [K.2.1](#).

K.2.2.2 Assessment preparation

- Preconditions for the assessment: the product's default configuration shall be used for the assessment.

The documentation shall identify:

- a) the intended lifetime of the product;
- b) the cryptographic mechanisms used in the product's default configuration;
- c) the related product function(s) for each cryptographic mechanism;
- d) the lifecycle information applicable to each cryptographic mechanism, where specified by the ACM catalogue or the present document, including any deprecation date, expiry date, migration condition or usage limitation.

K.2.2.3 Assessment activities

The assessment shall include verification that:

- a) for each cryptographic mechanism used in the product's default configuration, the lifecycle information specified by the ACM catalogue or the present document has been identified, where such information is specified;
- b) where the ACM catalogue or the present document specifies a deprecation date, expiry date, migration condition or usage limitation for a cryptographic mechanism, this information is reflected in the documentation;
- c) where a deprecation date, expiry date, migration condition or usage limitation falls within the intended lifetime of the product, the product provides an applicable mechanism for updating the cryptographic mechanism, using another cryptographic mechanism that complies with clause [K.1.1](#) and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation, disabling the use of the affected cryptographic mechanism, or limiting the use of the affected product functions accordingly;
- d) where another cryptographic mechanism is used, that cryptographic mechanism complies with clause [K.1.1](#) and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation.

K.2.2.4 Assessment evidence

The assessment evidence shall include, as applicable:

- a) documentation of the intended lifetime of the product;
- b) list of cryptographic mechanisms used in the product's default configuration;
- c) identification of the related product function(s) for each cryptographic mechanism;
- d) references to the ACM catalogue entry or to the provision of the present document used to determine lifecycle information, where applicable;
- e) identification of any deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product;
- f) description of the means provided by the product, such as update of the cryptographic mechanism, use of another cryptographic mechanism that complies with clause [K.1.1](#) and is not subject to the relevant lifecycle constraint, disabling the use of the affected cryptographic mechanism, or limitation of the use of the affected product functions.

K.2.2.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause [K.2.1](#).
- The verdict FAIL shall be assigned otherwise.

K.3 ACM-extended cryptographic mechanisms

K.3.1 Requirement

Where the product's default configuration uses ACM-extended cryptographic mechanisms, these mechanisms shall comply with the ACM-extended criterion in clause [K.1.1](#) item 2).

K.3.2 List of ACM-extended cryptographic mechanisms

The ACM-extended cryptographic mechanisms specified by the present document are listed in Table [K.3-1](#).

Table K.3-1: ACM-extended cryptographic mechanisms specified by the present document.

Cryptographic mechanism	Type	Related product function	Specification	Conditions or limitations
ChaCha20	Stream cipher	Software-based confidentiality, in particular protected communication and volume encryption on platforms without AES hardware acceleration	IETF RFC 8439 [9]	Used with unique nonces per key. Not used alone where integrity or authenticity is required; in that case used within an authenticated construction or combined with an appropriate integrity mechanism.
ChaCha20-Poly1305	Authenticated encryption (AEAD)	Confidentiality and data-origin authentication of communicated or stored data, for example TLS, secure tunnels, and software-based encryption where AES acceleration is unavailable	IETF RFC 8439 [9]	Nonces generated and managed according to the applicable protocol profile. Reuse of a nonce with the same key prevented.
Poly1305	Message authentication code	Message integrity and data-origin authentication, primarily as part of ChaCha20-Poly1305	IETF RFC 8439 [9]	Not used as a standalone MAC unless the implementation ensures correct one-time key generation and use according to IETF RFC 8439 [9].
X25519 and X448	Elliptic-curve Diffie-Hellman key agreement	Key agreement for TLS, SSH and secure-channel establishment	IETF RFC 7748 [6]; IETF RFC 8410 [8] for X.509 algorithm identifiers	The shared secret is processed through a suitable key derivation function or protocol-defined key schedule. Used only in protocol profiles that provide peer authentication and protection against active attacks where required.

Cryptographic mechanism	Type	Related product function	Specification	Conditions or limitations
Ed25519 and Ed448	Digital signature (EdDSA)	Signature verification for kernel module signing, boot integrity, software update and package signing, and SSH	IETF RFC 8032 [7]; IETF RFC 8410 [8] for X.509 algorithm identifiers	Used where supported by the applicable certificate profile, update framework or trust framework, with an appropriate key-management model. Ed25519 and Ed448 provide signature verification, not entity authentication by themselves.
Argon2id	Password hashing function	Protection of stored user and administrator authentication credentials (password verification), and derivation of storage-encryption keys from passphrases where the product implements passphrase-protected storage encryption	IETF RFC 9106 [10]	Each password verifier uses a unique random salt of at least 128 bits. Memory, iteration and parallelism parameters selected according to the product threat model and documented. Where used as a key derivation function for storage encryption, the salt is not reused across volumes or derived keys.
yescrypt	Password hashing function	Protection of stored authentication credentials and derivation of keys from passwords	Leverages IETF RFC 7914 [11] with state-of-the-art enhancements for GPU attack and cache-timing side-channel resistance. Uses ACM and NIST-approved cryptographic primitives: SHA-256 (ACM 2.3, FIPS PUB 180-4 [21]), HMAC (ACM 3.3, FIPS PUB 198-1 [22]), and PBKDF2 (ACM 3.7, NIST SP 800-132 [14]). It was a finalist with special recognition in the Password Hashing Competition (2013-2015) and is recommended in ANSSI's Guidelines for GNU/Linux Systems [i.14].	Each password verifier uses a unique random salt of at least 128 bits. An output of at least 256 bits. Cost parameter defaulting to 5 or greater.
SP 800-108 KDFs	Key Derivation Function	Derivation of subordinate keys from an existing secret key	NIST SP 800-108 Rev. 1 [3]	Derives additional keying material from an already established secret key using an approved PRF (e.g. HMAC, CMAC, or KMAC). Security depends on the strength of the source key and the approved PRF.

K.3.3 Assessment

Compliance with the ACM-extended criterion in clause [K.1.1](#) item) 2 is assessed in clause [K.1.2.2](#).

K.4 Interoperability-based cryptographic mechanisms

K.4.1 Requirement

Where the product's default configuration uses interoperability-based cryptographic mechanisms, these mechanisms shall be selected from the interoperability-based cryptographic mechanisms listed in clause [K.4.2](#) for the specified product functions and external specifications or external requirements, and shall be used in accordance with the conditions or limitations specified in clause [K.4.2](#).

K.4.2 List of interoperability-based cryptographic mechanisms

The interoperability-based cryptographic mechanisms specified by the present document are listed in Table [K.4-1](#). Inclusion of a cryptographic mechanism in this clause does not classify that mechanism as state of the art cryptography.

Table K.4-1: Interoperability-based cryptographic mechanisms specified by the present document

Cryptographic mechanism	Type	Related product function	Specification	Interoperability justification	Conditions or limitations
scrypt	Password hashing function	Protection of stored authentication credentials, or derivation of keys from passwords, where an existing format requires it	IETF RFC 7914 [11]	Required by an identified external specification, stored password-verifier format, encrypted storage format, or established deployment profile	Use limited to the identified interoperability purpose. Each password verifier uses a unique random salt of at least 128 bits. Cost parameters N, r and p selected and justified according to the product threat model and intended lifetime. Inclusion under this route does not classify scrypt as state of the art cryptography.
MD5	Hash function	Detection of data corruption	IETF RFC 1321 [12]	Widely used and deeply embedded in product ecosystems as a checksum for non-adversarial purposes	Used only for checksum purposes. Inclusion under this route does not classify MD5 as state of the art cryptography.

Cryptographic mechanism	Type	Related product function	Specification	Interoperability justification	Conditions or limitations
SHA-1	Hash function	Detection of data corruption	IETF RFC 3174 [13]	Widely used and deeply embedded in product ecosystems as a checksum for non-adversarial purposes	Used only for checksum purposes. Inclusion under this route does not classify SHA-1 as state of the art cryptography.
DES/TDEA	Symmetric Block Cipher	Legacy data encryption, compatibility with older protocols and file formats	FIPS PUB 46-3 [i.13]	Required to access or decrypt legacy data, systems, or protocols that cannot yet be migrated to stronger algorithms	Retained only for decrypting or accessing legacy data protected with DES/TDEA.
RC2	Symmetric Block Cipher	Legacy certificate, S/MIME, and PKCS#12 compatibility scenarios	IETF RFC 2268 [15]	Required for import, export, or processing of legacy certificates, archives, and encrypted content created by older products and infrastructure	Retained only for decrypting or accessing legacy data protected with RC2.
RC4	Symmetric Stream Cipher	Legacy TLS, SSL, Kerberos, and application compatibility scenarios	IETF RFC 7465 [16]; IETF RFC 6229 [17]	Required only to communicate with legacy clients, servers, or applications that have not yet migrated to modern cipher suites. Used solely for backward compatibility	Supported only for backward compatibility with legacy data or protocols.
NIST P-192 (secp192r1)	Elliptic Curve Cryptography (ECC)	Legacy ECDSA signature verification and ECDH key agreement interoperability	FIPS PUB 186-5 [18]; SEC 2 [19]	Required to interoperate with legacy PKI deployments, certificates, smart cards, embedded devices, and network appliances that continue to use P-192 for authentication or key agreement	Retained for processing existing certificates, signatures, and protocols that depend on P-192.

Cryptographic mechanism	Type	Related product function	Specification	Interoperability justification	Conditions or limitations
SP 800-135	Key Derivation Function	Derivation of session encryption, integrity and authentication keys	NIST SP 800-135 Rev. 1 [20]	Required for interoperability with standards compliant SSH servers and client. Enables secure remote administration, file transfer, and automation scenarios using SSH protocols. Required to interoperate with standards-compliant TLS implementations and device session keys necessary for secure communications between clients and servers	Retained only for accessing legacy protocols. Where the product is in control of crypto agility, the product shall default to state-of-the art cryptography.

K.4.3 Assessment

Compliance with the requirement in clause [K.4](#) is assessed in clause [K.1.2.3](#).

NOTE: The assessment of the external specifications or external requirements themselves is outside the scope of this assessment. Their relevance is deemed confirmed by their inclusion in the present document.

Annex L (informative): Change history

Version	Information about changes
V1.0.1	Final draft

History

Version	Date	Status
V1.0.1	August 2026	SRdAP process EV 20261105: 2026-08-13 to 2026-11-05